

网络空间安全导论（复习版）

2025-2026-1学期

池浩田

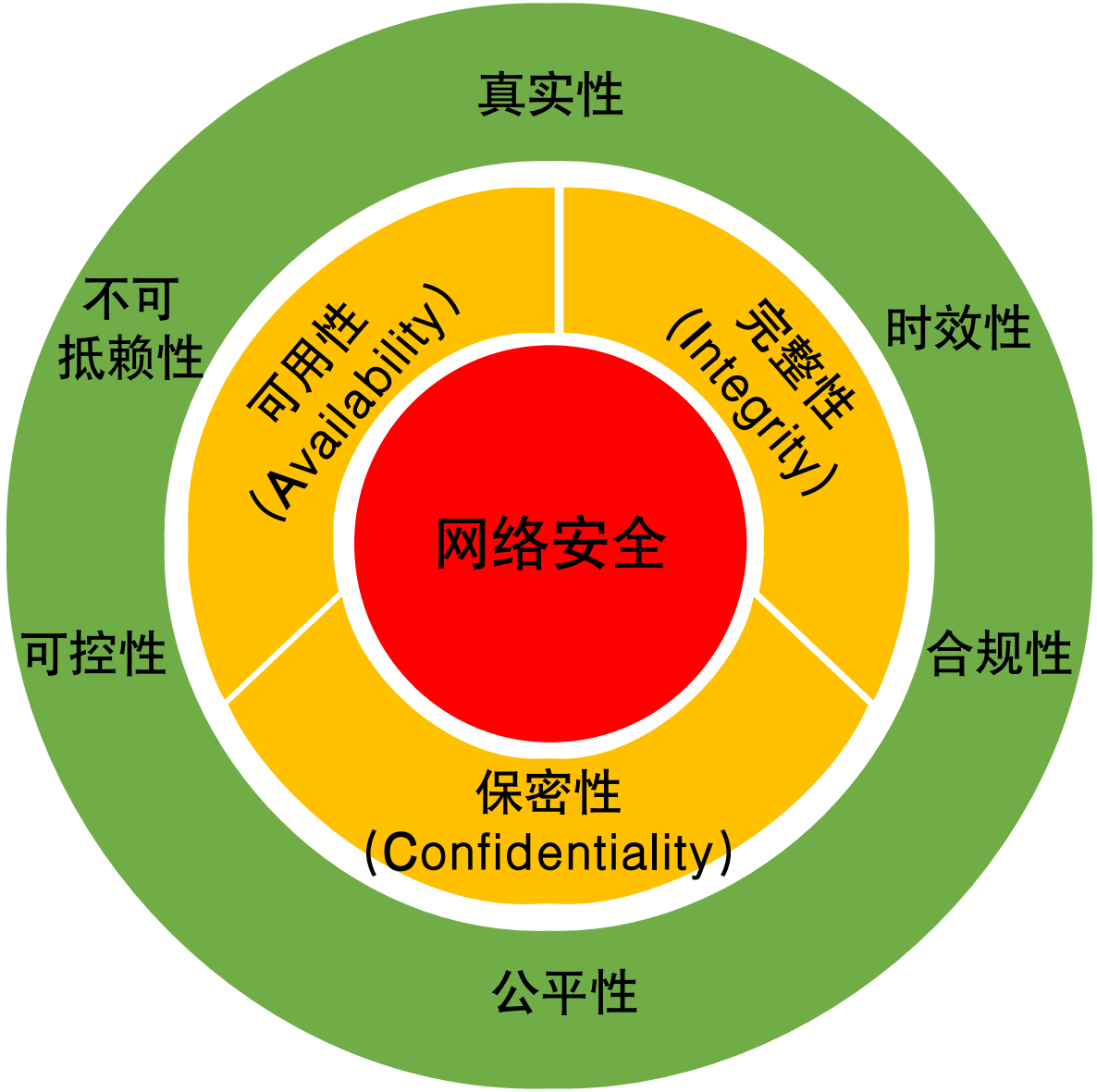
山西大学 自动化与软件学院

第1章 网络安全概述

网络安全的定义

网络安全是指网络系统的硬件、软件及其系统中的数据受到保护，不受偶然的或者恶意的原因而遭到破坏、更改、泄露，系统连续可靠正常地运行，网络服务不中断。

网络安全的目标



三大目标（CIA）

- 保密性（Confidentiality）
- 完整性（Integrity）
- 可用性（Availability）

其它目标：

- 可控性
- 不可抵赖性
- 合规性
- 真实性等

网络安全特征的解释

（1）**保密性**。信息不泄露给非授权的用户、实体或过程，或供其利用的特性。不被窃听、不被非法使用

（2）**完整性**。数据未经授权不能进行改变的特性。不被拦截、不被丢失、不被篡改

（3）**可用性**。可被授权实体访问并按需求使用的特性，即当需要时应能存取所需的信息。正常提供服务

常见网络安全威胁

常见的网络安全威胁包括但不限于：

（1）**非授权访问：**非授权用户对系统和网络资源的入侵和访问。

（2）**信息泄露：**指将有价值的和高度机密的信息暴露给无权访问该信息的人。

（3）**拒绝服务：**指使计算机或网络无法提供正常的服务与资源访问，使目标停止响应甚至崩溃。这些服务资源包括网络带宽、文件系统空间容量、开放的进程或者允许的连接。

网络安全威胁

思考一下：
下列威胁破坏了网络安全的哪个要求?

- 非授权访问。这主要是指对网络设备以及信息资源进行非正常使用或超越权限使用。保密性
- 假冒合法用户。主要指利用各种假冒或欺骗的手段非法获得合法用户的使用权，以达到占用合法用户资源的目的。保密性
- 数据完整性受破坏。完整性
- 干扰系统的正常运行，改变系统正常运行的方向，以及延时系统的响应时间。可用性
- 病毒。保密性、完整性、可用性
- 通信线路被窃听等。保密性

1.5 风险管理及评估

风险管理指的是识别、评估和控制网络系统安全风险的总过程，它贯穿于整个系统开发生命周期，包括风险识别、风险评估、风险处置三个核心步骤。

风险评估就是对网络自身存在的脆弱性状况、外界环境可能导致网络安全事件发生的可能性以及可能造成的影响进行评价。

风险评估的实现流程

01

识别威胁

为了能够进行更为集中的评估，应该对那些可能产生威胁的细节给予特别的关注。识别威胁的过程有利于改进网络管理和及时发现漏洞，这些改进的措施在一定程度上将减少威胁的危险性。

02

测量风险

测量风险是说明各种敌对行为在一个系统或应用中发生的可能性及发生的概率。

03

风险分析结果

风险分析结果可以用典型的定量法和定性法进行描述。定量法可用于描述预计的金钱损失量。定性法是描述性质的，通常用高、中、低或用1~10等级等形式来表示。

风险处置

一般风险处置的方式有降低风险、避免风险、转移风险、接受风险。对于风险的处置我们应针对识别的风险制定风险处置计划，主要包括时间、角色、职责分配、资金等的安排。

风险处置的目的是降低企业的业务风险，所以在制定处置方式时我们**要对风险发生所带来的损失和处置风险所花的成本进行平衡**，防止得不偿失的情况出现。

第2章 计算机系统安全与访问控制

2.1 什么是计算机安全

计算机安全的**主要目标**是保护计算机资源免受毁坏、替换、盗窃和丢失。这些计算机资源包括计算机设备、存储介质、软件和计算机输出材料和数据。

计算机部件中经常发生的一些电子和机械故障有：

磁盘故障，I/O控制器故障，电源故障，存储器故障，介质、设备和其它备份故障，芯片和主板故障等。

网络安全等级保护制度

等保测评

网站：https://www.djbh.net/

视频介绍：
https://www.bilibili.com/video/BV1ThG3evEK5/?spm_id_from=333.337.search-card.all.click

TCSEC安全级别

安全级别有两个含义，一个是主客体信息资源的安全类别，另一个是访问控制系统实现的安全级别。

根据不同的安全强度要求，美国国防部可信计算机系统评估系统TCSEC共定义了四组七个等级可信计算机系统准则，即D、C1、C2、B1、B2、B3、A。

TCSEC 可信计算机标准评估准则

级别	名称	主要特征
A1	验证设计级	形式化安全验证模型，形式化隐蔽通道分析
B3	安全区域保护级	安全内核，高抗渗透能力
B2	结构化保护级	形式化安全模型，隐蔽通道约束，面向安全的体系结构，较好的抗渗透能力
B1	标签安全保护级	强制访问控制，安全标识，删去安全相关的缺陷
C2	受控存取保护级	受控自主访问控制，增加审核机制，记录安全性事件
C1	自主安全保护级	自由访问控制
D	最小保护级	最低等级

访问控制的主要功能

1. 保证合法用户访问受保护的网络资源，
2. 防止非法的主体进入受保护的网络资源
3. 防止合法用户对受保护的网络资源进行非授权的访问。

访问控制要素

三个要素：主体、客体和控制策略。

（1）主体。是指提出访问资源具体请求的发起者（可能是用户，也可以是用户启动的进程、服务和设备等）

（2）客体。是指被访问资源的实体。所有可以被操作的信息、资源、对象都可以是客体，可以是信息、文件、记录等集合体，也可以是网络上硬件设施、无线通信中的终端，甚至可以包含另外一个客体。

（3）控制策略。是主体对客体的相关访问规则集合，即属性集合。访问策略体现了一种授权行为，也是客体对主体某些操作行为的默认。

身份认证

身份认证是指通过一定的手段，完成对用户身份的确认。身份认证的方法有很多，基本上可分为：

1. 基于共享密钥的身份认证

基于共享密钥的身份认证是指服务器端和用户共同拥有一个或一组密码。当用户需要进行身份认证时，用户通过输入或通过保管有密码的设备提交密码。服务器在收到用户提交的密码后，检查用户所提交的密码是否与服务器端保存的密码一致。

2. 基于生物学特征的身份认证

基于生物学特征的身份认证是指基于每个人身体上独一无二的特征，如指纹、手印、声音、虹膜等。这种识别技术只用于控制访问极为重要的场合，用于极为仔细地识别人员。

3. 基于公开密钥加密算法

基于公开密钥加密算法的身份验证是指通信中的双方分别持有公开密钥和私有密钥，由其中的一方采用私有密钥对特定数据进行加密，而对方采用公开密钥对数据进行解密。

系统口令安全

口令是访问控制的简单而有效的方法，只要口令保持机密，非授权用户就无法使用该账号。系统口令的维护不只是管理员一个人的事情，**系统管理员和普通用户都有义务保护好口令**。

选择安全的口令

01 选择长的口令，口令越长，黑客破解的成功率就越低；

02 口令最好包括英文字母和数字的组合；

03 不要使用英语单词作为口令；

04 若用户访问多个系统，则不要使用相同的口令；

05 不要使用自己名字、家人和宠物的名字作口令；

06 不要选择不易记忆的口令。

口令管理

用户应该定期改变自己的口令。例如一个月换一次。如果口令泄露或被盗取就会引起安全问题，经常更换口令可以帮助减少损失。比如两个星期更换一次口令总比一直保留原有口令损失要小。

管理员可以为口令设定生命期。这样当口令生命期到后，系统就会强制用户更改系统密码。

口令维护

口令的维护需注意以下几点：

01

不要将口令告诉别人，也不要几个人共享一个口令，不要把它记在本子上或计算机周围。

02

不要用系统指定的口令。如root、demo和test等。

03

如果账户长期不用，应将其暂停。

04

限制用户的登录时间。例如，只有在工作时间，用户才能登录。

05

限制登录次数。为了防止对账户多次尝试口令以闯入系统，系统可以限制登录的次数，这样可以防止有人不断地尝试使用不同的口令和登录名。

选择性访问控制

选择性访问控制（Discretionary Access Control，DAC）是基于主体或主体所在组的身份的，如果一个主体具有某种访问权，则它可以直接或间接地把这种控制权传递给别的主体（除非这种授权是被强制型控制所禁止的）。

选择性访问控制 v.s. 强制性访问控制

对比维度	DAC（选择性访问控制）	MAC（强制性访问控制）
控制权主体	资源的所有者（Owner）	系统安全策略或管理员
权限决定依据	用户身份 + ACL	安全标签（label）+ 策略规则
用户能否更改权限	可以	不可以（必须遵守系统策略）
灵活性	高	低（但更安全）
安全级别	较弱（容易被误操作或恶意修改）	较强（防止越级访问、信息泄漏）
典型应用	Unix 文件权限、NTFS ACL	SELinux、AppArmor、Trusted BSD、Windows MIC
适用场景	一般商用或多用户系统	安全要求极高的系统（如军队、政府、金融）

强制性访问控制从B1安全级别开始出现，低于B1的安全级别中无此要求。

第3章 数据安全技术

3.1　数据完整性简介

数据完整性是指数据的精确性和可靠性。它是应防止数据库中存在不符合语义规定的数据和防止因错误信息的输入输出造成无效操作或错误信息而提出的，包括：

（1）**正确性**。数据在输入时要保证其输入值与定义这个表相应的域的类型一致。

（2）**有效性**。在保证数据有效的前提下，系统还要约束数据的有效性。

（3）**一致性**。当不同的用户使用数据库时，应该保证他们取出的数据必须一致。

数据完整性的四种类型

数据完整性分为4类：

- 实体完整性（Entity Integrity）
- 域完整性（Domain Integrity）
- 参照完整性（Referential Integrity）
- 用户定义的完整性（User-defined Integrity）

数据完整性

（1）实体完整性

- 实体完整性规定表的每一行在表中是唯一的实体，不能出现重复的行。
- 表中定义的UNIQUE PRIMARY KEY约束就是实体完整性的体现。

（2）域完整性

- 域完整性是指数据库表中的列必须满足某种特定的数据类型或约束。其中约束又包括取值范围、精度等规定。
- 表中的CHECK、FOREIGN KEY、DEFAULT、NOT NULL约束都属于域完整性的范畴。

数据完整性

（3）参照完整性

参照完整性是指两个表的主关键字和外关键字的数据应对应一致。它确保了有主关键字的表中对应其他表的外关键字的行存在，既保证了表之间的数据的一致性，又防止了数据丢失或无意义的数据在数据库中扩散。

（4）用户定义完整性

用户定义的完整性是针对某个特定关系数据库的约束条件，它反映某一具体应用所涉及的数据必须满足的语义要求。

容错

为了提高网络系统的高可靠性，人们总结了两种方法。

- 避错：试图构造一个不包含故障的“完美”的系统，其手段是采用正确的设计和质量控制尽量避免把故障引进系统。
- 容错：所谓容错是指当系统出现某些指定的硬件或软件的错误时，系统仍能执行规定的一组程序。

容错系统的需求场景

容错系统的场景可分成 5 种不同的类型：

（1）高可用度系统。可用度是指系统在某时刻可运行的概率。随时可用、可兼容多种程序

（2）长寿命系统。长寿命系统在其生命期中（通常在5年以上）不用进行人工维修，常用于宇宙飞船、卫星等控制系统中。长寿命系统的特点是必须具有高度的冗余，有足够的备件，能够经受得住多次出现的故障的冲击，冗余管理可以自动或遥控进行。

容错系统的需求场景

（3）**延迟维修系统。**能够在进行周期性维修前暂时容忍已经发生的故障从而保证系统的正常运行。这类容错系统的特点是现场维修非常困难或代价高。例如，在飞机、轮船、坦克的运行中难以维修，通常都要在返回基地后才能进行维修。车载、机载和舰载计算机系统都采用延迟维修容错计算机系统。

（4）**高性能计算系统。**高性能计算系统对瞬时故障和永久故障均很敏感，要提高系统性能，增加平均无故障时间和对瞬时故障的自动恢复能力，必须进行容错设计。

（5）**关键任务计算系统。**在关键任务计算系统中，出现的错误可能危及人的生命或造成重大的经济损失。在这类系统中，不仅要求处理方法正确无误，还要求从故障中恢复的时间最短，不致影响到应用系统的执行。

数据库安全的威胁

目前，对数据库构成的威胁主要有篡改、损坏和窃取。

1. **篡改：** 指未经授权对数据库中的数据进行修改，使其失去原来的真实性。篡改在造成影响之前很难发现它。篡改是人为的，原因主要有如下几种：个人利益驱动、隐藏证据、恶作剧、无知。

2. **损坏：** 表现形式：表和整个数据库部分或全部被删除、移走或破坏。产生损坏的原因主要有破坏、恶作剧和病毒。

3. **窃取：** 针对敏感数据，窃取的手法除了将数据复制到U盘之类的可移动的介质上外，也可以把数据打印后取走。

导致窃取的原因有工商业间谍的窃取、不满和要离开员工的窃取，还有就是被窃的数据可能比想象中更有价值。

3.7　数据库备份与恢复

数据库系统对付故障有两种办法：一种办法是尽可能提高系统的可靠性；另一种办法是在系统发出故障后，把数据库恢复至原来的状态。

数据库系统如果发生故障可能会导致数据的丢失，要恢复丢失的数据，必须对数据库系统进行备份。

第4章 恶意代码及网络防病毒技术

第4章 恶意代码及网络防病毒技术

恶意代码是指能够破坏计算机系统功能、未经用户许可非法使用计算机系统，影响计算机系统、网络正常运行，窃取用户信息的计算机程序或代码。未经授权执行有害操作

病毒、木马、蠕虫的比较

类别	是否自我复制	是否依附宿主	传播方式	主要危害	举例
病毒	是	是	文件传播、拷贝、U盘	文件损坏、系统异常	• CIH（“陈盈豪病毒”） • 宏病毒（感染 Word、Excel 文档的宏脚本）
木马	否	否	用户误装、钓鱼、恶意网站	窃密、远控、开后门	• 远控木马（Remote Access Trojan, RAT）、游戏外挂木马、 • 银行木马（窃取网银账号密码）
蠕虫	是	否	网络漏洞、自传播	网络瘫痪、系统崩溃	• “震网（Stuxnet）” • “冲击波（Blaster）” • “熊猫烧香”

4.1　计算机病毒

4.1　计算机病毒

计算机病毒指编制者在计算机程序中插入的破坏计算机功能或者破坏数据，影响计算机正常使用并且能够自我复制的一组计算机指令或程序代码。

计算机病毒的工作方式

计算机病毒的工作方式与病毒所能表现出来的特性或功能是紧密相关的。病毒能表现出的特性或功能有：

1. 感染
2. 变异
3. 触发
4. 破坏
5. 高级功能（如隐身和多态）

计算机病毒的特点

刻意编写人为破坏

不是偶然自发产生的，而是人为编写的有意破坏、严谨精巧的程序段，它是严格组织的程序代码，与所在环境相互适应并紧密配合。

01

夺取系统控制权

系统每执行一次操作，病毒就有机会执行它预先设计的操作，完成病毒代码的传播或进行破坏活动。

02

潜伏性

大部分病毒不会马上发作，它可长期隐藏在系统中，只有在满足其特定条件后才启动。

03

自我复制能力

也称“再生”或“传染”。在一定条件下，病毒通过某种渠道从一个文件或一台计算机传染到另外没有被感染的文件或计算机。

04

隐蔽性

受到传染后，一般计算机系统仍然能够运行，被感染的程序也能执行，用户不会感到明显的异常，

05

不可预见性

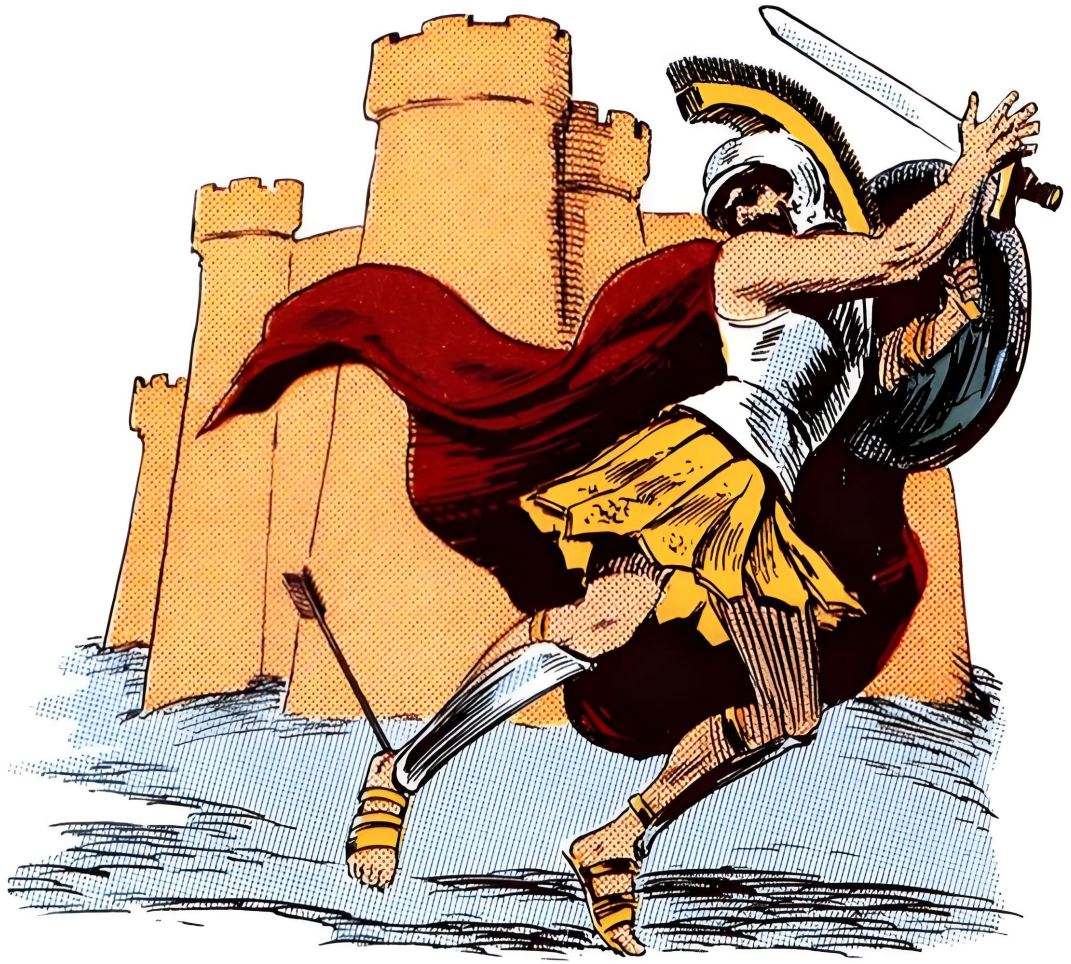
不同种类病毒的代码千差万别，病毒的制作技术也在不断地提高，对未来病毒的预测更加困难，这就要求人们不断提高对病毒的认识，增强防范意识。

06

4.2 特洛伊木马

4.3 特洛伊木马





《特洛伊：木马屠城》

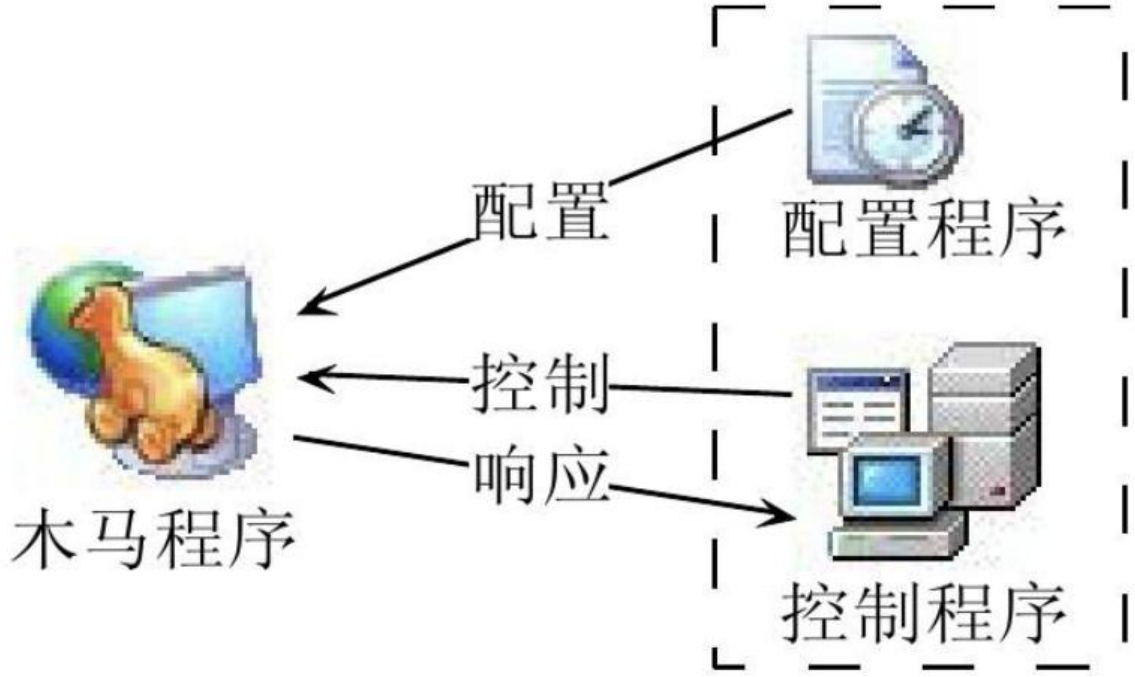
4.3 特洛伊木马

“特洛伊木马”（Trojan Horse）简称“木马”，木马和病毒都是黑客编写的程序，都属于电脑病毒。

“木马”程序是目前比较流行的病毒文件，与一般的病毒不同，它不会自我繁殖，也并不“刻意”地去感染其他文件，它通过将自身伪装吸引用户下载执行，向施种木马者提供打开被种者电脑的门户，使施种者可以任意毁坏、窃取被种者的文件，甚至远程操控被种者的电脑。

木马的工作原理

木马程序的服务器端程序是需要植入到目标主机的部分。客户端程序是用来控制目标主机的部分，安装在控制者的计算机上，它的作用是连接木马服务器端程序，监视或控制远程计算机。



木马服务器端（被控制端）
（目标主机）

木马客户端（控制端）
（攻击者主机）

左图为早期典型的木马原理

后来，为绕过防火墙，新型木马演变出“反向连接”的机制，即木马不再等待连接，而是主动连接攻击者的客户端。

但是，由于命名习惯，木马程序仍称为“服务器端”

木马的检测

程序运行的两个必要条件就是：进程（模块，线程）和加载（自启动和触发）。

从这两个大的方向入手，理论上可以找出所有木马。

4.3 蠕虫病毒

4.4 蠕虫病毒

蠕虫是一种可以自我复制的代码，并且通过网络传播，通常无需人为干预就能传播。

蠕虫病毒入侵并完全控制一台计算机之后，就会把这台机器作为宿主，进而扫描并感染其他计算机。这种行为会一直延续下去。蠕虫使用这种递归的方法进行传播，按照指数增长的规律控制越来越多的计算机。

蠕虫病毒的特点

（1）较强的独立性。蠕虫病毒可以不依赖于宿主程序而独立运行。

（2）利用漏洞主动攻击。由于不受宿主程序的限制，蠕虫病毒可以利用操作系统的各种漏洞进行主动攻击。

（3）传播更快更广。比病毒具有更大的传染性，不仅感染本地计算机，还可以通过网络中的共享文件夹、电子邮件、恶意网页以及存在着大量漏洞的服务器感染网络中的所有计算机，传播速度可以达到传统病毒的几百倍。

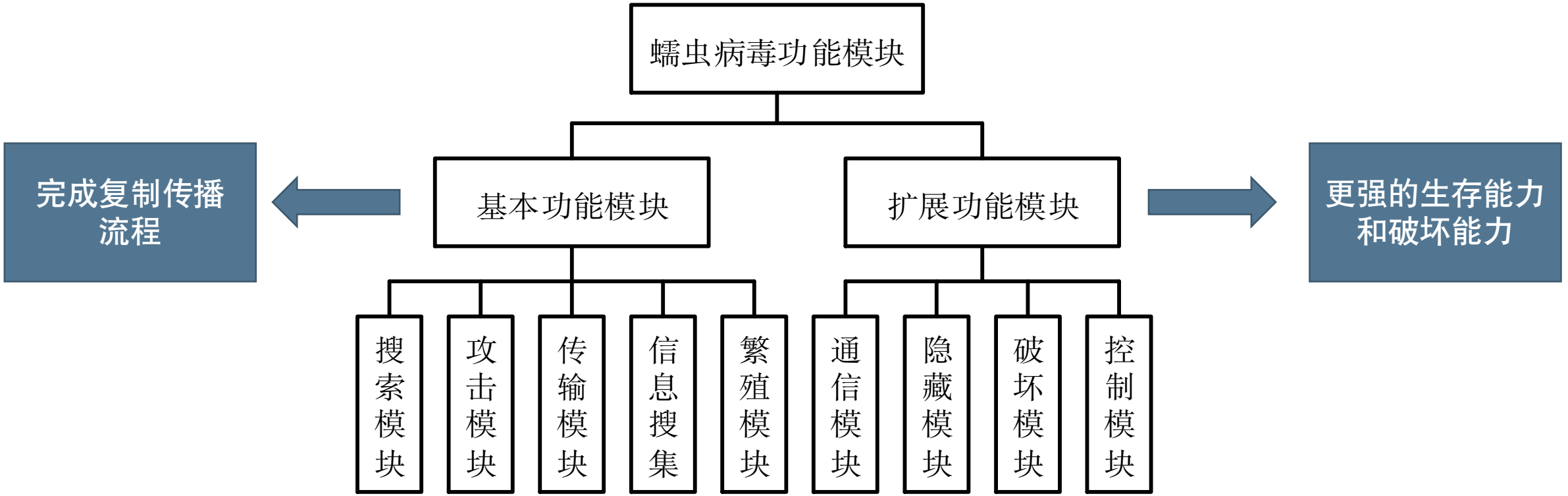
（4）更好的伪装和隐藏方式。通过Base64编码隐藏到邮件的正文中，并通过MIME的漏洞在用户单击时，自动解码到硬盘上并运行。

（5）技术更加先进。利用VBScript、Java、ActiveX等技术隐藏在HTML页面里。当浏览含有病毒代码的网页时，病毒会自动驻留内存并伺机触发。

（6）使追踪变得更困难。当蠕虫病毒感染了大部分系统之后，攻击者便能发动多种其他攻击方式对付一个目标站点，并通过蠕虫网络隐藏攻击者的位置，这样要抓住攻击者会非常困难。

蠕虫病毒的功能结构

蠕虫病毒分解为基本功能模块和扩展功能模块。



蠕虫病毒的功能结构——基本功能

基本功能由5个功能模块构成。

① 搜索模块。寻找下一台要传染的机器；可以采用一系列的搜索算法以提高效率。

② 攻击模块。在被感染的机器上建立传输通道（传染途径）。

③ 传输模块。计算机间的蠕虫程序复制。

④ 信息搜集模块。搜集和建立被传染机器上的信息。

⑤ 繁殖模块。建立自身的多个副本；在同一台机器上提高传染效率、判断避免重复传染。

蠕虫病毒的功能结构——扩展功能

扩展功能由4个功能模块构成。

① 隐藏模块。隐藏蠕虫程序，使简单的检测不能发现。

② 破坏模块。摧毁或破坏被感染的计算机；或在被感染的计算机上留下后门程序等。

③ 通信模块。蠕虫间、蠕虫同黑客之间进行交流，可能是未来蠕虫发展的侧重点。

④ 控制模块。调整蠕虫行为，更新其他功能模块，控制被感染计算机，可能是未来蠕虫发展的侧重点。

网络病毒

	网络病毒（Network Virus）	蠕虫病毒（Worm Virus）
定义	一类通过网络传播的病毒的总称，强调“传播媒介是网络”，但本质仍是**病毒**（依附宿主文件传播）。	一种特殊类型的**自我复制程序**，不依附任何宿主文件即可通过网络主动传播。
是否依附宿主	是	否
传播方式	借助网络共享、邮件附件、文件传输、下载感染等方式。	自动扫描网络漏洞、利用系统服务（如 RPC、SMB、HTTP）主动传播。
自我复制能力	有复制能力，但通常依赖宿主文件或用户操作。	有强自我复制能力，完全自动化传播。
典型示例	CIH、宏病毒通过网络共享传播时属于网络病毒。	“熊猫烧香”、Conficker、“冲击波（Blaster）”、“震荡波（Sasser）”等。

4.5 其他恶意代码

4.5 其他恶意代码

恶意代码又称恶意软件，例如广告软件、间谍软件、恶意共享软件。恶意软件在未明确提示用户或未经用户许可的情况下，在用户计算机或其他终端上安装运行，侵犯用户合法权益的软件。有时也称作流氓软件。

恶意代码具有共同特征是：

- 恶意的目的
- 本身是计算机程序
- 通过执行发生作用

名称	核心定义	传播 / 触发方式	典型危害	防御与检测要点
移动端恶意代码	对移动终端进行攻击，造成移动终端异常的不良程序代码	病毒短信、攻击相邻手机、攻击网关、攻击漏洞、木马型	执行未经授权操作、下载其他恶意软件、窃密	注意来电信息、谨慎进行网络下载、不接收怪异短信、关闭无线连接、关注安全信息
陷门（后门）	绕过正常认证或防护机制，给攻击者保留长期访问的方法（通常隐蔽）	开发者疏忽；或被植入可执行文件、配置、服务或系统账户	持久远控、非授权访问等	文件完整性监控、审计启动项/服务/账号、检测异常监听端口与持久化机制
逻辑炸弹	按特定条件（时间、事件）触发执行破坏行为的恶意代码，跟病毒相比，不具有传染性	触发条件达成时激活（如某日、文件删除、用户登录等）	数据丢失破坏、计算机不能引导、系统瘫痪、物理损坏假象等	代码审查、文件完整性监控、备份策略等
僵尸病毒	被感染的主机（僵尸）被远程控制并集中管理，形成网络（Botnet）	常由木马/蠕虫等植入，受 C&C 或 P2P 控制	DDOS、垃圾邮件、挖矿、进一步攻击跳板	行为检测（大量出站流量）、C&C 域/IP 阻断、端点防护（EDR）、网络分段、及时补丁
复合型病毒	具备变形/多种传播方式的恶意代码：多态通过变换代码以躲避签名检测，复合型融合多种恶意类型	可结合文件感染、引导区感染、网络传播、宏等多渠道	隐蔽性强、持久性高、难以用单一方法清除	行为/启发式检测、沙箱动态分析、基于上下文的检测、端点与网络联动防御

4.6 病毒的预防、检测和清除

病毒的预防

防范措施主要有以下几点：

（1）操作系统层面：及时更新操作系统的补丁，修补操作系统本身存在的安全漏洞，禁用不需要的功能、账号、端口等。

（2）应用系统层面：通过安装软件补丁、优化软件设计，提高应用软件的安全性。

（3）安装安全防护软件：通过安装防火墙、杀毒软件、入侵检测等安全防护软件，提高计算机的防护能力。

（4）提防问题网站：目前黑客等不法分子会把病毒、木马挂在网页上，只要浏览网页，就有可能会被植入木马或感染病毒。因此在浏览网页时需要加以提防，不要登录不正规的网站。

病毒的预防

（5）**提防利用电子邮件传播病毒：** 收到陌生可疑邮件时尽量不要打开，特别是对带有附件的电子邮件要格外小心，打开前对邮件进行杀毒。

（6）**及时查杀病毒：** 对于来路不明的光盘、软盘、U盘等介质，使用前进行查杀；对于从网络上下载的文件也要先查杀病毒；计算机需要安装杀毒软件要及时更新病毒库。

（7）**预防病毒爆发：** 经常关注一些网站发布的病毒报告，及时了解病毒爆发情况，提前做好预防。

（8）**定期备份：** 对于重要的文件、数据要定期备份，以免丢失。

第5章 数据加密与认证技术

数据加密与认证技术

第5章
主要内容

- 密码学概述
- 古典密码
- 对称密钥密码
- 非对称密钥（公钥）密码

5.1 密码学概述

密码与口令

password、passcode、passphrase——口令

- 登录、验证

cryptography——密码学

- 数据加密、安全认证

密码学的发展阶段

阶段	处理内容	加密方式	加密技术
古典密码	字符	手工、机械	移位法、替换法
现代密码	二进制	计算机	对称加密、非对称加密

密码学的两大分支

- 密码编码学
- 密码分析学

密码系统的组成结构——术语

术语	英文	含义
明文 P/M	Plaintext	需要加密的原始消息
密文 C	Ciphertext	明文经过变换，形成密文
密码算法	Algorithm	加密变换与解密变换的具体规则
加密 E	Encryption	对明文实施的一系列变换过程
解密 D	Decryption	对密文实施的一系列逆变换过程，将密文恢复成明文
密钥 K	Key	加密和解密的参数

密钥Key

密方法被破解了怎么办？

—— 设计新的加密方法 ×　　加入密钥，替换密钥 √

密钥能被猜出来吗？——单向陷门函数

$E(K, M) = C$

$(C_0, M_0), (C_1, M_1), ..., (C_{i-1}, M_{i-1})$

加密密钥 Ke (Key of Encryption) / PK (Public Key)

解密密钥 Kd (Key of Decryption) / SK (Private/Secret Key)

破解时间计算

密钥大小(位)	密钥个数	每微秒执行一次解密所需要的时间	每微秒执行 100 万次解密所需要的时间
32	$2^{32}=4.3\times10^{9}$	$2^{31}\,\mu s=35.8min$	2.15ms
56	$2^{56}=7.2\times10^{16}$	$2^{55}\,\mu s=1142$ 年	10.01 小时
128	$2^{128}=3.4\times10^{38}$	$2^{127}\,\mu s=5.4\times10^{24}$ 年	5.4×10^{18} 年
168	$2^{168}=3.7\times10^{50}$	$2^{167}\,\mu s=5.9\times10^{30}$ 年	5.9×10^{30} 年
26 个字符的排列组合	$26!=4\times10^{26}$	$2\times10^{26}\,\mu s=6.4\times10^{12}$ 年	6.4×10^{6} 年

对称密码和非对称密码

对称密码：

- 加密：E(Ke, M) → C
- 解密：D(Kd, C) → M
- 在对称密码中，Ke和Kd通常一样，或可相互得到，通常认为是一个密钥

非对称密码：

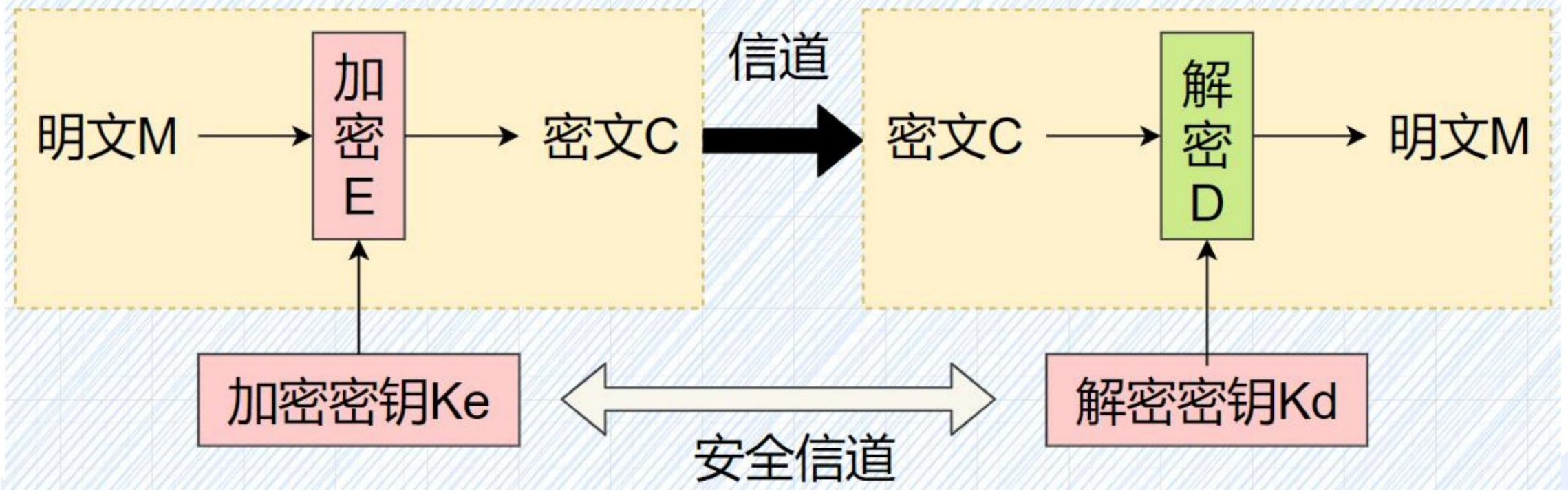
假设通信双方为Alice和Bob，攻击者是Eve。Alice拥有公私钥对（PK_A, SK_A），Bob拥有公私钥对（PK_B，SK_B）。

- Alice→Bob 加密：E(PK_B, M) → C
- Bob　　解密：D(SK_B, C) → M
- Alice→Bob 签名：Sign(SK_A, M) → signature
- Bob　　验证：Verify(PK_A, signature) → true/false

密码系统的工作流程

加密过程：$C=E_{Ke}(M)$

解密过程：$M=D_{Kd}(C)$



密码系统的安全性——柯克霍夫（Kerckhoff）原则

密码的安全性取决于密钥，而不是密码算法，即密码算法要公开。

——1883年 荷兰密码学家Auguste Kerckhoffs

论文：《军用密码学》

密码系统的安全定义

评估方法	描述	类型
无条件安全	在时间、算力无限的情况下，无法破译	极限状态安全
计算安全	攻击者不具备破解算法需要的时间、算力	强力破解安全
可证明安全	因为是经研究的数学难题，所以很难破解	理论保证安全

密码实践中的安全标准

1、破译需要的资源（时间、算力）耗费巨大

2、破译的时间超过被加密信息有用的生命周期

3、破译的费用超过信息本身的价值

满足一条，即是安全的

密码系统的基本攻击方法

攻击方法	描述	防御方法
穷举攻击	把所有可能的密钥都尝试一遍	增加密钥长度
统计分析	根据明文和密文的统计规律进行破译	扰乱统计规律
数学分析攻击	基于加密算法的数学基础和密码学特征，用数学求解的方法破译	设计足够复杂的加密函数

攻击模式

1、唯密文攻击（Ciphertext Only Attack，COA）

2、已知明文攻击（Known Plaintext Attack，KPA）

3、选择明文攻击（Chosen Plaintext Attack，CPA）

4、选择密文攻击（Chosen Ciphertext Attack，CCA）

密码攻击模式（总结）

攻击难度： 选择密文攻击（CCA）< 选择明文攻击（CPA）< 已知明文攻击（KPA）< 唯密文攻击 （COA）

一般来说，当密码系统只有承受住选择明文攻击(CPA)和选择密文攻击(CCA)，才能算是安全的（即已知信息更多的情况下，依然无法破解）。

密码法律法规

2019年10月26日 《中华人民共和国密码法》
https://www.oscca.gov.cn/sca/xxgk/2023-06/04/content_1057225.shtml

- 三种密码：核心密码、普通密码、商用密码
- 密码谁来管、怎么管？国家密码管理局（https://www.oscca.gov.cn/）

5.2 古典密码

古典密码

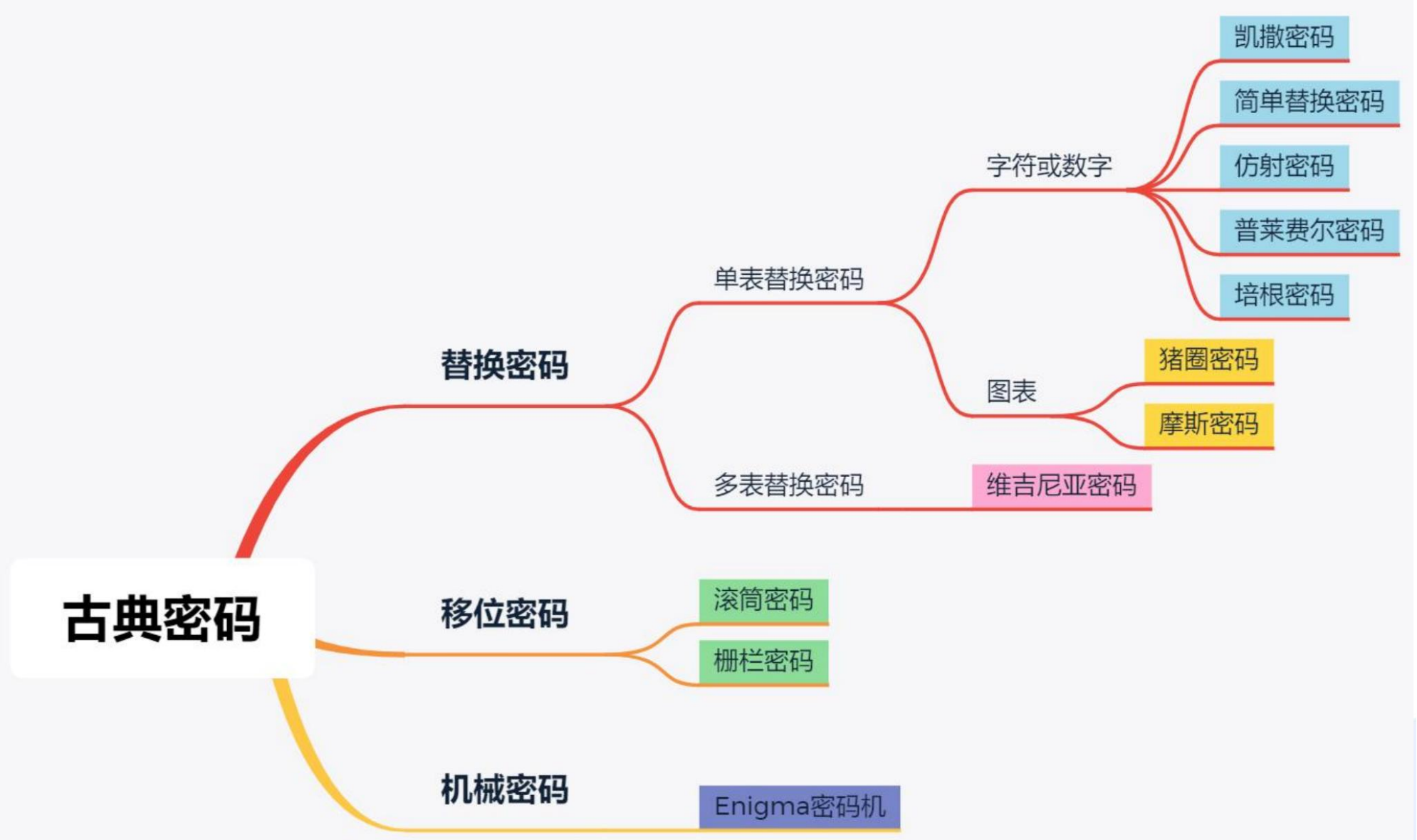
- 替换密码（Substitution Cipher）(代换)
- 移位密码（Permutation Cipher）（置换）
- 机械密码

没有系统性的理论
没有人专门研究
1949年香农《保密通信的信息理论》

CTF解密工具：

http://www.hiencode.com/

古典密码的分类


古典密码
替换密码
单表替换密码
字符或数字
凯撒密码
简单替换密码
仿射密码
普莱费尔密码
培根密码
图表
猪圈密码
摩斯密码
多表替换密码
维吉尼亚密码
移位密码
滚筒密码
栅栏密码
机械密码
Enigma密码机

单表替换——凯撒密码


A B C D E F G H I J K L M N O P Q R S T U V W X Y Z
A Z Y X W V U T S R Q P O N M L K J I H G F E D C B

凯撒密码Caesar Cipher

加密公式:

密文 = （明文 + 偏移数）Mod 26

解密公式:

明文 = （密文 - 偏移数） Mod 26

模运算：

26 * 商 + 模结果 = 被除数

26 * 商 + 模结果 = -45

26 * (商+2) + 模结果 = -45 + (26*2)

单表替换——培根密码Baconian Cipher

Knowledge is Power - Francis Bacon

第一种方式：

A aaaaa B aaaab C aaaba D aaabb E aabaa F aabab G aabba H aabbb I abaaa J abaab

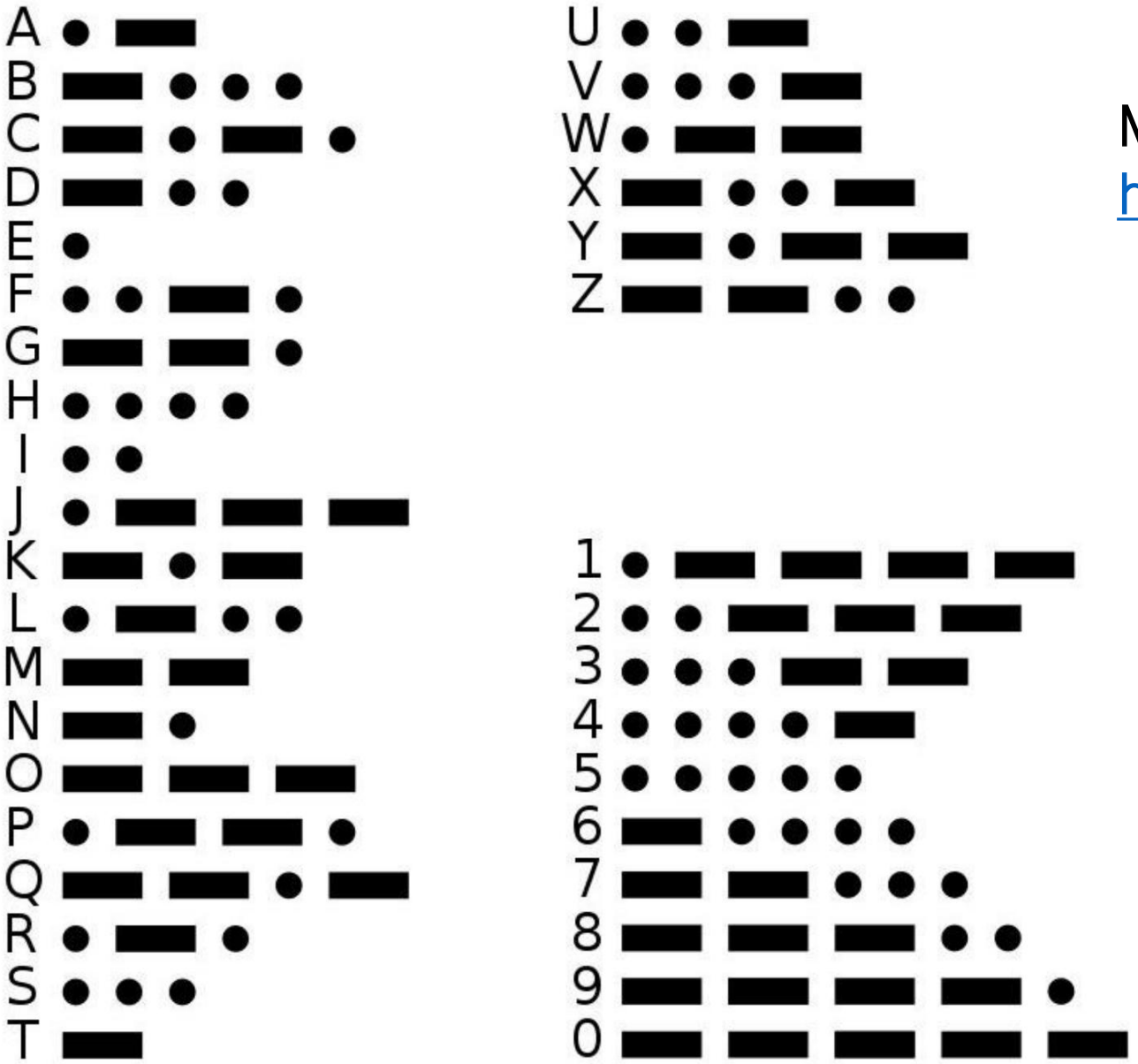
K ababa L ababb M abbaa N abbab O abbba P abbbb Q baaaa R baaab S baaba T baabb

U babaa V babab W babba X babbb Y bbaaa Z bbaab

第二种方式

a AAAAA	g AABBA	n ABBAA	t BAABA
b AAAAB	h AABBB	o ABBAB	u-v BAABB
c AAABA	i-j ABAAA	p ABBBA	w BABAA
d AAABB	k ABAAB	q ABBBB	x BABAB
e AABAA	l ABABA	r BAAAA	y BABBA
f AABAB	m ABABB	s BAAAB	z BABBB

莫尔斯电码（莫斯密码）



Morse Code转换器

https://morsecodetranslator.com/

多表替换——维吉尼亚密码Vigenère Cipher

明文：nicetomeetyoutoo
密钥：secret

n	i	c	e	t	o	m	e	e	t	y	o	u	t	o	o
s	e	c	r	e	t	s	e	c	r	e	t	s	e	c	r

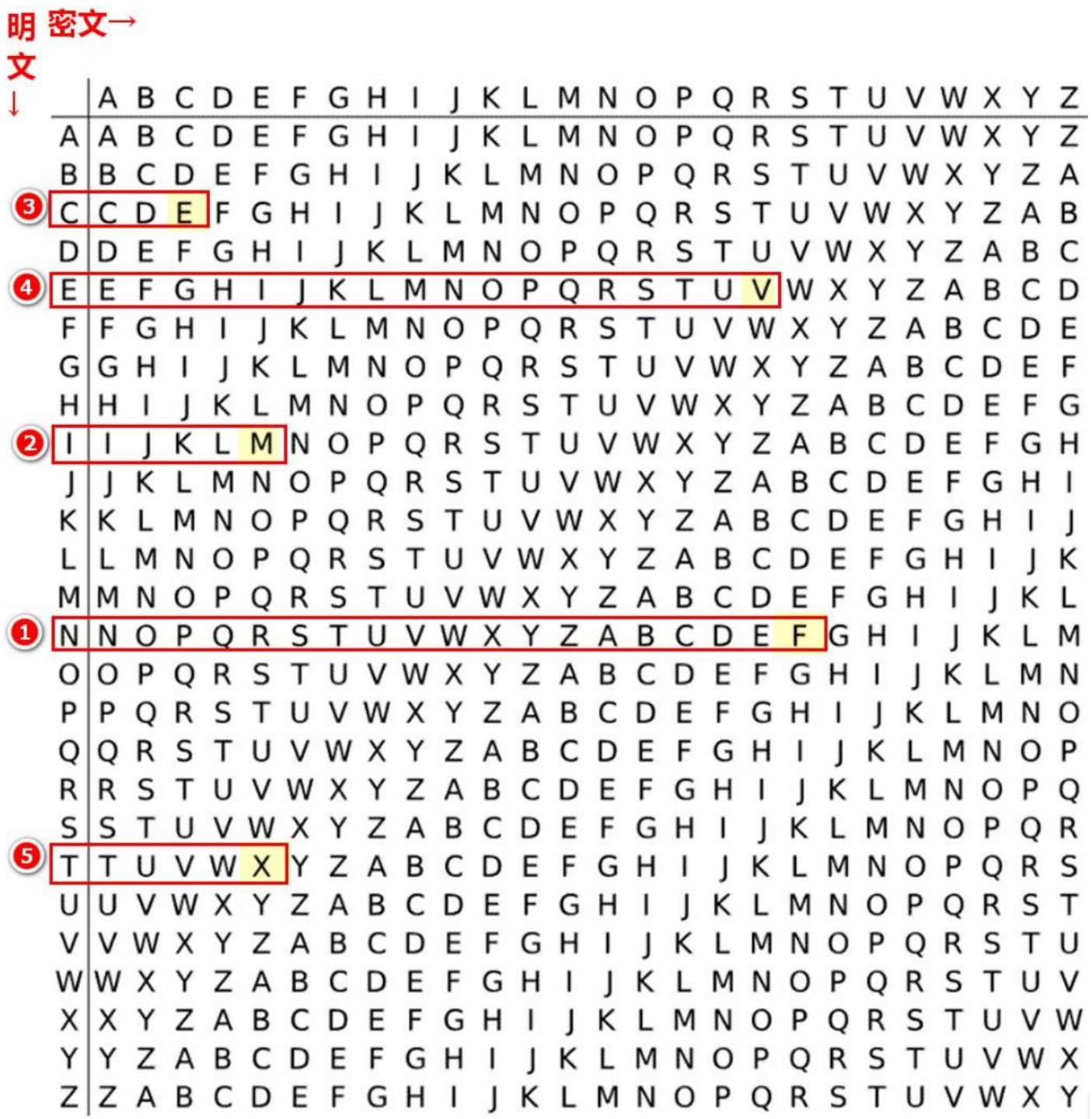
多表替换——维吉尼亚密码Vigen è re Cipher

明文从上往下读
密文从左往右读

n	i	c	e	t	o	m	e
s	e	c	r	e	t	s	e

e	t	y	o	u	t	o	o
c	r	e	t	s	e	c	r

	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
A	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
B	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A
C	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B
D	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C
E	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D
F	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E
G	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F
H	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G
I	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H
J	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I
K	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J
L	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K
M	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L
N	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M
O	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N
P	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O
Q	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P
R	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q
S	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R
T	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S
U	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T
V	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U
W	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V
X	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W
Y	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X
Z	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y


明文↓
密文→
A B C D E F G H I J K L M N O P Q R S T U V W X Y Z
A A B C D E F G H I J K L M N O P Q R S T U V W X Y Z
B B C D E F G H I J K L M N O P Q R S T U V W X Y Z A
C C D E F G H I J K L M N O P Q R S T U V W X Y Z A B
D D E F G H I J K L M N O P Q R S T U V W X Y Z A B C
E E F G H I J K L M N O P Q R S T U V W X Y Z A B C D
F F G H I J K L M N O P Q R S T U V W X Y Z A B C D E
G G H I J K L M N O P Q R S T U V W X Y Z A B C D E F
H H I J K L M N O P Q R S T U V W X Y Z A B C D E F G
I I J K L M N O P Q R S T U V W X Y Z A B C D E F G H
J J K L M N O P Q R S T U V W X Y Z A B C D E F G H I
K K L M N O P Q R S T U V W X Y Z A B C D E F G H I J
L L M N O P Q R S T U V W X Y Z A B C D E F G H I J K
M M N O P Q R S T U V W X Y Z A B C D E F G H I J K L
N N O P Q R S T U V W X Y Z A B C D E F G H I J K L M
O O P Q R S T U V W X Y Z A B C D E F G H I J K L M N
P P Q R S T U V W X Y Z A B C D E F G H I J K L M N O
Q Q R S T U V W X Y Z A B C D E F G H I J K L M N O P
R R S T U V W X Y Z A B C D E F G H I J K L M N O P Q
S S T U V W X Y Z A B C D E F G H I J K L M N O P Q R
T T U V W X Y Z A B C D E F G H I J K L M N O P Q R S
U U V W X Y Z A B C D E F G H I J K L M N O P Q R S T
V V W X Y Z A B C D E F G H I J K L M N O P Q R S T U
W W X Y Z A B C D E F G H I J K L M N O P Q R S T U V
X X Y Z A B C D E F G H I J K L M N O P Q R S T U V W
Y Y Z A B C D E F G H I J K L M N O P Q R S T U V W X
Z Z A B C D E F G H I J K L M N O P Q R S T U V W X Y
3
4
2
1
5

移位密码——滚筒密码



移位密码——栅栏密码

明文：stay hungry stay foolish

s	a		u	g	y	s	a		o	l	s
t	y	h	n	r		t	y	f	o	i	h

密文（2栏）：sa ugysa olstyhnr tyfoih

s		g	s		l
t	h	r	t	f	i
a	u	y	a	o	s
y	n		y	o	h

密文（4栏）：s gs lthrtfiauyaosyn yoh

栅栏密码破解

破解思路：依次尝试所有栏数

古典密码总结

1、所有古典密码都已不安全

2、密钥空间应该尽量大

3、密文应该扰乱统计规律

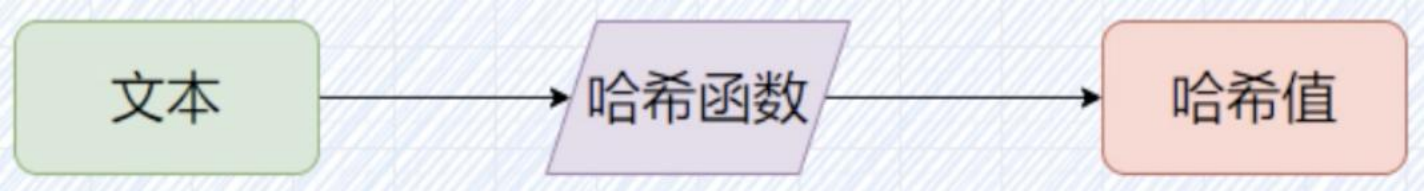
4、效率和安全是矛盾的

5.3 对称密码体制

摘要函数/哈希函数/散列函数/杂凑函数

摘要函数是一种防止信息篡改的方法。

$$Digest=Hash(M)$$



- M可以是任意大小的消息
- 输出Digest（称为摘要、哈希值、散列值、杂凑值）是固定长度
- 不需要密钥
- 计算是单向的，不需要解密
- 不是压缩算法，无法解压缩
- 可用于数据完整性校验、文件校验、数字签名、简单的密码存储等

安全Hash函数

安全的摘要函数应具备以下特性：

- 唯一性：对于给定输入，输出的哈希值是固定的。
- 单向性：由M计算Digest是简单的，由Digest推出M是困难的。
- 快速性：计算应该是非常快速的。
- 扩散性：即对于输入的改变是敏感的。如果改变输入消息中的任何一点，甚至只有一位，输出的摘要将会发生不可预测的改变，也就是说输入消息的每一位对输出摘要都有影响。
- 抗碰撞性：找到不同的M_1和M_2，使得Hash(M1)=Hash(M2)是困难的。

常见哈希函数的生命周期 https://valerieaurora.org/hash.html

抗碰撞性

1. 是否存在任意M_1和M_2，使得Hash(M1)=Hash(M2)?

存在。因为消息空间>摘要空间。

2. 对于给定的M_1和M_2，Hash(M1)=Hash(M2)的可能性大吗?

不大，因为摘要空间非常大，

2^{128}=340282366920938463463374607431768211456

但是，仍要保证不会由于算法本身的脆弱性而导致容易找到定向的碰撞，即给定M1，可以容易地找到这样的M2

Hash函数的应用

Hash函数包括但不限于以下应用场景：

- 文件校验：检验文件是否被篡改。
  - ✓ https://www.kali.org/get-kali/#kali-live
- 网盘存储：避免重复存储相同的文件。
  - ✓ 计算上传文件的哈希值，相同的文件只存一份
- 消息完整性：发送消息（M，hash(M)），M被篡改导致哈希值变化
- 密码存储：为保护用户隐私，服务器存储密码的哈希值而不是原始值
  - ✓ http://china.cnr.cn/ygxw/201112/t20111227_508980291.shtml
- 计算数字签名：数字签名中的一步

常见的哈希函数（不作考察要求）

算法	类别	输出长度（bit）	是否安全?	用途
国际经典	MD5	128	不安全	校验、指纹
国际经典	SHA-1	160	已被攻破	老系统兼容
国际主流	SHA-256	256	安全	加密、签名、区块链、https
国际主流	SHA-512	512	安全	高安全需求
SHA-3	Keccak 系列	多种	安全	后量子友好、轻量
国密	SM3	256	安全	SM2签名、国密系统
快速哈希	CRC32	32	不安全	数据校验
快速哈希	MurmurHash3	32/128	不安全	分布式负载均衡
快速哈希	CityHash	64/128	不安全	哈希表
新兴	BLAKE3	默认256（可变）	非常强	高性能系统

国密算法（商密SM）

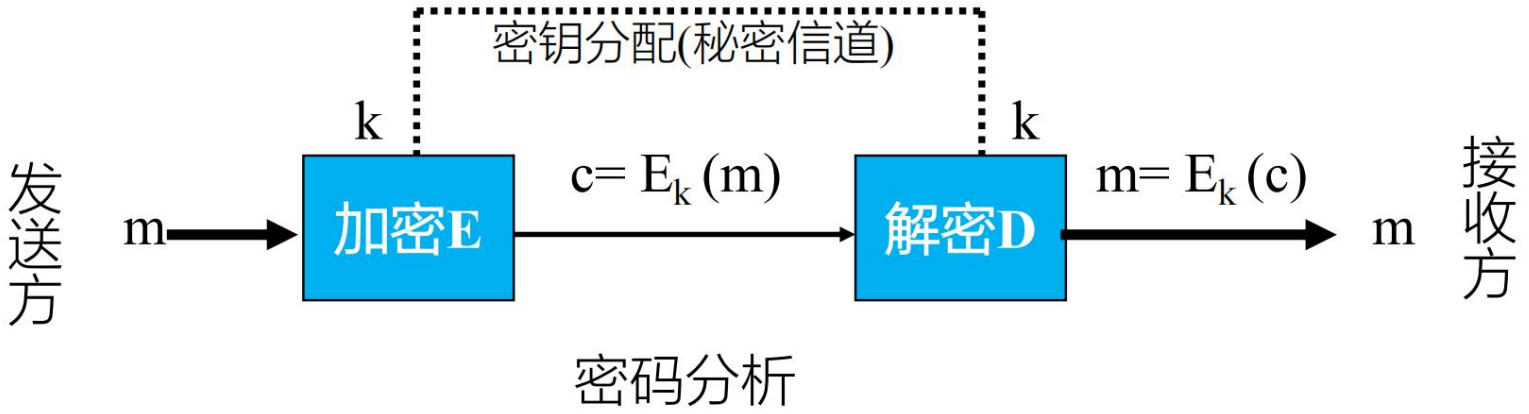
最核心，
三大基础算法

算法	类别	说明	对标国际算法
SM1	对称加密	未公开，仅芯片实现，用于机密级场景	——
SM2	非对称加密	椭圆曲线公钥体系（Elliptic Curve Cryptography），包括密钥交换、加密、签名，加解密速度快于RSA	ECC/RSA
SM3	哈希算法	256位摘要，抗碰撞能力与SHA-256类似	SHA-256
SM4	对称加密	128位分组加密，效率高，硬件实现友好	AES-128
SM7	对称加密	未公开，部分设备内部使用	——
SM9	非对称加密	基于身份的加密体系	IBE

现代密码学

1949年，香农发表的“Communication Theory of Secrecy Systems”为密码系统建立了理论基础，是密码发展史上的**第一次飞跃**，使密码技术由艺术变成了科学

- 将**算法**和**密钥**分开
- 密码算法可以公开，密钥保密
- 密码系统的安全性在于保持密钥的保密性



对称加密

- 加密和解密使用**相同的密钥**：Ke=Kd
- 密钥必须使用**秘密的信道**分配
- 常用对称密钥密码算法
  - DES (Data Encryption Standard)及其各种变体
  - AES (Advanced Encryption Standard)

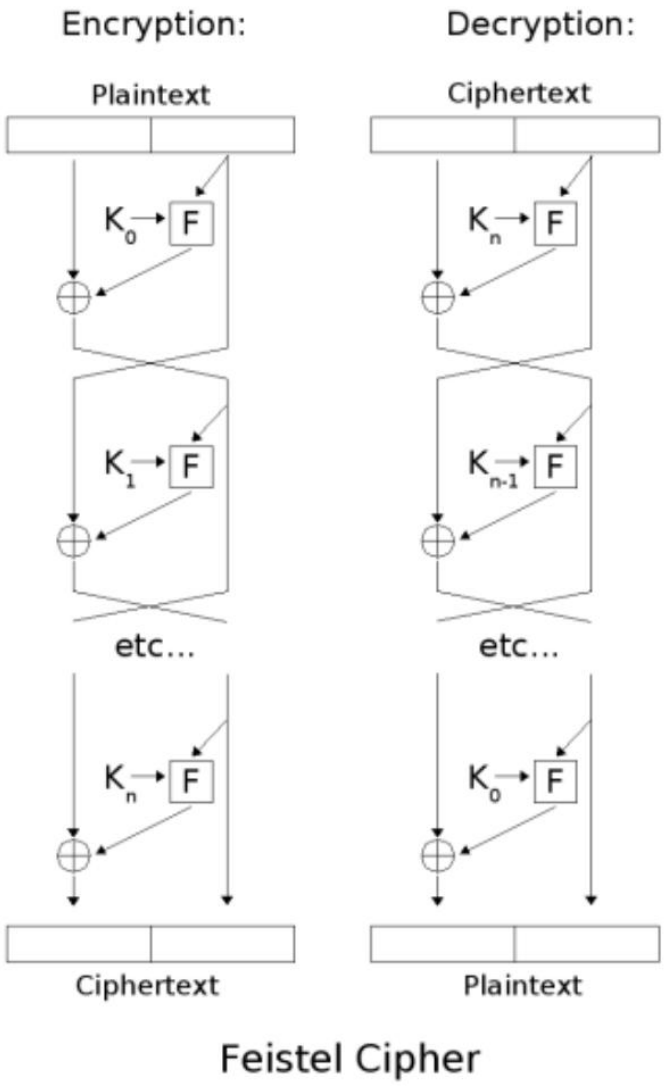


对称加密

常见的对称加密算法有：

- DES：Data Encryption Standard，数据加密标准
- 3-DES：DES的增强版
- AES：高级加密标准
- IDEA：国际数据加密算法，由DES发展而来，类似于3-DES
- BlowFish
- GOST：前苏联设计，为前苏联国家标准局所采用
- PKZIP
- RC5：1994由马萨诸塞技术研究所的Ronald L. Rivest教授发明

Feistel密码结构



Feistel Cipher

- **霍斯特·菲斯特尔（Horst Feistel）**分组密码之父
- 1973年他在 Scientific American 杂志上发表了Cryptography and Computer Privacy一文，提出了Feistel网络
- 多轮迭代结构
- 加密解密对称

Feistel密码结构

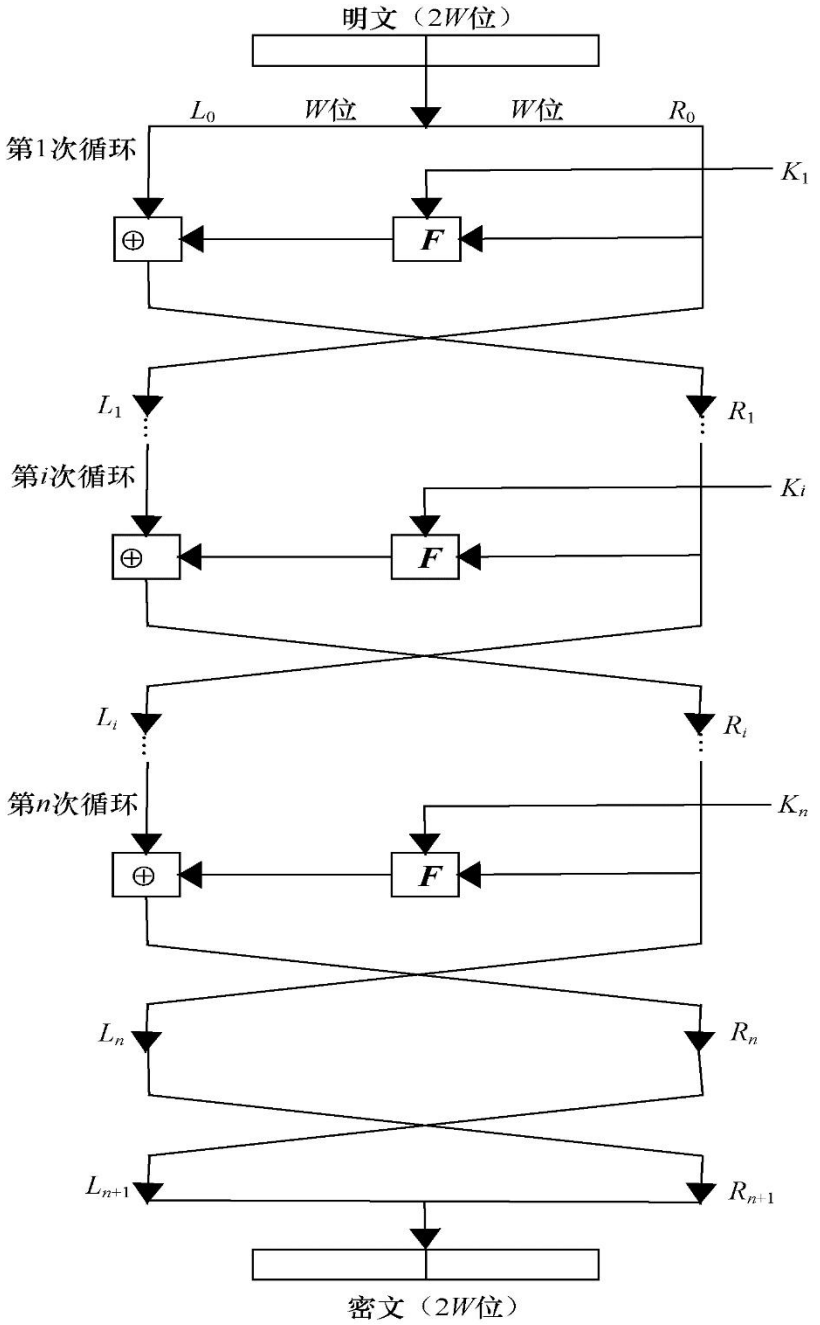
（1）块大小。其他参数相等的情况下，块越大就意味着具有更好的安全性，但是会降低加密/解密的速度。**块大小为64位就是一个很好的折衷**，而且在块密码设计中几乎是通用的。

（2）密钥大小。密钥越大就意味着具有更好的安全性，但是会降低加密/解密的速度。**在现在的加密算法中最通用的密钥长度是128位**。

（3）循环次数。Feistel密码的本质就是单个循环不能提供足够的安全性，而多个循环能够提供更多的安全性。**循环次数的典型大小是16次循环**。

（4）子密钥产生算法。该算法的复杂性越大，那么密码分析就会越困难。

（5）循环函数。循环函数越复杂，就意味着能够更好地抵抗密码分析。



DES

数据加密标准（Data Encryption Standard，DES）是美国国家标准局开始研究除国防部以外的其他部门的计算机系统的数据加密标准，1972年和1974年，美国国家标准局（NBS）先后两次向公众发出了征求加密算法的公告。对加密算法要求要达到以下几点。

① 必须提供高度的安全性。

② 具有相当高的复杂性，使得破译的开销超过可能获得的利益，同时又便于理解和掌握。

③ 安全性应不依赖于算法的保密，其加密的安全性仅以加密密钥的保密为基础。

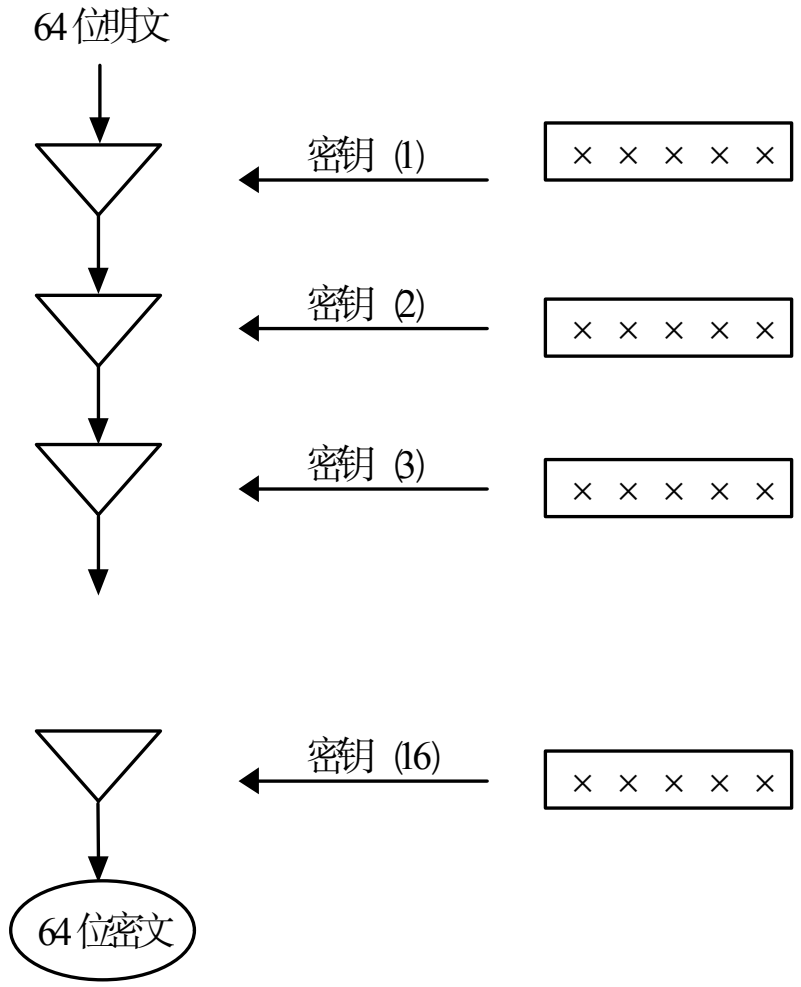
④ 必须适用于不同的用户和不同的场合。通用性高

⑤ 实现算法的电子器件必须很经济、运行有效。适合硬件实现

⑥ 必须能够验证，允许出口。

DES算法

- DES是一个**分组加密**算法
- 分组长度为**64**位
- 密钥的长度为64位，其中有效长度为**56**位
- 共**16**轮，每轮实施相同的组合技术
- 子密钥长度为**48**位，由56位的主密钥生成，每轮使用不同的子密钥



DES算法的过程（考察要求）

首先，要从明文和主密钥得到
用于轮计算的初始值
L0，R0，C0，D0

明文的初始置换（Initial Permutation，IP）

初始置换： 在第一轮运算之前执行，对输入分组实施如下表所示的变换。此表应从左向右、从上向下读。例如，初始置换把明文的原第 58 位换到现在的第 1 位的位置，把原第 50 位换到现在第 2 位的位置，把原第 42 位换到现在第 3 位的位置等。

58	50	42	34	26	18	10	2	60	52	44	36	28	20	12	4
62	54	46	38	30	22	14	6	64	56	48	40	32	24	16	8
57	49	41	33	25	17	9	1	59	51	43	35	27	19	11	3
61	53	45	37	29	21	13	5	63	55	47	39	31	23	15	7

密钥的奇偶校验位

DES的密钥长度为64位，而有效长度为56位，这是由于每8位的最后一位是奇偶校验位。

奇偶校验位的计算方法：若前面数据中**1的个数为奇数，则为奇偶校验位为0；若1的个数为偶数，则为1**。

主密钥的初始置换（PC-1）PC：permuted choice

密钥置换。一开始，由于不考虑每个字节的第 8 位，DES 的密钥由 64 位减至 56 位，如下表所示。每个字节的第 8 位可作为奇偶校验位以确保密钥不发生错误。

57	49	41	33	25	17	9	1	58	50	42	34	26	18
10	2	59	51	43	35	27	19	11	3	60	52	44	36
63	55	47	39	31	23	15	7	62	54	46	38	30	22
14	6	61	53	45	37	29	21	13	5	28	20	12	4

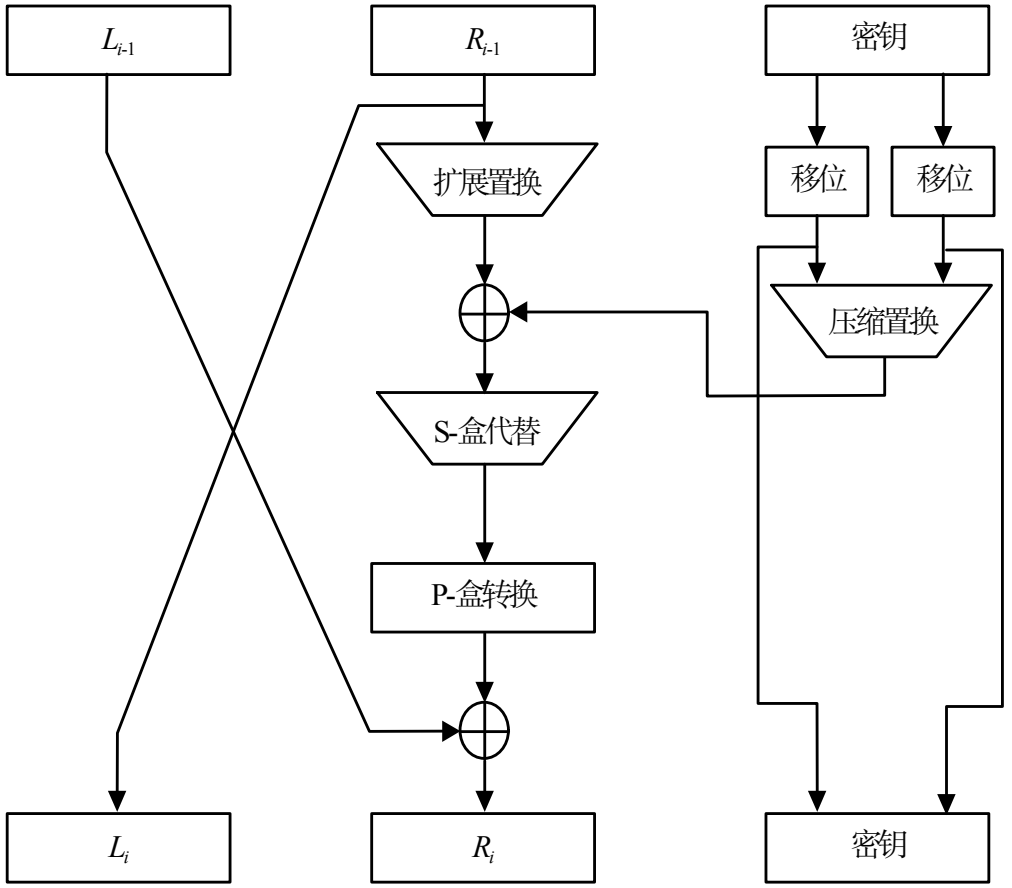
从这里开始，可以进行轮计算了...

DES每轮的过程

$L_i = R_{i-1}$

$R_i = L_{i-1} \oplus F(R_{i-1}, K_i)$

- L_i 和 R_i 是第i轮计算结果的左半部分和右半部分
- K_i 是第 i 轮的48位子密钥
- F是实现代替、置换及密钥异或等运算的函数



一轮 DES

子密钥生成

在 DES 的每一轮中，从 56 位密钥产生出不同的 48 位子密钥（Sub Key），这些子密钥 K_i 由下面的方式确定。

Step 1. 移位： 首先，56 位密钥被分成两部分，每部分 28 位。然后，根据轮数，这两部分分别循环左移 1 位或 2 位。下表给出了每轮移动的位数。

轮	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16
位数	1	1	2	2	2	2	2	2	1	2	2	2	2	2	2	1

子密钥生成——压缩置换（PC-2）

Step 2. 压缩置换：下表定义了压缩置换（也称为置换选择）。例如，处在第 33 位位置的那一位在输出时移到了第 35 位的位置，而处在第 18 位位置的那一位被略去了。

14	17	11	24	1	5	3	28	15	6	21	10
23	19	12	4	26	8	16	7	27	20	13	2
41	52	31	37	47	55	30	40	51	45	33	48
44	49	39	56	34	53	46	42	50	36	29	32

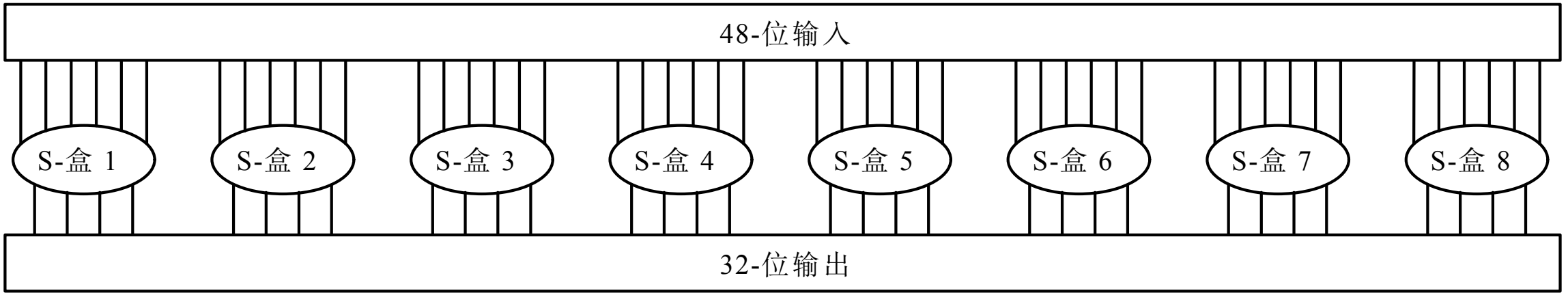
明文分组的扩展置换（E盒置换）E:expansion

这个运算将数据的右半部分 R_i 从 32 位扩展到了 48 位。由于这个运算改变了位的次序，重复了某些位，故被称为扩展置换，也叫作 *E* 盒置换。

32	1	2	3	4	5	4	5	6	7	8	9
8	9	10	11	12	13	12	13	14	15	16	17
16	17	18	19	20	21	20	21	22	23	24	25
24	25	26	27	28	29	28	29	30	31	32	1

S 盒代替　　S：substitution

- 将48位的结果进行S盒代替运算，得到32位的结果。
- 共8个S盒，每个S盒都有6位输入，4位输出。48 位的输入被分为8个6位的分组，每一分组使用一个S盒。



S 盒代替

每个 S 盒是一个 4 行、16 列的表。盒中的每一项都是一个 4 位的数。S 盒的 6 个位输入确定了其对应的输出在哪一行哪一列。表列出了所有 8 个 S 盒。

S-盒1															
14	4	13	1	2	15	11	8	3	10	6	12	5	9	0	7
0	15	7	4	14	2	13	1	10	6	12	11	9	5	3	8
4	1	14	8	13	6	2	11	15	12	9	7	3	10	5	0
15	12	8	2	4	9	1	7	5	11	3	14	10	0	6	13
S-盒2															
15	1	8	14	6	11	3	4	9	7	2	13	12	0	5	10
3	13	4	7	15	2	8	14	12	0	1	10	6	9	11	5
0	14	7	11	10	4	13	1	5	8	12	6	9	3	2	15
13	8	10	1	3	15	4	2	11	6	7	12	0	5	14	9

S-盒3															
10	0	9	14	6	3	15	5	1	13	12	7	11	4	2	8
13	7	0	9	3	4	6	10	2	8	5	14	12	11	5	1
13	6	4	9	8	15	3	0	11	1	2	12	5	10	14	7
1	10	13	0	6	9	8	7	4	15	14	3	11	5	2	12
S-盒4															
7	13	14	3	0	6	9	10	1	2	8	5	11	12	4	15
13	8	11	5	6	5	0	3	4	7	2	12	1	10	14	9
10	6	9	0	12	11	7	13	15	1	3	14	5	2	8	4
3	15	0	6	10	1	13	8	9	4	5	11	12	7	2	14
S-盒5															
2	12	4	1	7	10	11	6	8	5	3	15	13	0	14	9
14	11	2	12	4	7	13	1	5	0	15	10	3	9	8	6
4	2	1	11	10	13	7	8	15	9	12	5	6	3	0	14
1	8	12	7	1	14	2	13	6	15	0	9	10	4	5	3
S-盒6															
12	1	10	15	9	2	6	8	0	13	3	4	14	7	5	11
10	15	4	2	7	12	9	5	6	1	13	14	0	11	3	8
9	14	15	5	2	8	12	3	7	0	4	10	1	13	11	6
4	3	2	12	9	5	15	10	11	14	1	7	6	0	8	13
S-盒7															
4	11	2	14	15	0	8	13	3	12	9	7	5	10	6	1
13	0	11	7	4	9	1	10	14	3	5	12	2	15	8	6
1	4	11	13	12	3	7	14	10	15	6	8	0	5	9	2
6	11	13	8	1	4	10	7	9	5	0	15	14	2	3	12
S-盒8															
13	2	8	4	6	15	11	1	10	9	3	14	5	0	12	7
1	15	13	8	10	3	7	4	12	5	6	11	0	14	9	2
7	11	4	1	9	12	14	2	0	6	10	13	15	3	5	8
2	1	14	7	4	10	8	13	15	12	9	0	3	5	6	11

S 盒代替

- 输入位以一种非常特殊的方式确定了 S 盒中的项。假定将S盒的6位输入标记为b1、b2、b3、b4、b5、b6。则 b1 和 b6 组合构成了一个 2 位的数，从0 到3，它对应着表中的一行。从 b2 到 b5 构成了一个 4 位的数，从 0 到 15，对应着表中的一列。
  - ✓ 例如，假设第 6 个 S 盒的输入为110011。第 1 位和最后一位组合形成了 11，它对应着第 6 个 S 盒的第三行。中间的 4 位组合在一起形成了1001，它对应着同一个 S 盒的第9 列。S-盒6 的第三行第 9 列处的数是 14（注意：行、列的记数均从0开始），则值1110就代替了110011。
- 这个代替过程的结果是 8 个 4 位的分组，它们重新合在一起形成了一个 32 位的分组。这个分组将进行下一步：P 盒置换。

P 盒置换

S盒代替运算后的32位输出依照P盒进行置换。该置换把每输入位映射到输出位，任意一位不能被映射两次，也不能被略去，这个置换叫作直接置换。下表给出了每位移到的位置。例如，第21 位移到了第 4 位处，同时第 4位移到了第 31 位处。

16	7	20	21	29	12	28	17	1	15	23	26	5	18	31	10
2	8	24	14	32	27	3	9	19	13	30	6	22	11	4	25

最后，将P盒置换的结果与最初的 64 位分组的左半部分异或，然后左、右半部分交换，接着开始另一轮。

DES破解：DES不再安全！

时间	攻击速度
1997	Broken for the first time
1998	Broken in 56 hours
1999	Broken in 22 hours and 15 minutes
2021	Capable of broken in 5 minutes

1997年，美国政府发起了新加密算法的征集

1999年，NIST将3-DES指定为过渡的加密标准

三重 DES

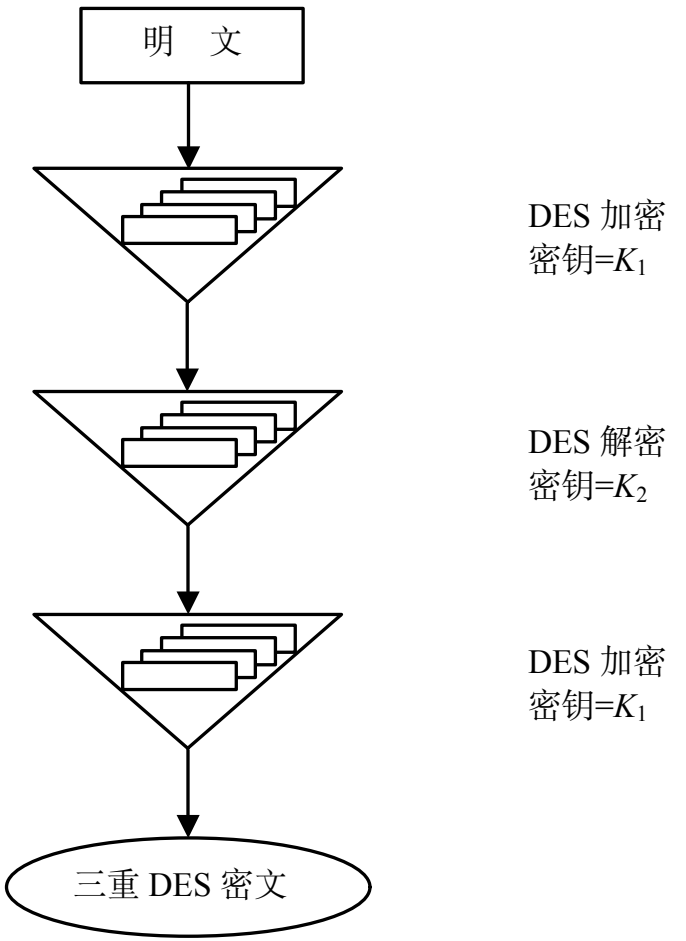
三重 DES 方法需要执行 3 次常规的 DES 加密步骤，但最常用的三重 DES 算法中仅仅用两个 56 位 DES 密钥。设这两个密钥为 K_1 和 K_2，其算法的步骤如下。

① 用密钥 K_1 进行 DES 加密。

② 用步骤①的结果使用密钥K_2进行DES解密。

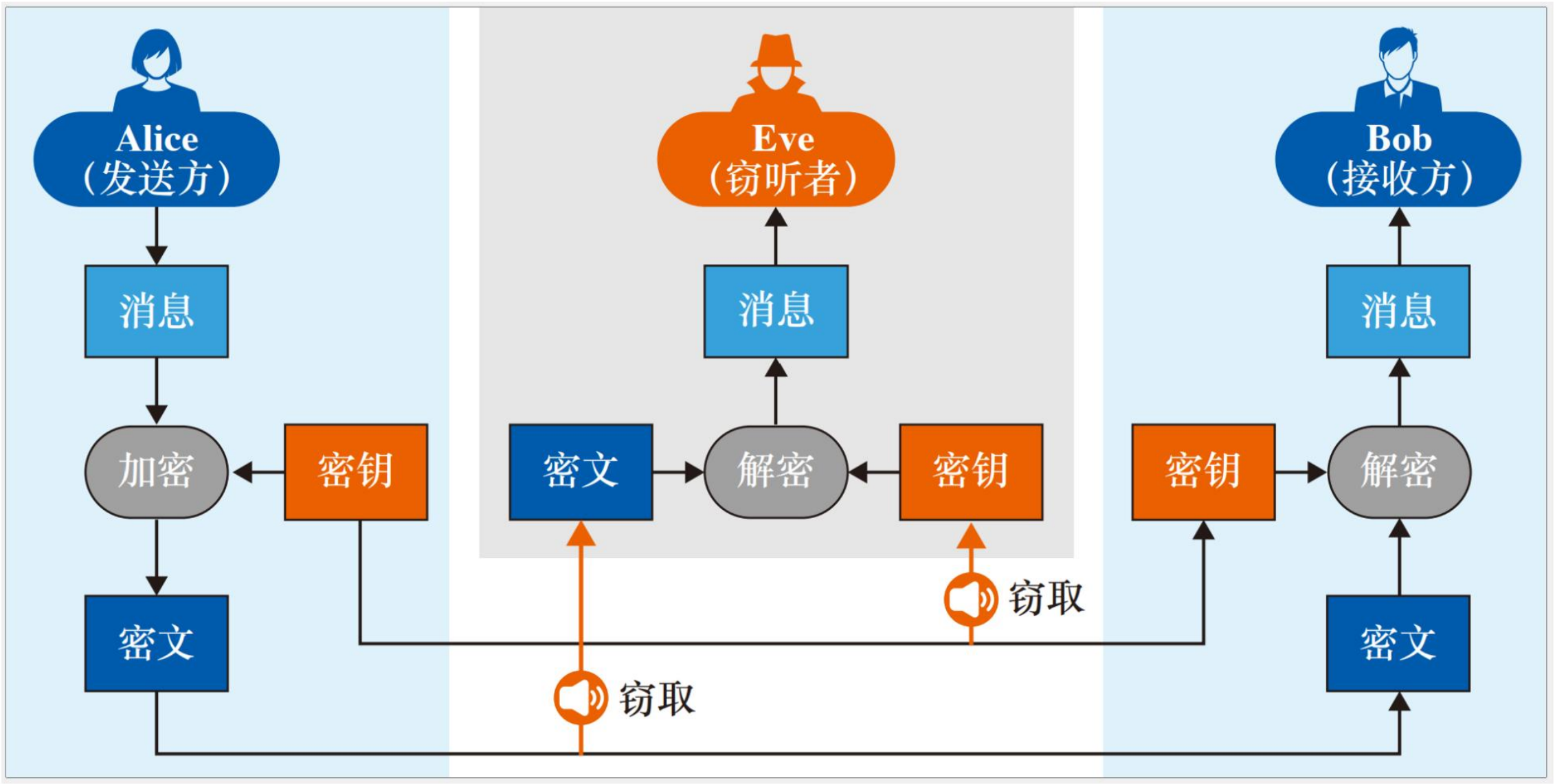
③ 用步骤②的结果使用密钥K_1进行DES加密。

这个过程称为 EDE，因为它是由加密—解密—加密（Encrypt Decrypt Encrypt）步骤组成的。在 EDE 中，中间步骤是解密，所以，可以使$K_1=K_2$来用三重 DES 方法执行常规的DES加密。



5.4 非对称密码（公钥密码）体制

对称密码中的密钥分发问题



解决方法

1. 通过事先共享密钥来解决

在加密通信以前，事先用安全的方式将密钥交给接收方

2. 通过密钥分配中心来解决

当参与加密通信的人过多，可以使用密钥分配中心(Key Distribution Center, KDC) 。当需要进行加密通信时，密钥分配中心会生成一个通信密钥，每个人只需和KDC事先共享密钥即可

3. 通过Diffie-Hellman密钥交换协议来解决

进行加密通信的双方仅需要交换一些信息，该信息即使被窃听也无法对算法进行解密，而通信双方则可以通过该信息各自生成相同的密钥

4. 通过公钥密码来解决

由于加解密使用不同密钥，故无需进行密钥分发

5.4 公钥密码体制

公钥密码体制 是1976年由斯坦福大学的Whitfield Daffier和Martin Hellmann提出的。

公钥密码通过使用两个密钥。这两种密钥合在一起称为**密钥对**。公钥密码也叫做**非对称密码**。

- **公钥：public key,** 尽人皆知的密钥
- **私钥：private key,** 只有密钥拥有者才知道的密钥

公钥密码系统的作用

公钥密码系统可用于以下三个方面：

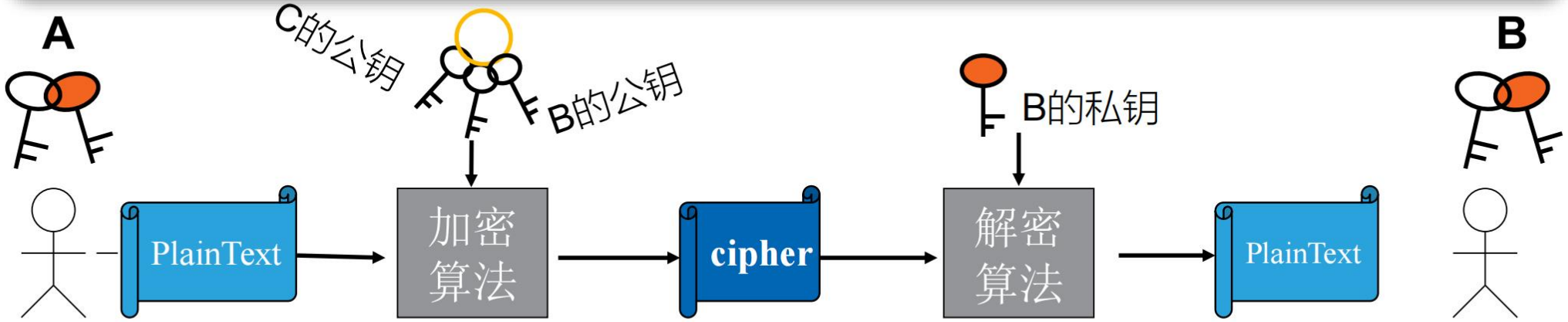
（1）**通信保密。**将**公钥作为加密密钥，私钥作为解密密钥**，不需要交换密钥就可以实现保密通信。这时，通过公钥或密文分析出明文或私钥是不可行的。当Alice给Bob发送信息时，$Encrypt(PK_{Bob}, M)$

（2）**数字签名。**将**私钥作为加密密钥，公钥作为解密密钥**，可实现由一个用户对数据签名而使多个用户验证。$M, Sign(SK_{Alice}, hash(M))$

（3）**密钥交换。**通信双方交换会话密钥，以加密通信双方后续连接所传输的信息。每次逻辑连接使用一把新的会话密钥，用完就丢弃。

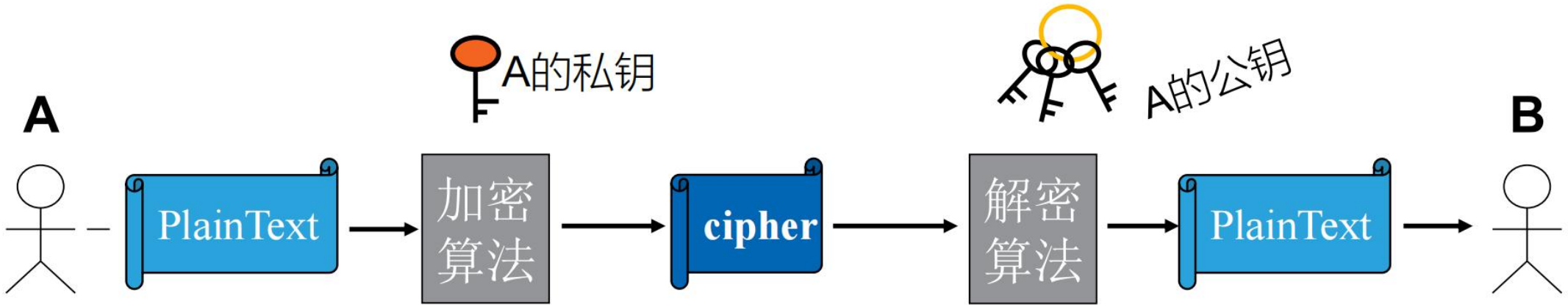
公钥密码系统的加密原理

- 每个通信实体有一对密钥(公钥，私钥)
  - 公钥公开，用于加密和验证签名，私钥保密，用作解密和签名
- A 向 B 发送消息，用 B 的公钥加密
- B 收到密文后，用自己的私钥解密



- **任何人向 B 发送信息都可以使用同一个密钥（B 的公钥）加密**
- **没有其他人可以得到 B 的私钥，所以只有 B 可以解密**

公钥密码系统的签名原理



- A 向 B 发送消息，用 A 的私钥加密 (签名)
- B 收到密文后，用 A 的公钥解密 (验证)

对公钥密码算法的误解

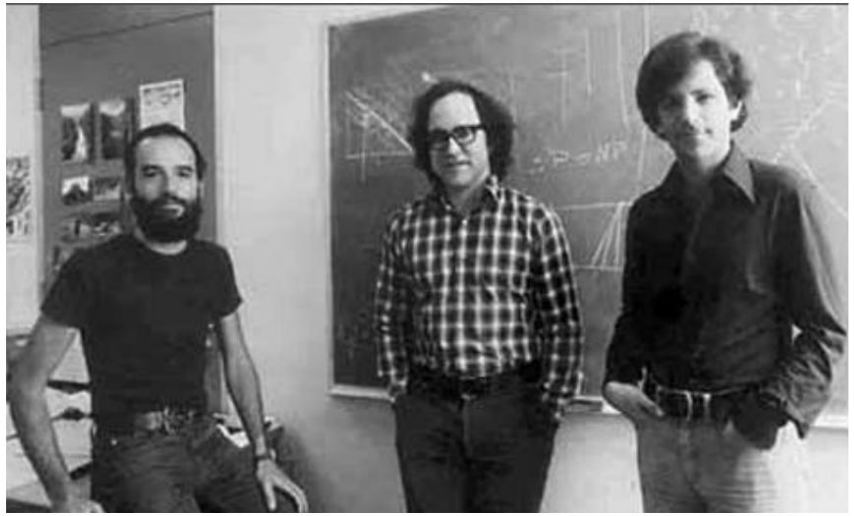
- 公开密钥算法比对称密钥密码算法更安全
  - 任何一种算法都依赖于密钥长度、破译密码的工作量，从抗分析角度，**没有一方更优越**
- 公开密钥算法使对称密钥成为过时的技术
  - 公开密钥很慢，只能用在密钥管理和数字签名，对称密钥密码算法将**长期存在**
- 使用公开密钥加密，密钥分配非常简单
  - 事实上的密钥分配既不简单，也不有效

RSA算法简介

- Ron Rivest, Adi Shamir , Leonard Adleman

  ——获得2002年图灵奖

- RSA的安全性基于**大数分解**的难度
- RSA在美国申请了专利(已经过期)，在其他国家没有
- RSA已经成了事实上的工业标准，在美国除外
- RSA算法既可以用于公钥密码也可以用于数字签名



RSA算法的性能表现

- **安全性**
  - 蛮力攻击：对所有密钥都进行尝试
  - 数学攻击：等效于对两个素数乘积(n)的因子分解
- 大数的因子分解是数论中的一个难题

因子分解的进展

十进制数字位数	近似比特数	得到的数据	MIPS年
100	332	1991	7
110	365	1992	75
120	398	1993	830
129	428	1994	5000
130	431	1996	500

- **速度**
  - 软件实现比DES慢100倍
  - 硬件实现比DES慢1000倍

	512位	768位	1024位
加密（秒）	0.03	0.05	0.08
解密（秒）	0.16	0.48	0.93
签名（秒）	0.16	0.52	0.97
验证（秒）	0.02	0.07	0.08

RSA算法密钥产生（不作考察要求）

- 密钥产生

1. 取两个大素数 p, q , **保密** → $p=7, q=17$
2. 计算$n=pq$，公开n → $n=119$
3. 计算欧拉函数$\varphi(n) = (p-1)(q-1)$ → $\varphi(n)=96$
4. 任意取一个与$\varphi(n)$互素的小整数e, 即 → 取$e=5$

   $gcd\ (e,\varphi(n)\ )=1;\ \ 1<e<\varphi(n)$
5. 寻找d, $d<\varphi(n)$, 使得 $de \equiv 1\ mod\ \varphi(n)$, $de = k\ \varphi(n) + 1$ → $5d=k\times 96+1$，取 $k=4$, 得到 $d=77$

公开$(e, n)=(5, 119)$

将d 保密，丢弃 p, q

RSA加密/解密过程

- 公开密钥: KU={e, n}
- 秘密密钥: KR=d
- 加密过程
  - 把待加密的内容分成k比特的分组
    $k \leq \log_2 n$，并写成数字，设为M，则
    $C = M^e \bmod n$
- 解密过程

$M = C^d \bmod n$

Remember:

$de = k\varphi(n) + 1$

$M^{k\varphi(n)+1} \equiv M \bmod n$

→ {5, 119}

→ 77

→ $c=m^5 \bmod 119$

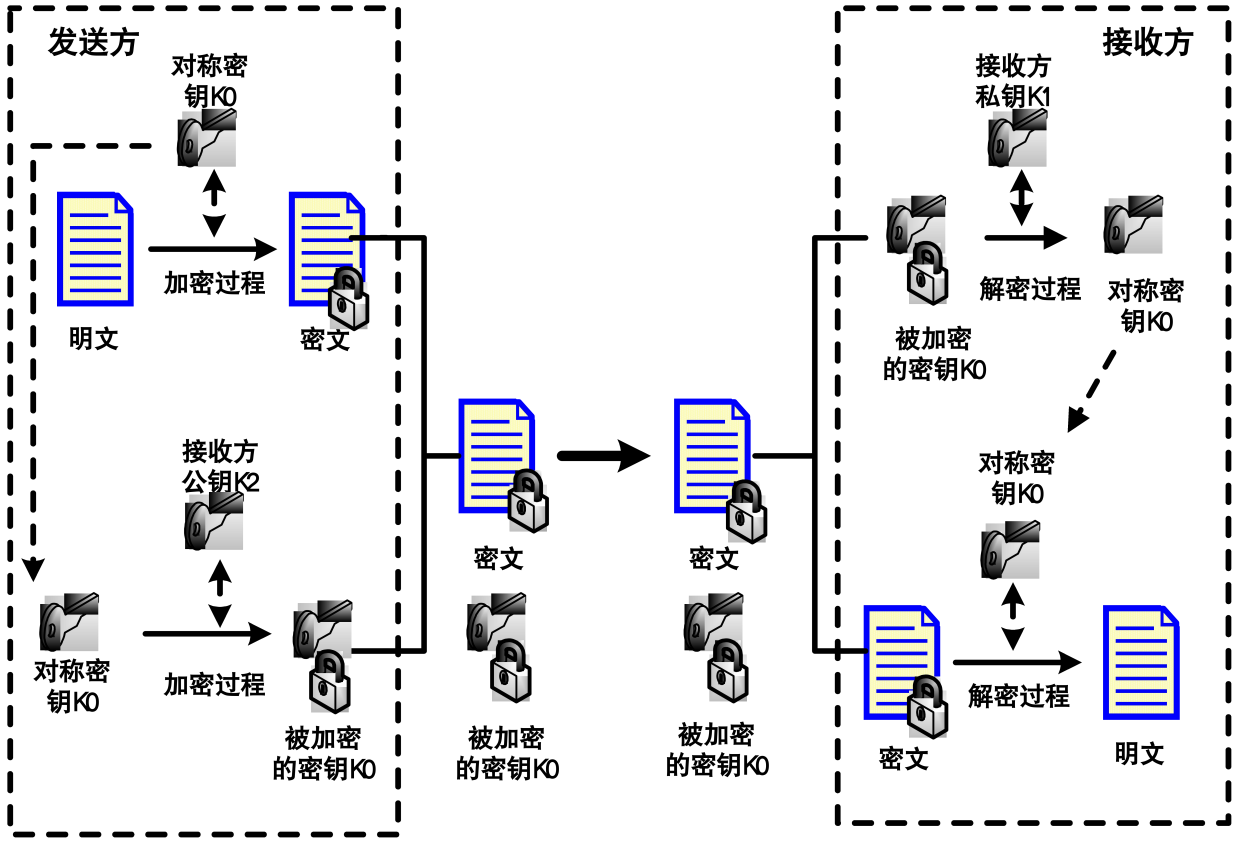
→ $m=c^{77} \bmod 119$

根据欧拉定理，若gcd(m, n)=1，则$m^{\varphi(n)} \equiv 1 \ (mod\ n)$

数字信封技术

数字信封技术使用两层加密体制，内层使用对称加密技术，外层使用非对称加密技术。例如Alice给Bob发送一个消息时：

$$E_{RSA}(PK_{Bob}, \text{session-key}), E_{AES}(\text{session-key}, \text{message})$$



数字签名技术

数字签名的作用有：

1. 身份认证/消息来源谁认证
2. 完整性验证
3. 不可抵赖性

假设Alice向Bob发送消息M，

数字签名的生成： $signature \leftarrow \mathrm{Sign}(SK_{Alice}, hash(M))$

$(M, signature)$

数字签名的验证：

$Digest_1 \leftarrow hash(M)$

$Digest_2 \leftarrow Decrypt(PK_{Alice}, signature)$

比较两个哈希值是否相等，若相等则验证通过

数字签名技术

数字签名应满足以下条件。

① **可验证。**即收方可以确认或证实签名确实是由发方签名的。

② **不可伪造的。**接收方和第三方都不能伪造签名。

③ **不可重用。**即签名是消息（文件）的一部分，不能把签名移到其他消息（文件）上。

④ **不可抵赖。**即发方不能否认他所签发的消息。

⑤ **第三方可验证。**第三方可以确认收发双方之间的消息传送但不能篡改消息。

公钥基础设施PKI

PKI（Public Key Infrastructure）是利用公钥理论和技术建立的提供安全服务的基础设施，能够为所有网络应用提供加密和数字签名等密码服务及所必需的密钥和证书管理体系。

CA

证书颁发机构CA（Certificate Authority）是证书的签发、认证和管理机构，是PKI的核心。

证书的颁发：如果用户Bob想使用公钥密码时，他应先向 CA 提出申请。在CA判明申请者的身份后，便为他分配公私钥及证书。

$$Cert_{Bob} = \langle ID_{Bob}, PK_{Bob}, Info, Sign(SK_{CA}, ID_{Bob}, PK_{Bob}, Info) \rangle$$

证书可用于验证公钥的真实性：Bob可以向其它用户（如Alice）分享自己的公钥PK_{Bob}及证书，当Alice想验证Bob所提供公钥的真实性时，可以验证其证书上CA的签名。

那么，CA的公钥的真实性如何来验证呢?



第6章 网络安全技术

第6章 网络安全技术

按照网络安全技术的理论可分为：攻击技术和防御技术。

- 攻击技术包括网络监听、网络扫描、网络入侵、网络后门等；
- 防御技术包括加密技术、防火墙技术、入侵检测技术等。

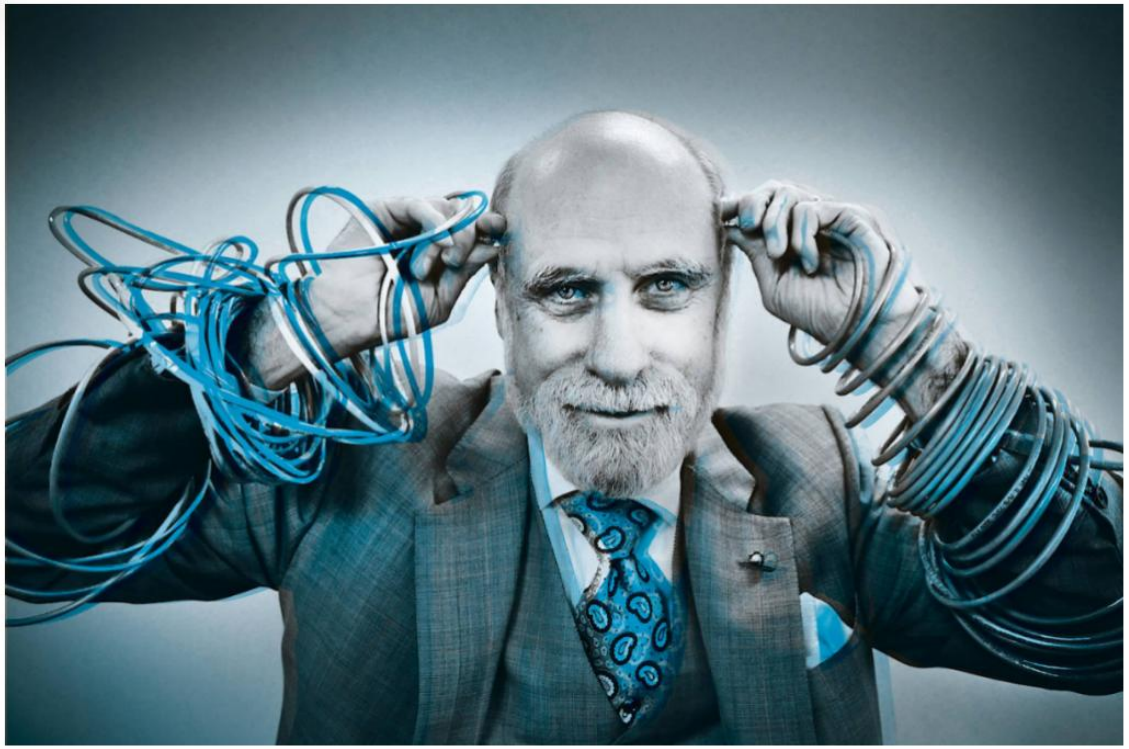
网络安全技术

第6章
主要内容

- TCP/IP协议栈安全
- 常见网络攻击类型
- 防御技术及产品

TCP/IP协议栈原理

TCP/IP协议栈

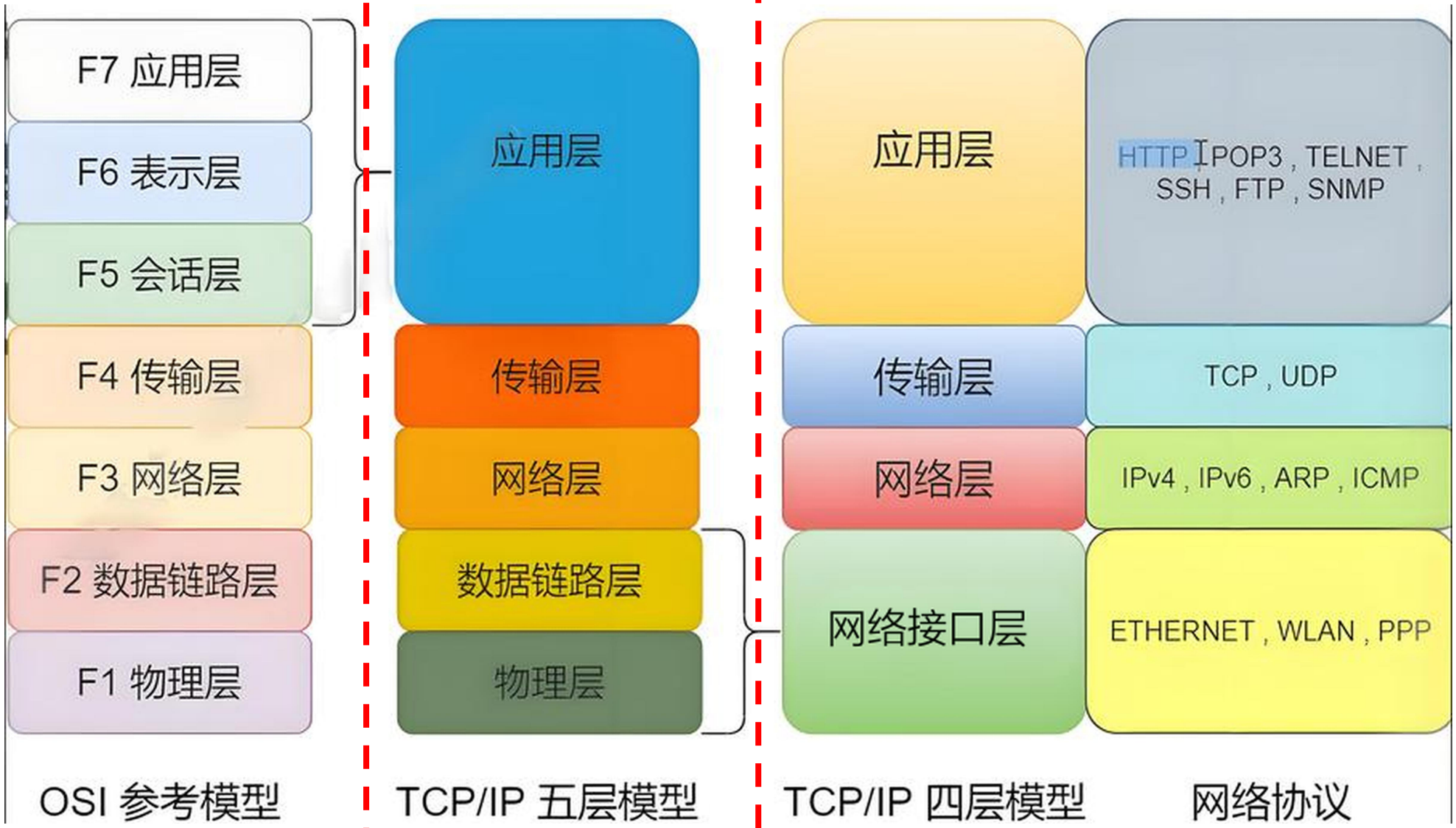




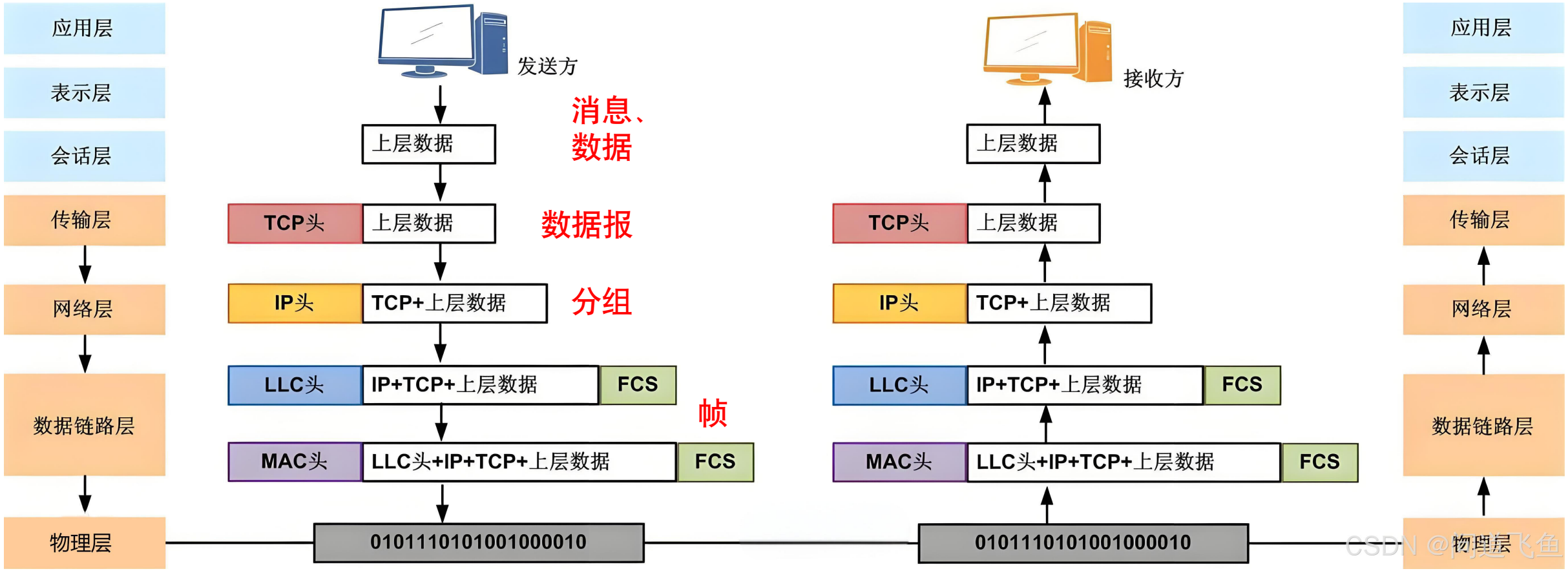
上世纪70年代，罗伯特·卡恩和文顿·瑟夫开发了TCP/IP协议。TCP/IP协议是互联网的核心，其标准化过程由IETF主导，形成的标准系列名为RFC

TCP/IP协议栈

本课程以TCP/IP五层模型为主进行讲解

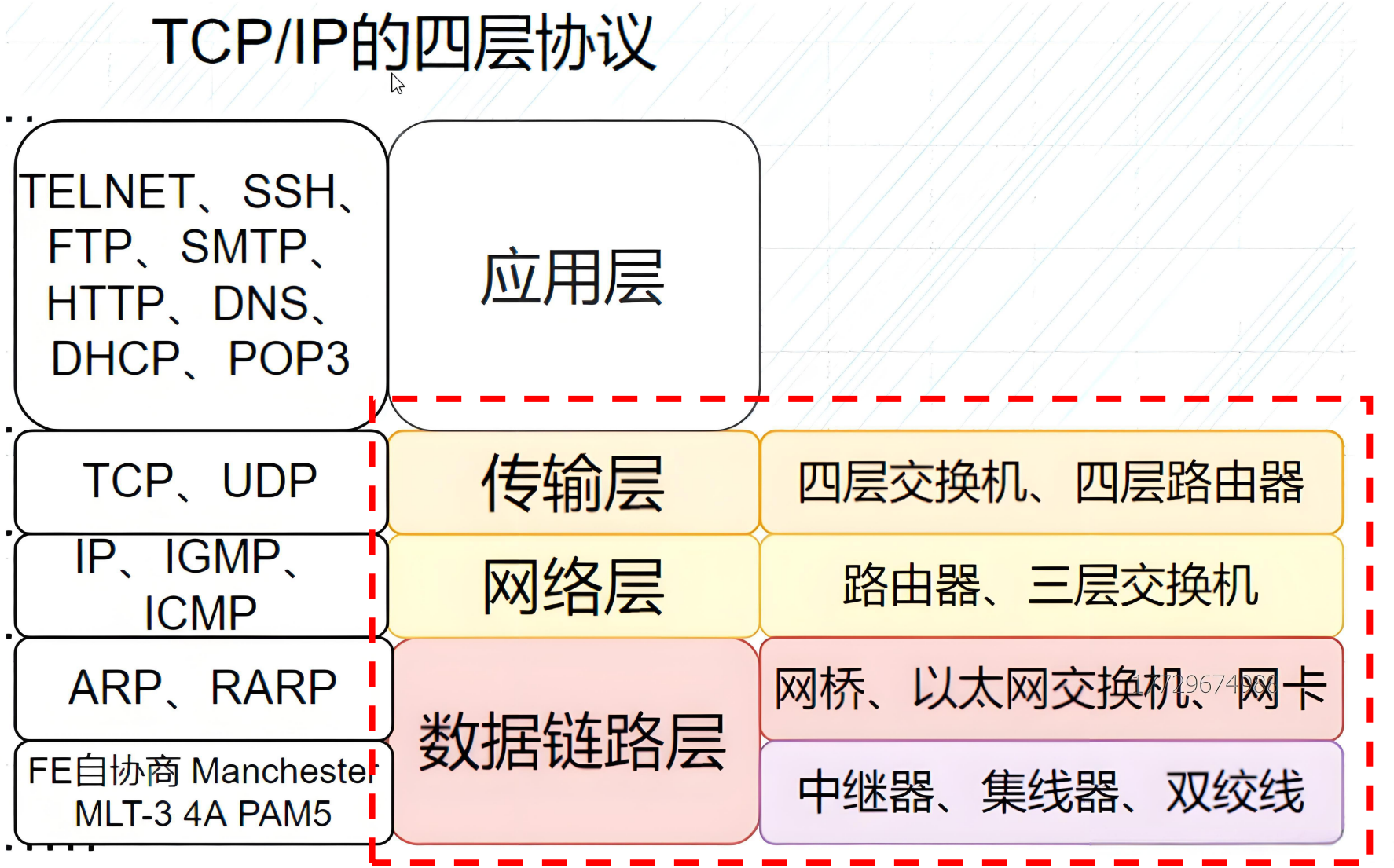


数据包的封装



CSDN @阿超飞鱼

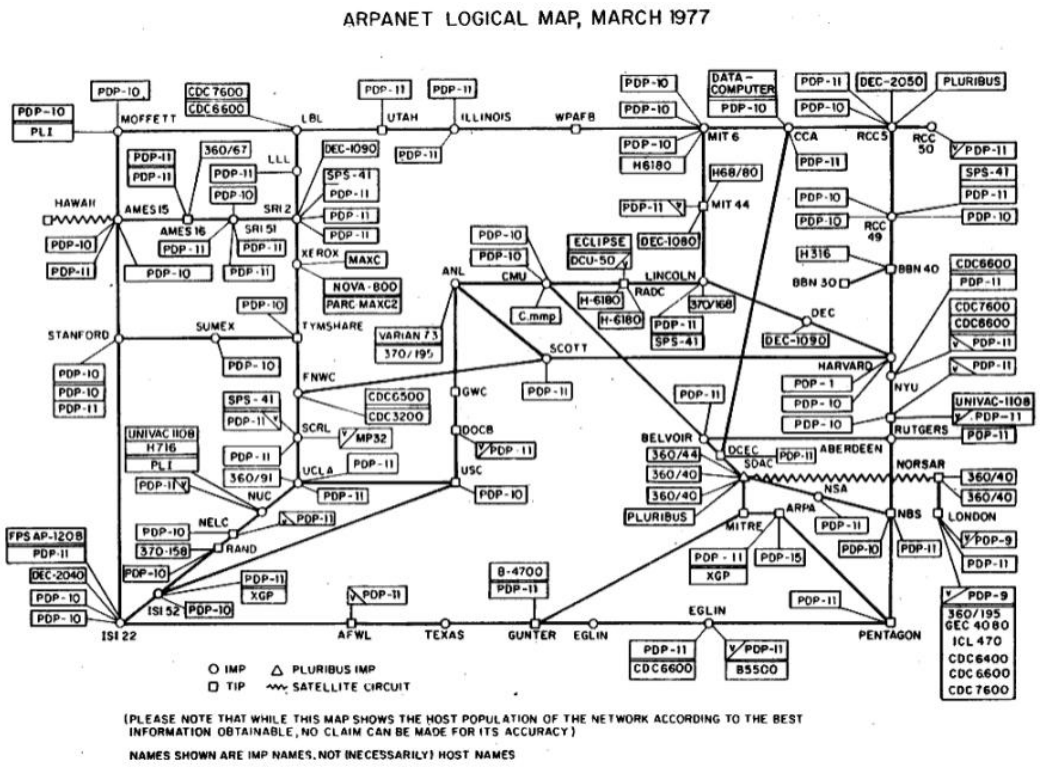
不同层涉及到的网络设备



TCP/IP协议栈安全

互联网在设计之初仅面向可信的、少量的用户群体，因此并未考虑安全性的问题。但随着互联网的发展，网络的安全问题变得逐渐突出





9. Security Considerations

Security issues are not discussed in this memo.

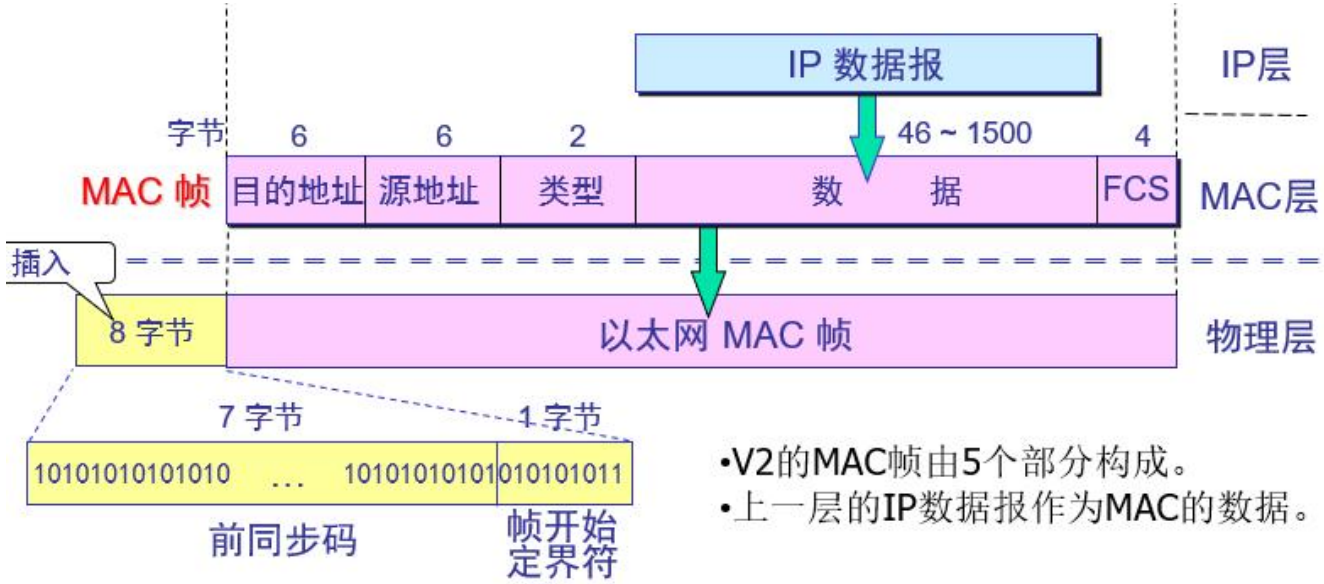
链路层安全

链路层功能

链路层最基本的功能是向该层用户提供透明和可靠的数据传送基本服务

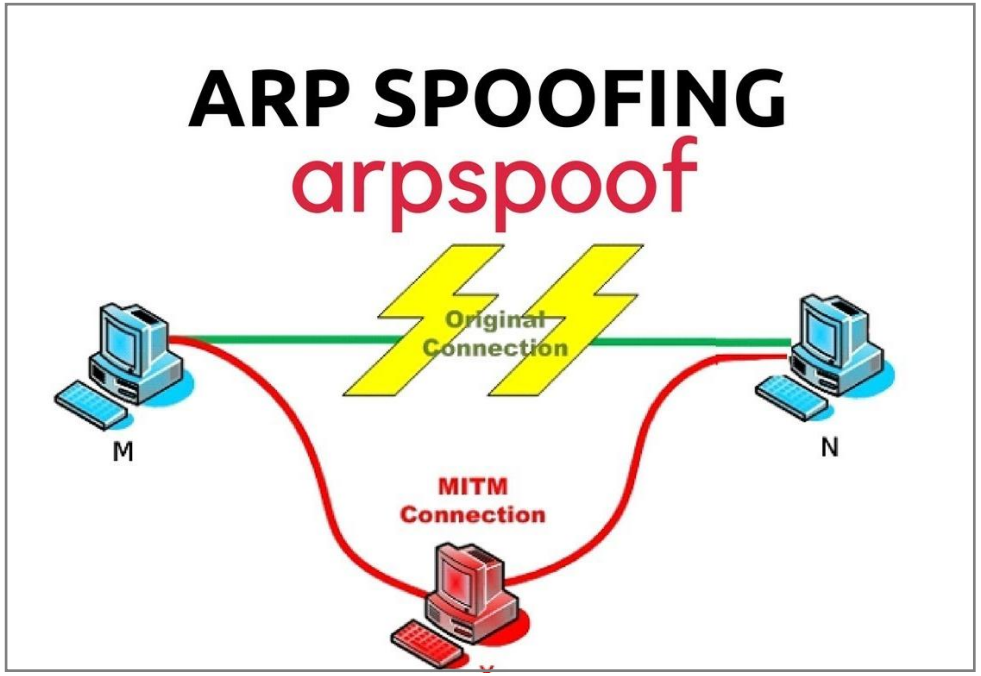
主要功能有：

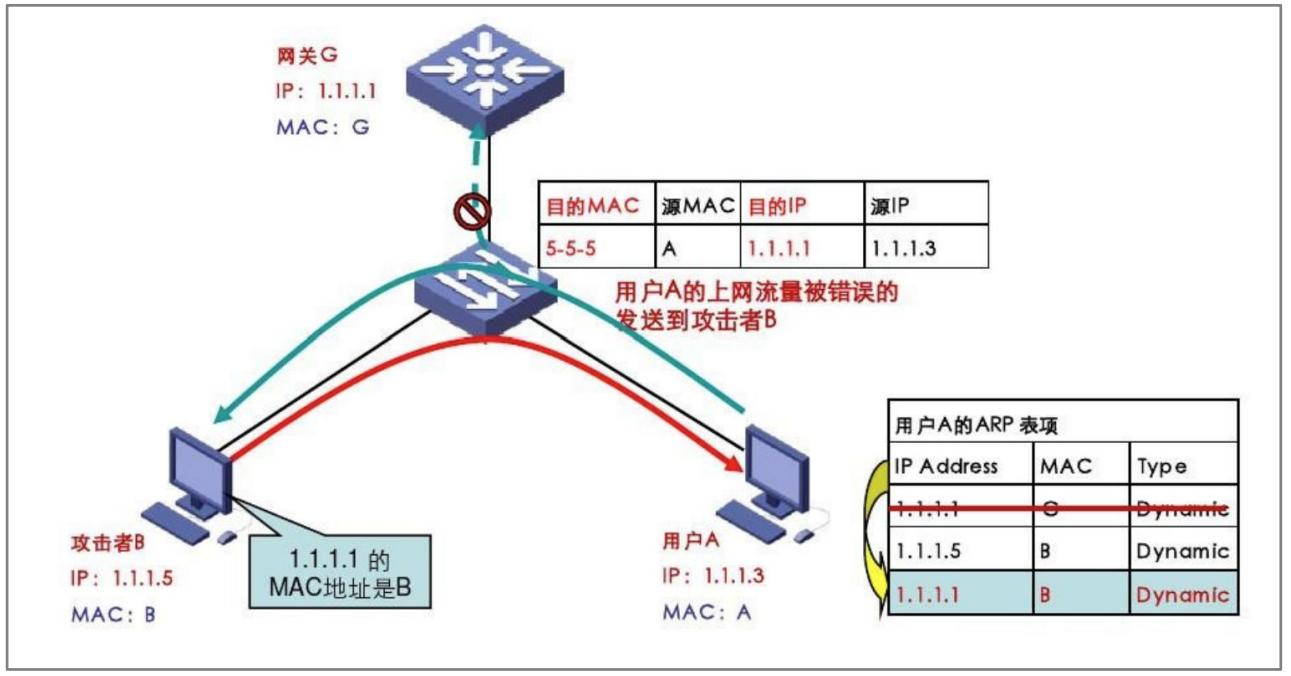
- 将数据组合成帧
- 控制在物理信道上的传输，包括处理传输差错，调节发送速率
- 提供数据链路通路的建立、维持和释放的管理



ARP（Address Resolution Protocol）欺骗与污染

- ARP欺骗（ARP spoofing），又称ARP污染（ARP poisoning），是针对以太网地址解析协议（ARP）的一种攻击技术
- 可让攻击者成为中间人（Man-in-the-Middle, **MITM**），获取局域网上的数据包，甚至可篡改数据包，同时迫使受害主机无法正常接收报文

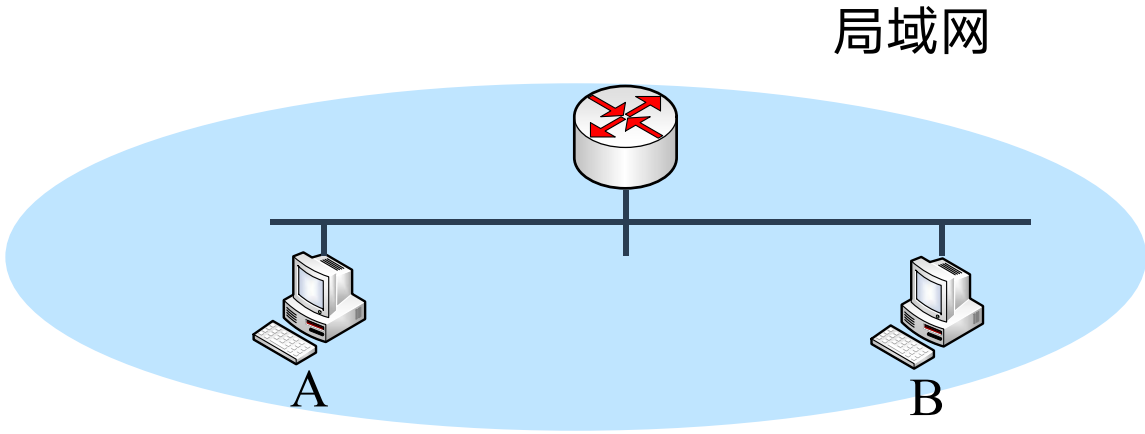




正常的ARP解析过程

拓扑示例：

局域网中的两台主机A、B，以及他们的IP地址和MAC地址

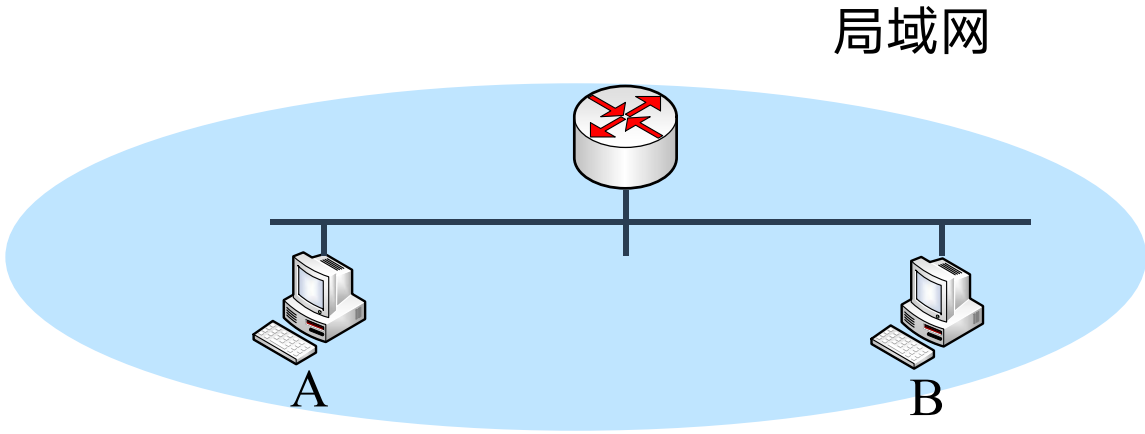


ARP表	主机	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
	B	192.168.1.2	0A-11-22-33-44-02

正常的ARP解析过程

A、B间正常的ARP解析过程：

第1步： A主机在本地ARP缓存中，查找主机B的MAC地址

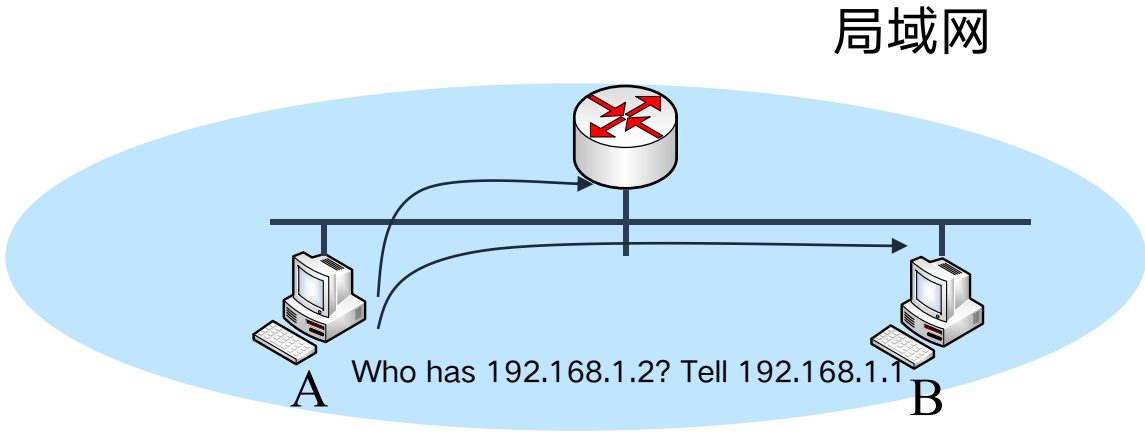


ARP表	主机	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
		192.168.1.2	?
	B	192.168.1.2	0A-11-22-33-44-02

正常的ARP解析过程

A、B间正常的ARP解析过程：

第2步：如果没有找到，就需要通过将ARP请求帧广播到本地网络上的所有主机来询问192.168.1.2 的MAC地址

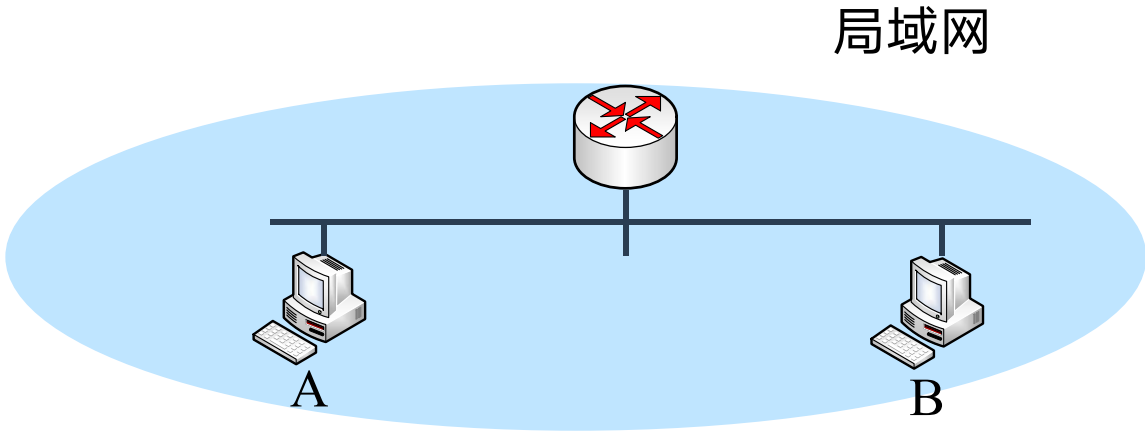


ARP表	主机	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
		192.168.1.2	?
	B	192.168.1.2	0A-11-22-33-44-02

正常的ARP解析过程

A、B间正常的ARP解析过程：

第3步： 主机B确定ARP请求中的IP地址与自己的IP地址匹配，将主机A的IP地址和MAC地址映射添加到本地ARP缓存中

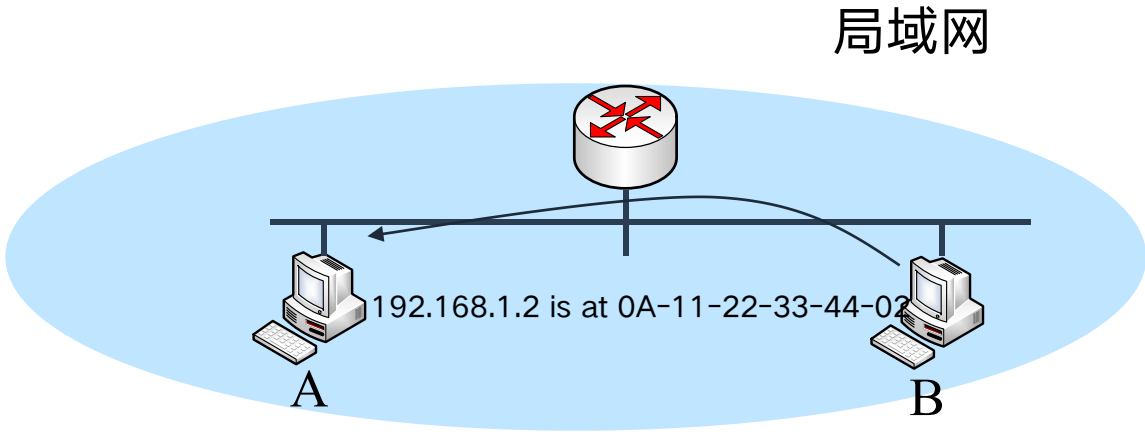


ARP表	主机	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
		192.168.1.2	?
	B	192.168.1.2	0A-11-22-33-44-02
		192.168.1.1	0A-11-22-33-44-01

正常的ARP解析过程

A、B间正常的ARP解析过程：

第4步： 主机B将包含其MAC地址的ARP回复消息，直接发送回主机A

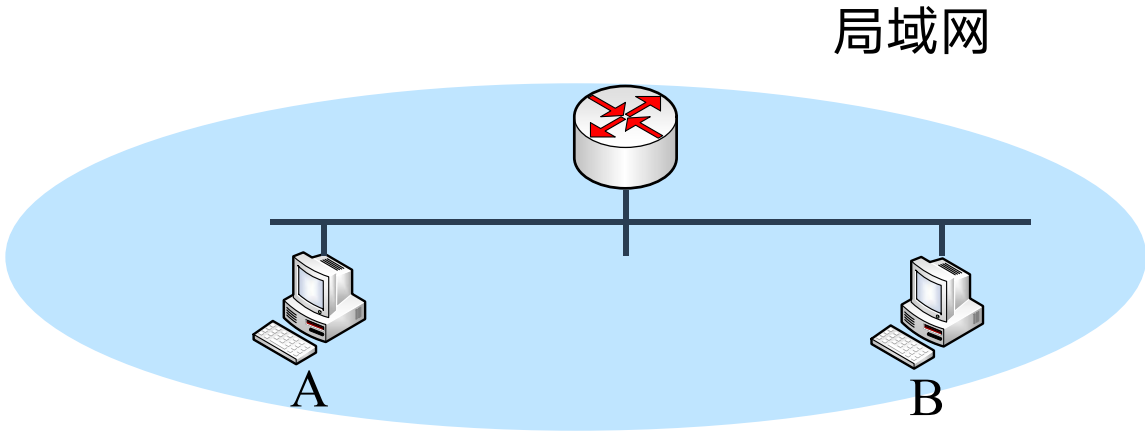


ARP表	主机	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
		192.168.1.2	?
	B	192.168.1.2	0A-11-22-33-44-02
		192.168.1.1	0A-11-22-33-44-01

正常的ARP解析过程

A、B间正常的ARP解析过程：

第5步： A收到回复，用主机B的IP地址和MAC地址映射更新ARP缓存



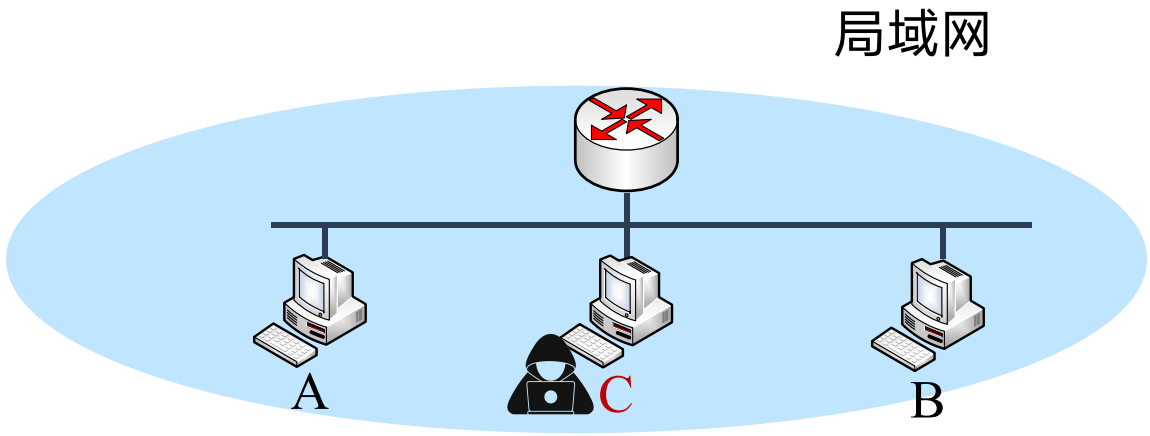
ARP表	主机	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
		192.168.1.2	0A-11-22-33-44-02
	B	192.168.1.2	0A-11-22-33-44-02
		192.168.1.1	0A-11-22-33-44-01

ARP欺骗与污染

安全问题：

在ARP回复时，主机A并不会验证ARP回复包的**真实性**。由此引出一个局域网攻击方式

ARP欺骗：恶意主机C，企图冒充B，欺骗A

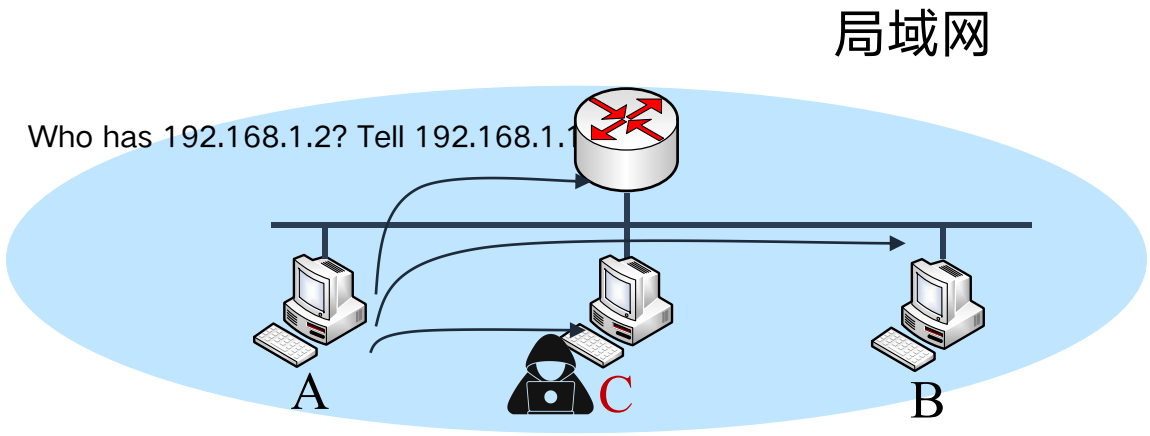


ARP表	主机	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
	B	192.168.1.2	0A-11-22-33-44-02
	C	192.168.1.3	0A-11-22-33-44-03

ARP欺骗与污染

恶意节点C进行ARP欺骗，污染攻击A的ARP缓存：

第1步：主机A要和主机B通信，主机A发出ARP包询问谁是192.168.1.2？请回复192.168.1.1

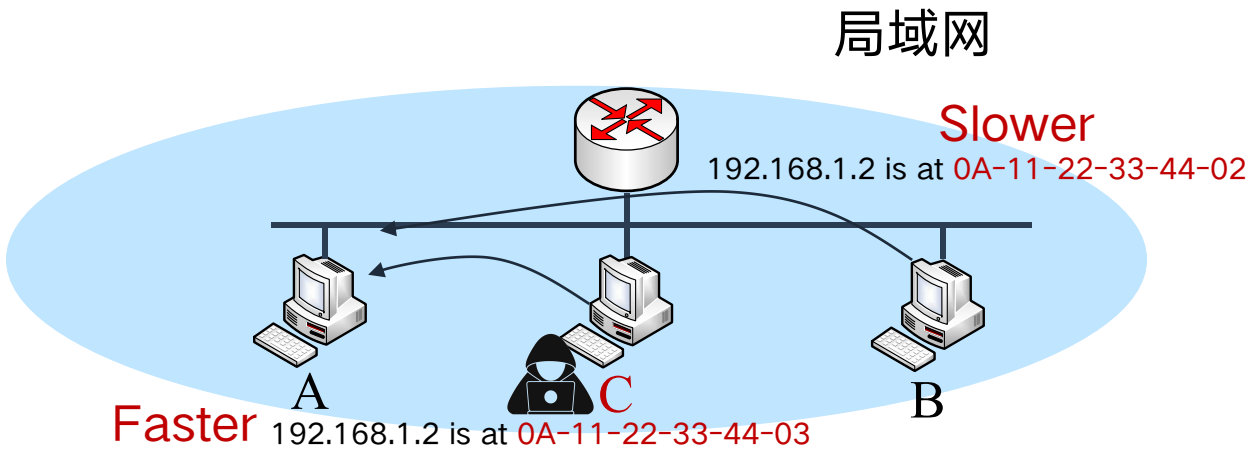


ARP表	主机	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
		192.168.1.2	?
	B	192.168.1.2	0A-11-22-33-44-02
	C	192.168.1.3	0A-11-22-33-44-03

ARP欺骗与污染

恶意节点C进行ARP欺骗，污染攻击A的ARP缓存：

第2步：主机C向主机A发送ARP应答报文，我是192.168.1.2，我的地址是0A-11-22-33-44-03

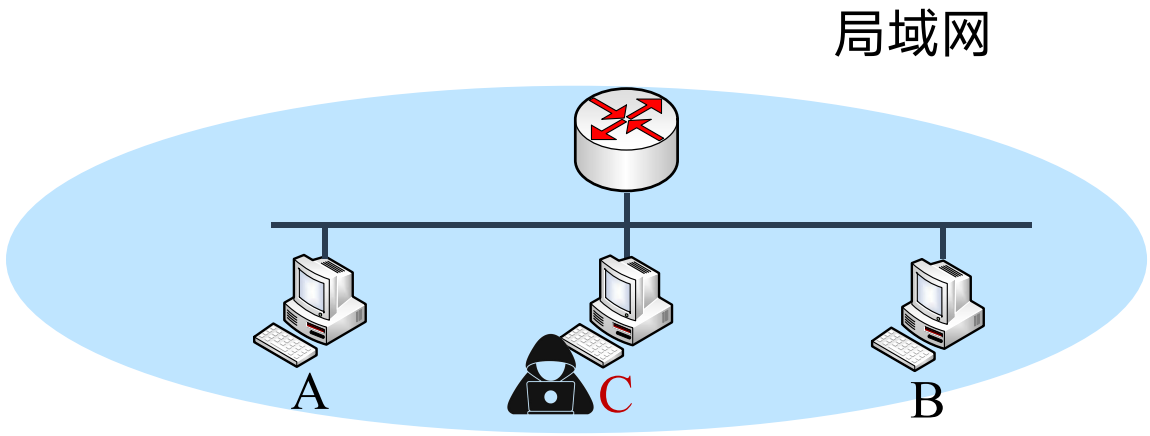


ARP表	主机	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
		192.168.1.2	?
	B	192.168.1.2	0A-11-22-33-44-02
		192.168.1.1	0A-11-22-33-44-01
	C	192.168.1.3	0A-11-22-33-44-03

ARP欺骗与污染

恶意节点C进行ARP欺骗，污染攻击A的ARP缓存：

第3步：当A收到C发来的ARP回复消息时，会用**B的IP地址和C的MAC地址**映射，更新ARP缓存，从而实现了攻击者C对A发往B的流量的劫持

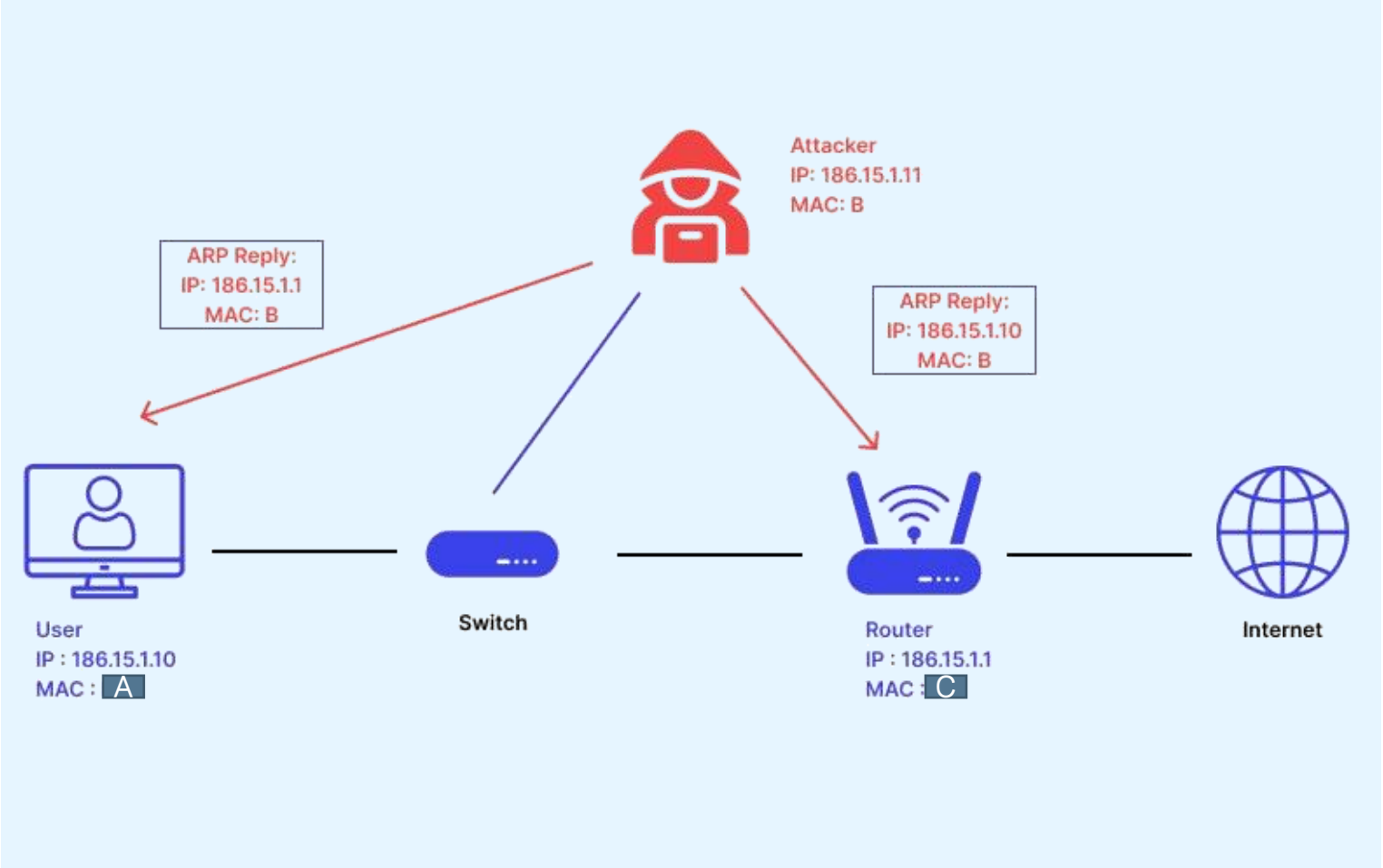


ARP表

主机	IP	MAC
A	192.168.1.1	0A-11-22-33-44-01
	192.168.1.2	0A-11-22-33-44-03
B	192.168.1.2	0A-11-22-33-44-02
	192.168.1.1	0A-11-22-33-44-01
C	192.168.1.3	0A-11-22-33-44-03

ARP欺骗与污染

如果攻击者**假冒为网关**向受害者发送ARP广播应答，从而成为中间人（Man-in-the-Middle, **MITM**），可以窃取或篡改局域网上的数据包，**危害更大**

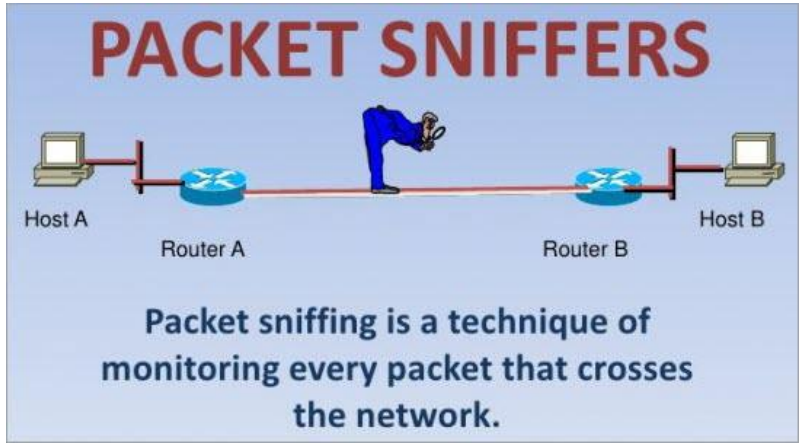


如何防御ARP欺骗与污染攻击

静态ARP绑定	将**IP地址和MAC地址绑定**在一起，防止ARP表被攻击者篡改。 这种方法需要在网络中的每个设备上**手动配置**
ARP监控	通过**实时监控ARP表的变化**，及时发现并防范ARP欺骗攻击。 常用的ARP监控工具包括ARPWatch、ArpON等
划分虚拟局域网	将网络分成多个虚拟的子网，不同的子网之间通过路由器连接。 这样可以**将攻击者与被攻击设备隔离**开来，增加攻击的难度

网络监听与嗅探

- 网络嗅探（Sniffers）是一种网络流量数据分析的手段，常见于网络安全攻防技术使用，也有用于业务分析领域
- “嗅探工具”，也称为“数据包分析器”，还有别称为“嗅探器”、“抓包工具”等。常见的开源嗅探工具包括TCPDUMP，Wireshark等



TCPDUMP

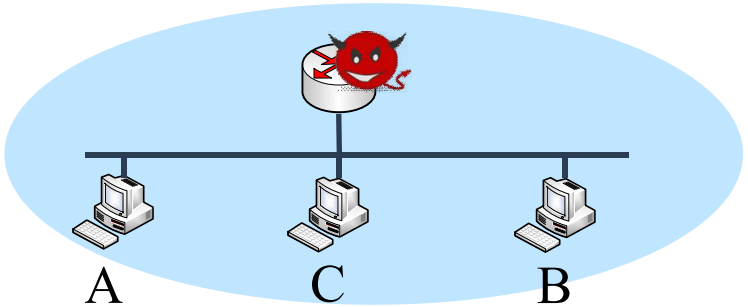
Wireshark

网络嗅探具有两面性

- **网络管理员**使用嗅探器，通过捕获分析网络流量，进行高效的网络管理
- **恶意攻击者**使用嗅探器，攫取网络中的大量敏感信息，进行网络攻击





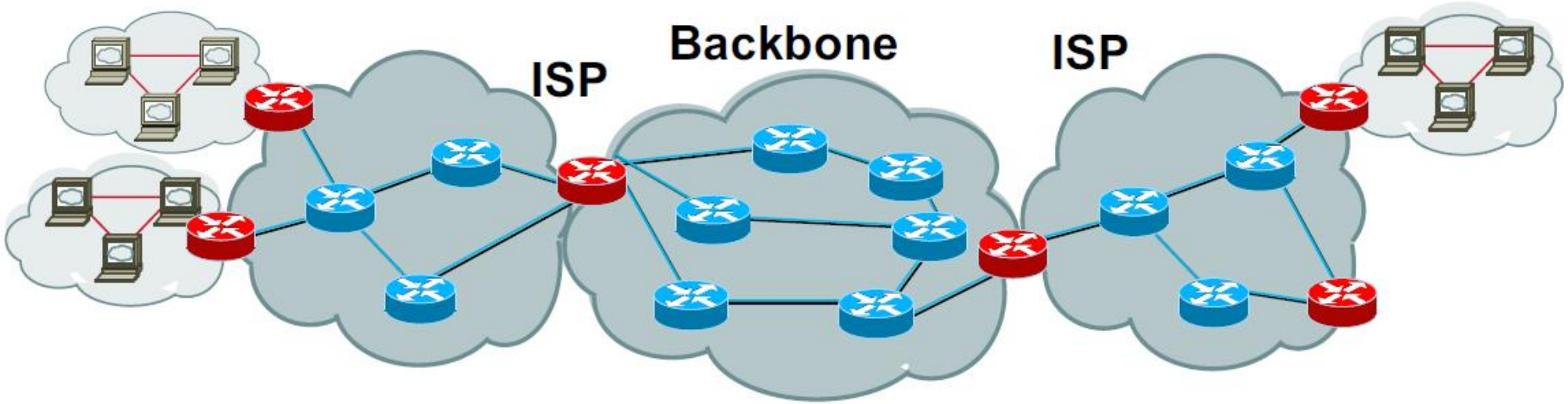


恶意的网络嗅探，取决于攻击者的位置和攻击能力：

- 共享网络传输链路场景下，攻击者的恶意嗅探监听
- 攻击者控制了网络设备，对流经的流量进行拦截嗅探

网络层安全

网络层功能



网络层介于传输层和数据链路层之间，向传输层提供最基本的端到端的数据传送服务

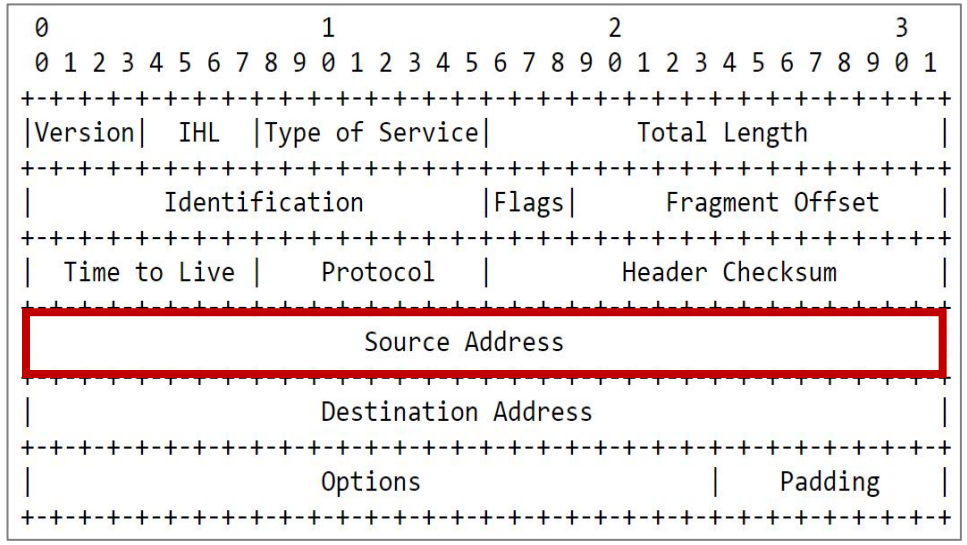
网络层具备的功能包括：

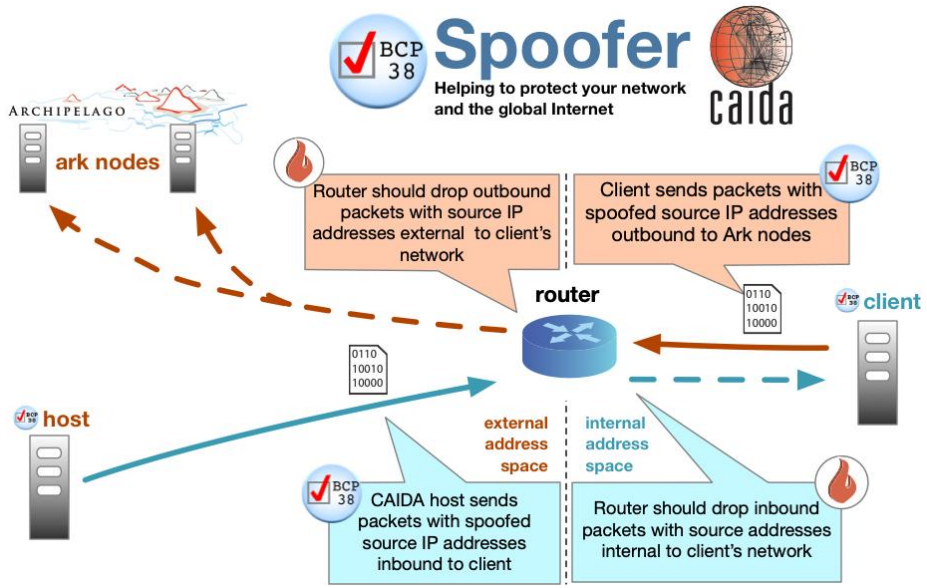
- Best effort 分组转发
- 路由
- 网络连接复用
- 服务选择
- 网络管理
- 分片与重组

源地址假冒攻击

IP地址用于唯一标识互联网上的一个网络通信接口

互联网在设计之初，对分组的源IP地址并不进行合法性验证，因此恶意的攻击者很容易篡改或伪造分组的源IP地址

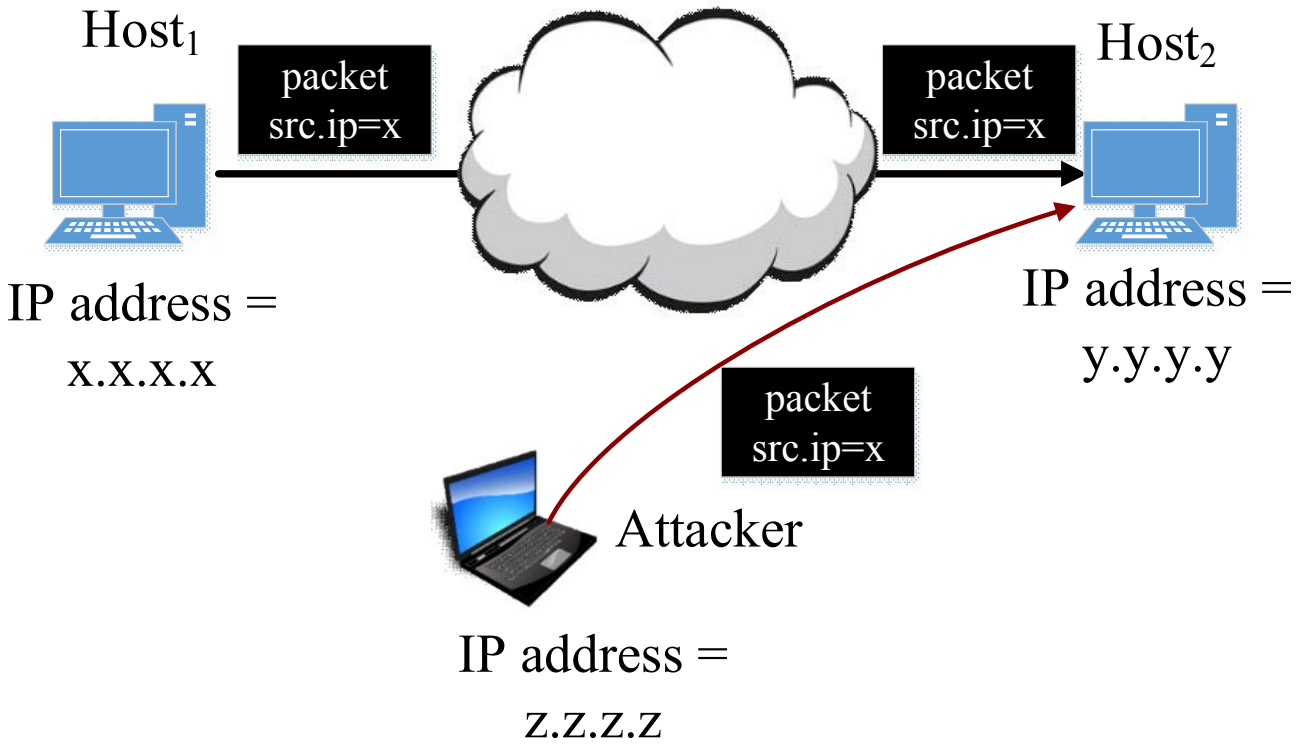




源地址假冒攻击

攻击原理：

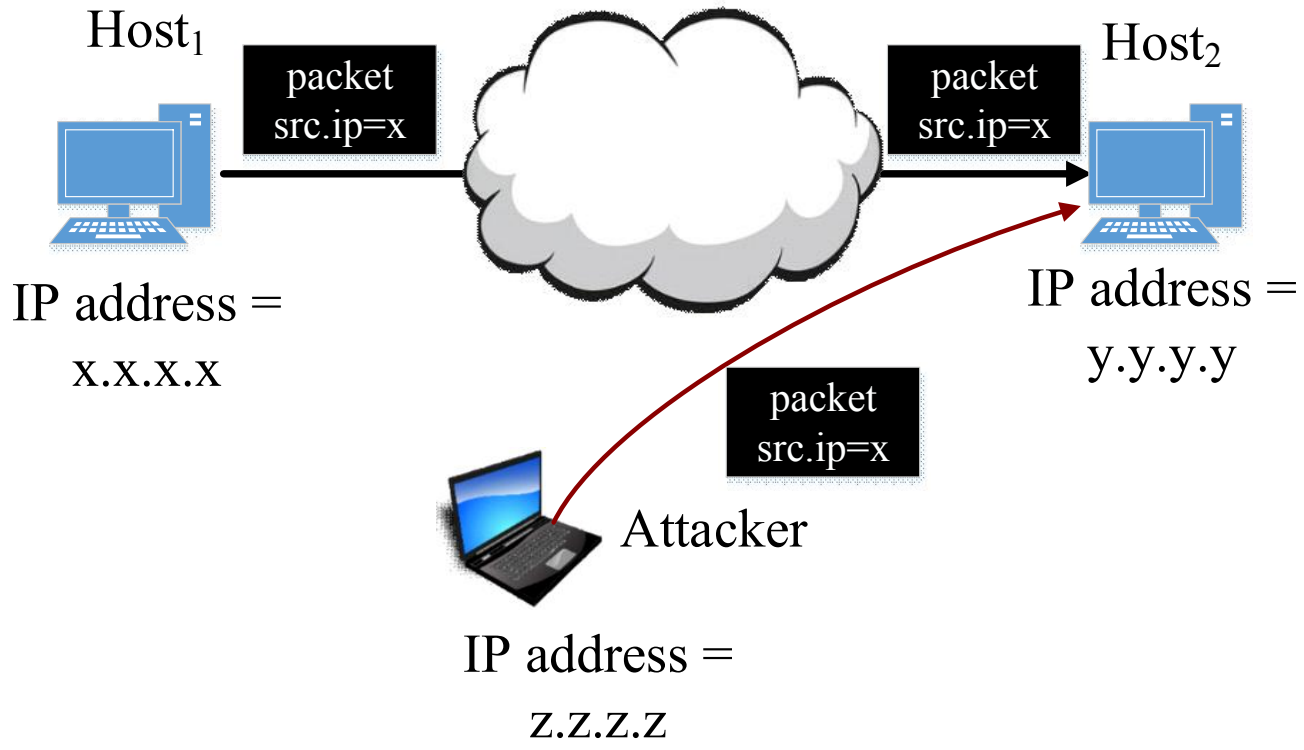
- $Host_1$和$Host_2$为正常合法通信的两台主机，IP地址分别为：x.x.x.x 和 y.y.y.y
- 恶意攻击者Attacker，其真实IP地址为z.z.z.z，Attacker企图冒充$Host_1$，发动源IP地址伪造攻击
- Attacker生成恶意分组，发送给主机$Host_2$，并且将分组的源地址指定为x.x.x.x



源地址假冒攻击

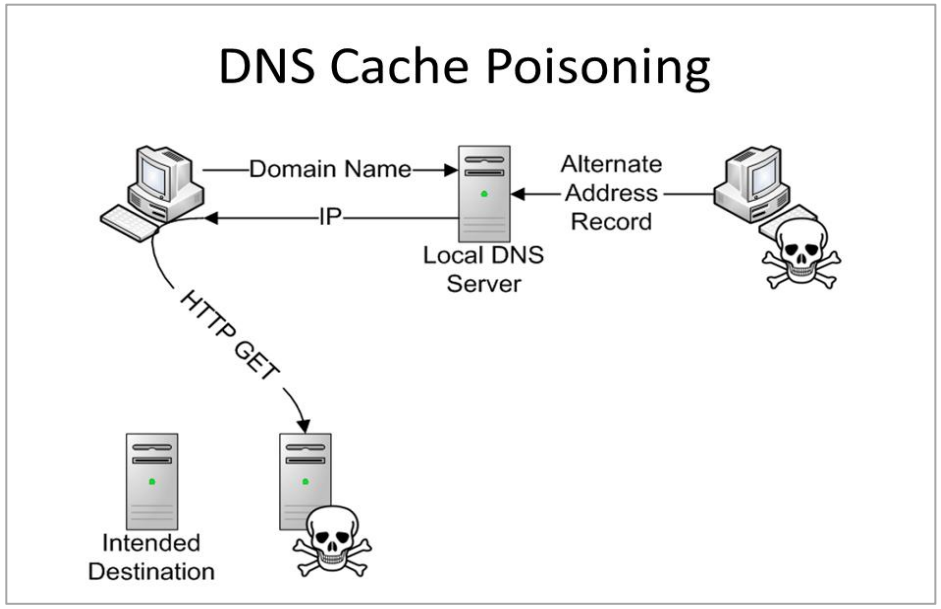
最终的后果是：

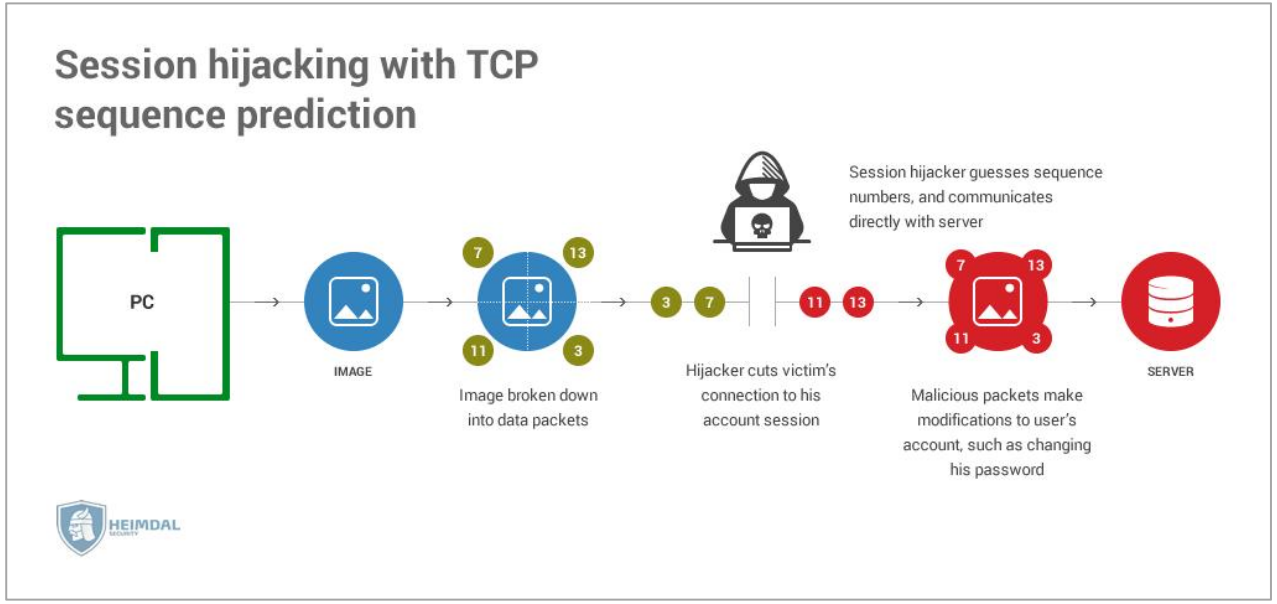
- Attacker欺骗了主机$Host_2$，使其误认为这些分组来自于合法的远程通信端$Host_1$
- Attacker也隐藏了自己的真实地址和身份，避免被追踪溯源



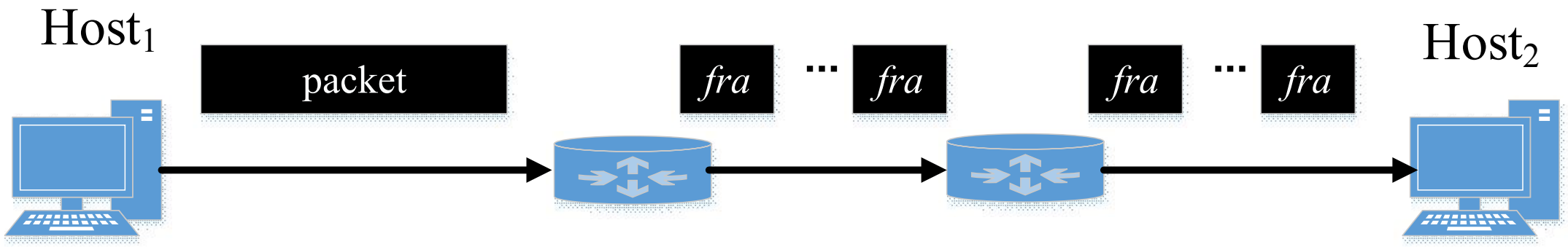
源地址假冒攻击

IP地址伪造通常是攻击者需具备的基本能力和手段，也是进行后续恶意数据注入、连接劫持等攻击行为的基础条件，如**TCP连接劫持攻击、DNS污染攻击**等





IP分片攻击原理



当互联网上的两台远程主机进行数据传输时，如果传输路径上的各路由器间，存在不同的链路**最大传输单元**（Maximum Transmission Unit, **MTU**），那么可能会发生IP分组分片（IP fragmentation），以满足链路MTU的要求

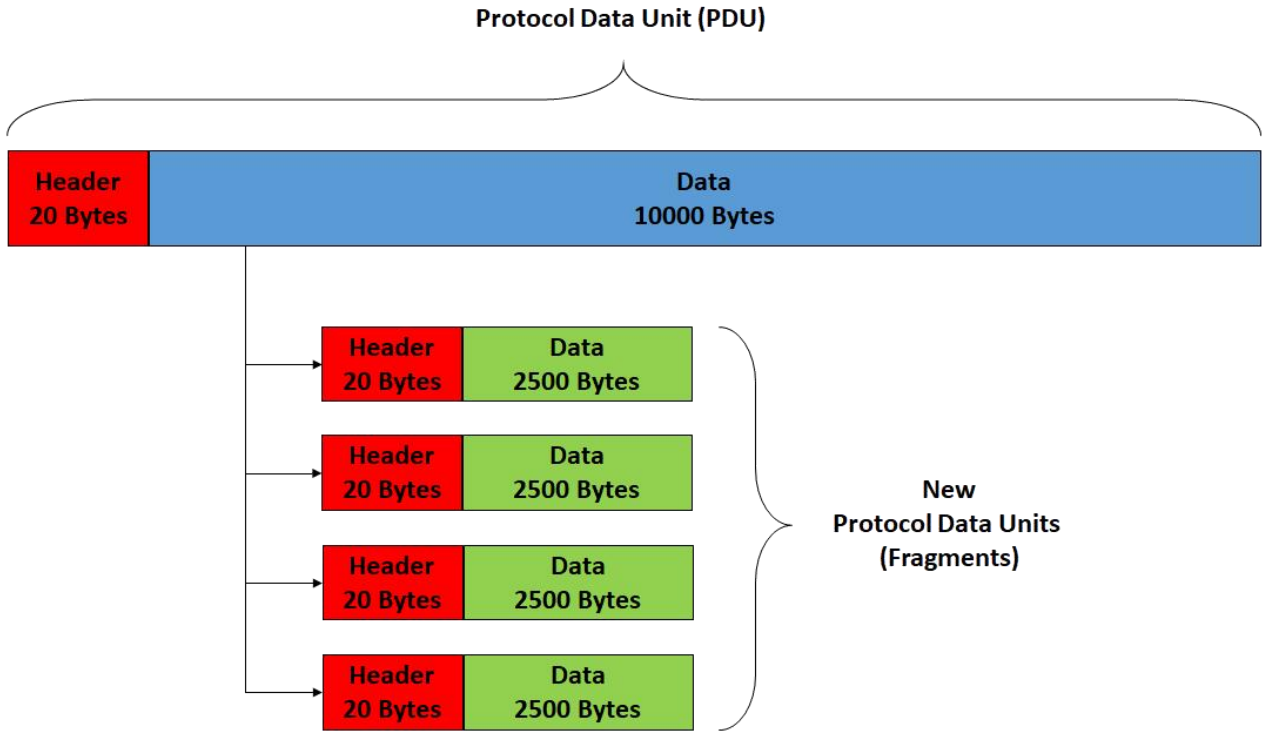
IP分片攻击原理

IP分组的这种先分片、再重组的机制，为攻击者暴露出了IP层的一个攻击面。

IP分片通常发生在**源主机或中间路由器**上，而重组往往都在目的接收端发生

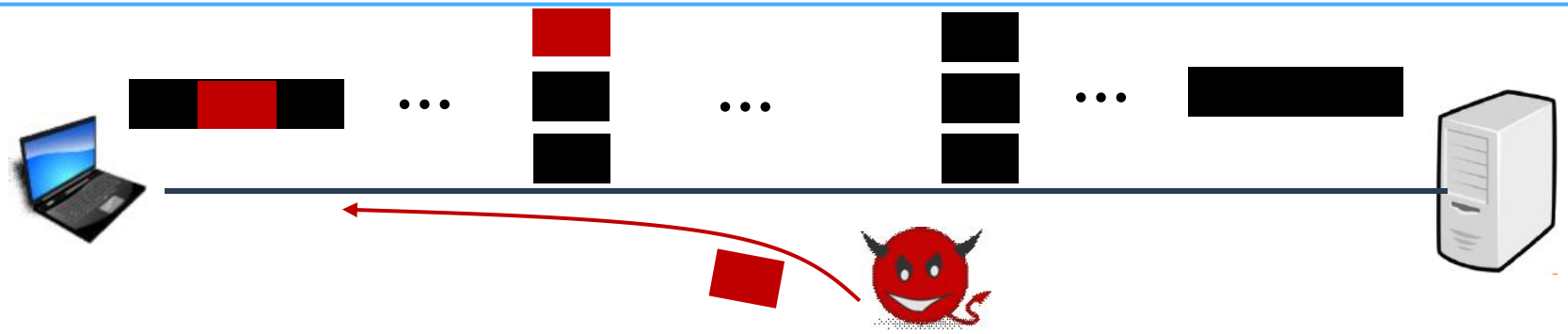
根据不同的攻击效果，IP分片攻击可以分为3种：

- 拒绝服务攻击
- 污染攻击
- 安全策略逃逸



IP分片利用——污染攻击

- 在原始报文被分片、传输过程中，攻击者**伪造一些分片**，注入到正常分片流中，篡改原始报文内容，从而形成对合法流量的污染
- 在这一过程中，攻击者需要具备的能力：
  - 源地址欺骗
  - IPID的猜测
  - 原始报文校验和的欺骗等



基于分片的污染攻击技术，已被广泛应用到DNS缓存污染、流量拦截等场景中

IP分片利用——DNS缓存污染攻击



client

Recursive resolver





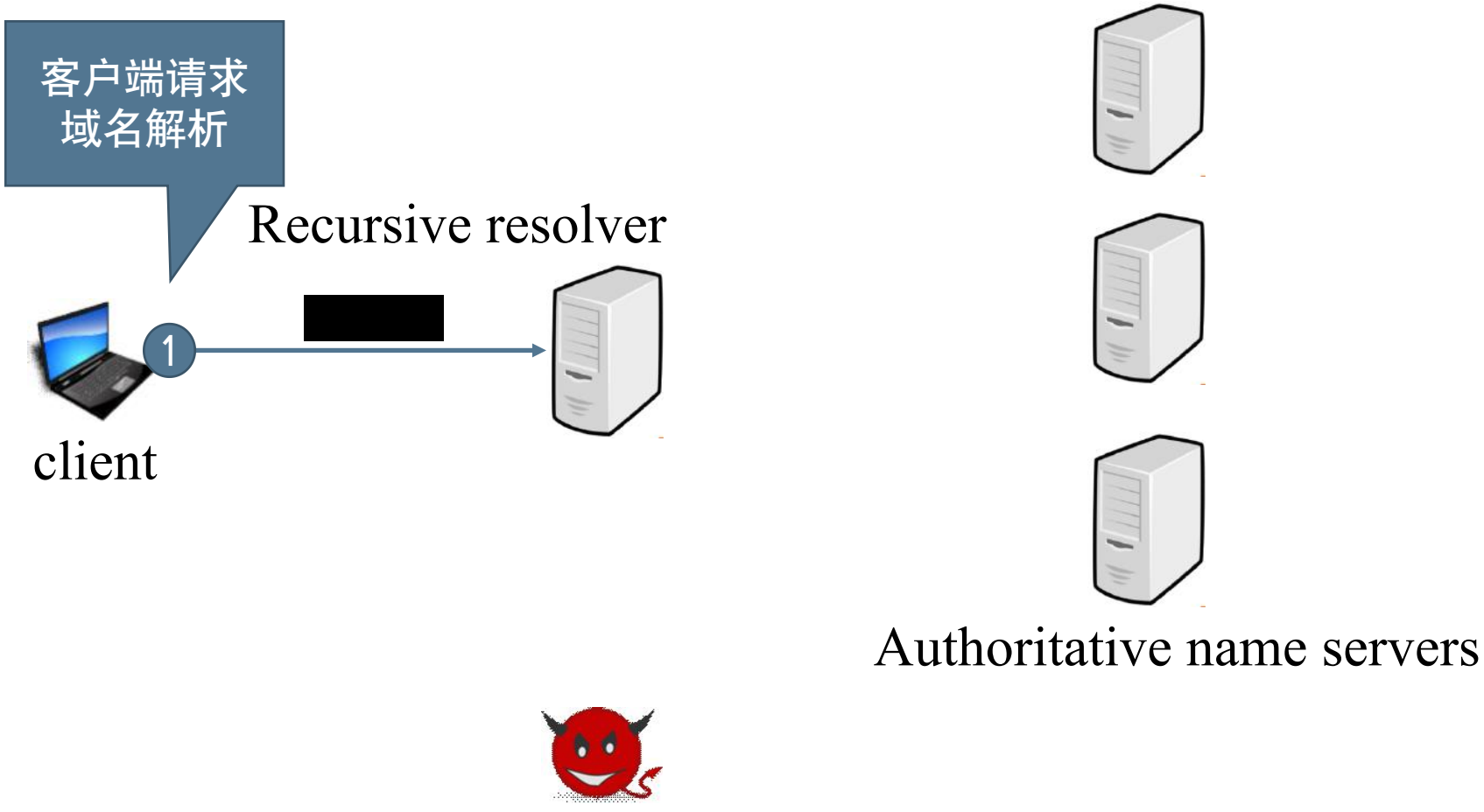




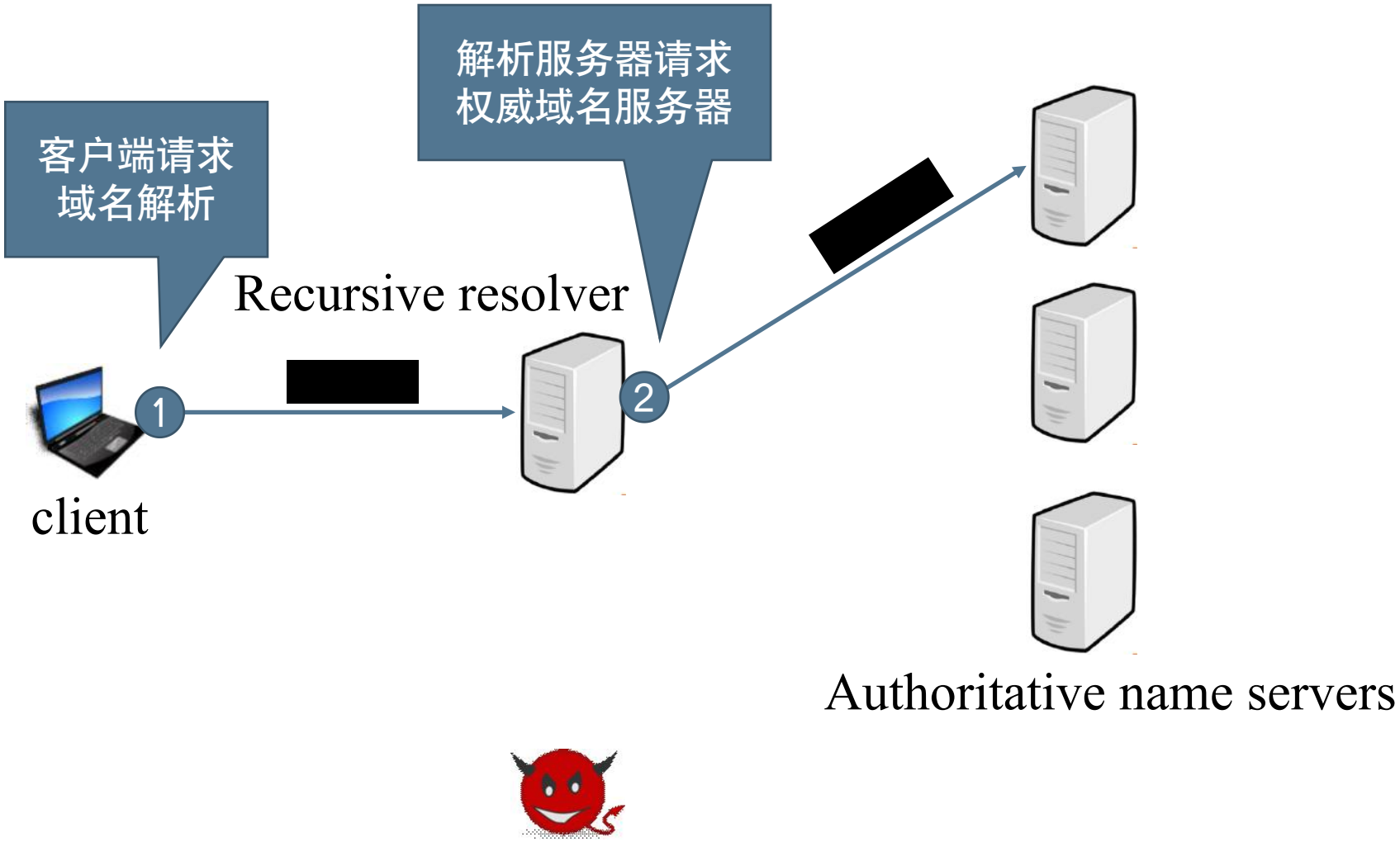
Authoritative name servers



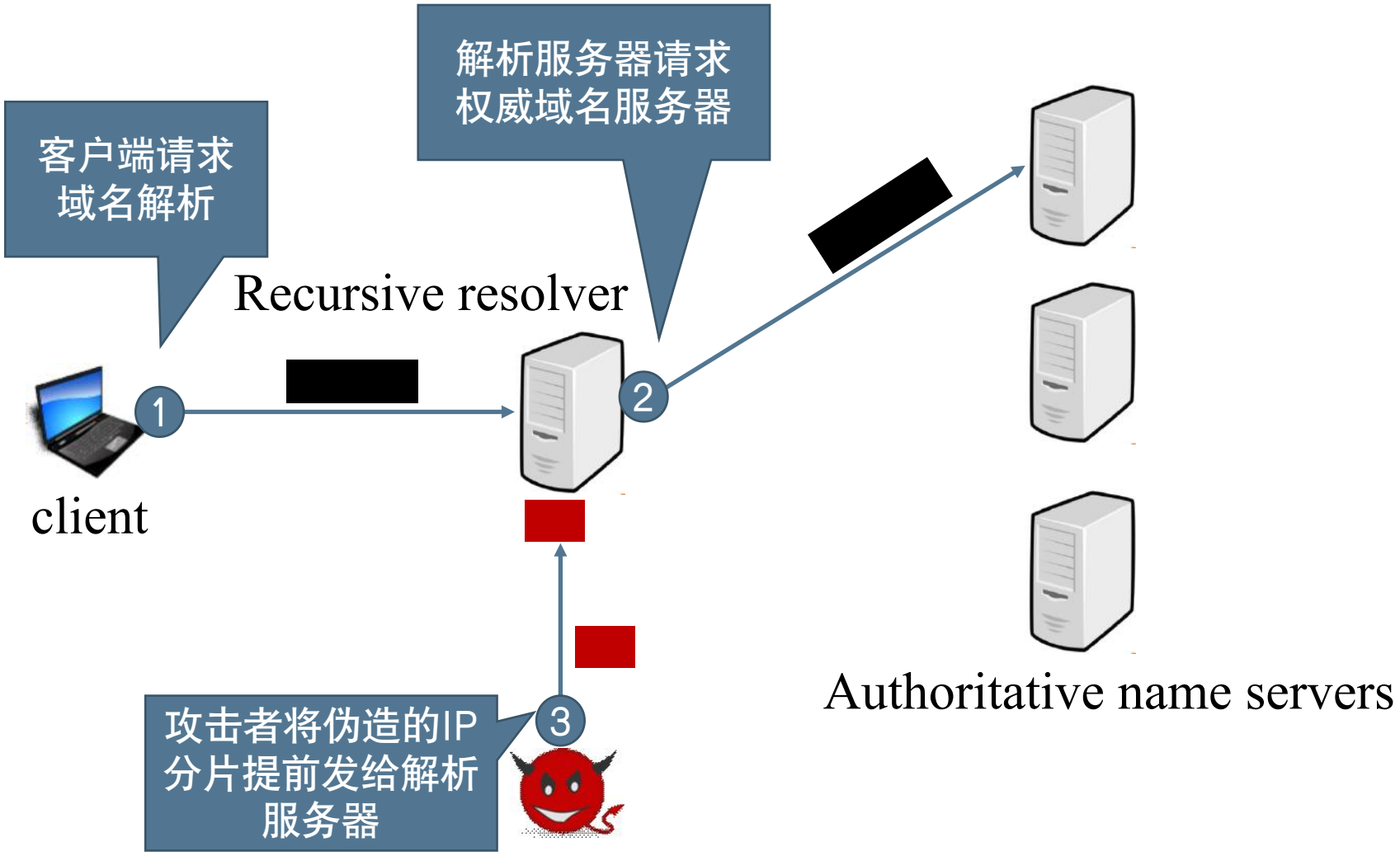
IP分片利用——DNS缓存污染攻击



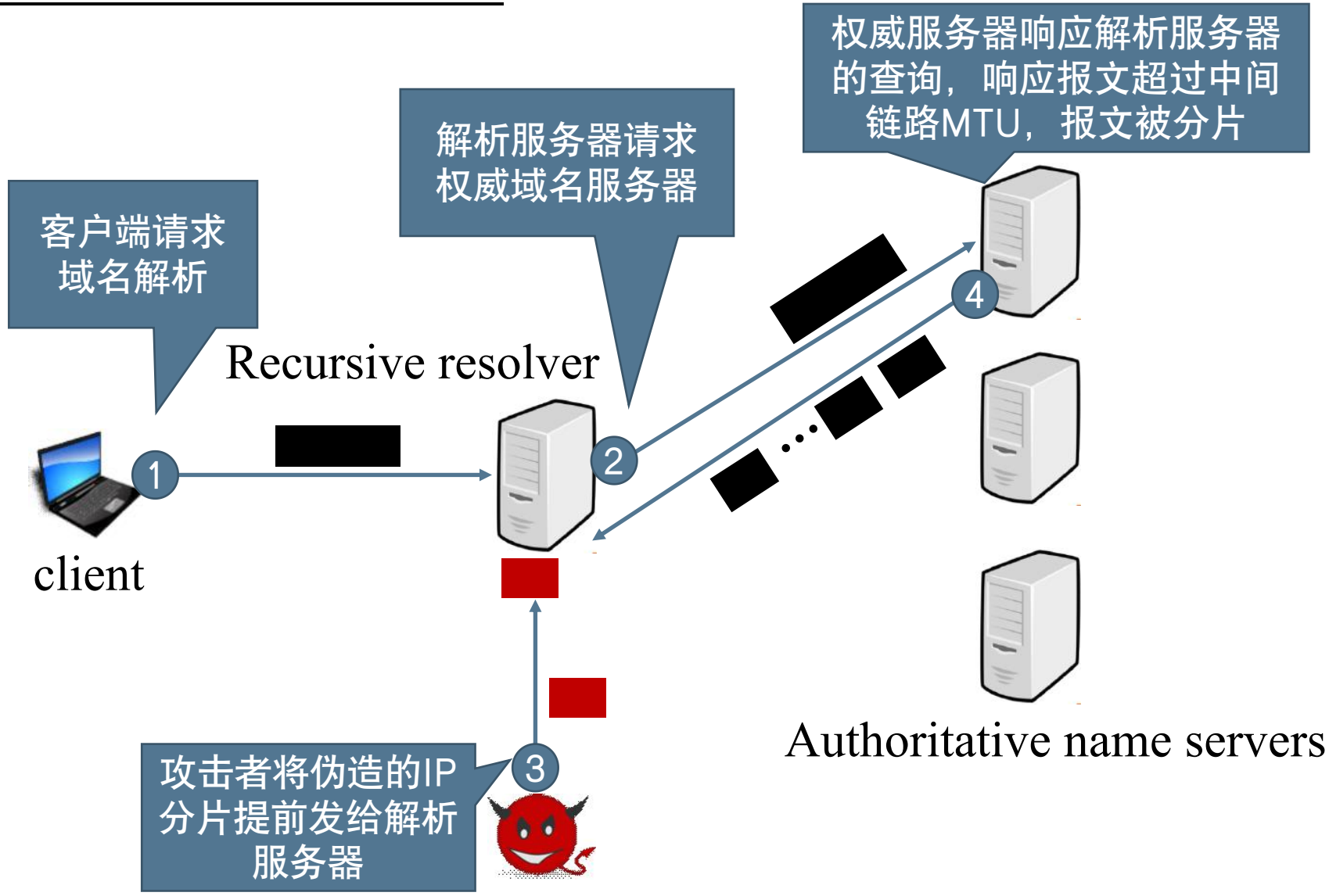
IP分片利用——DNS缓存污染攻击



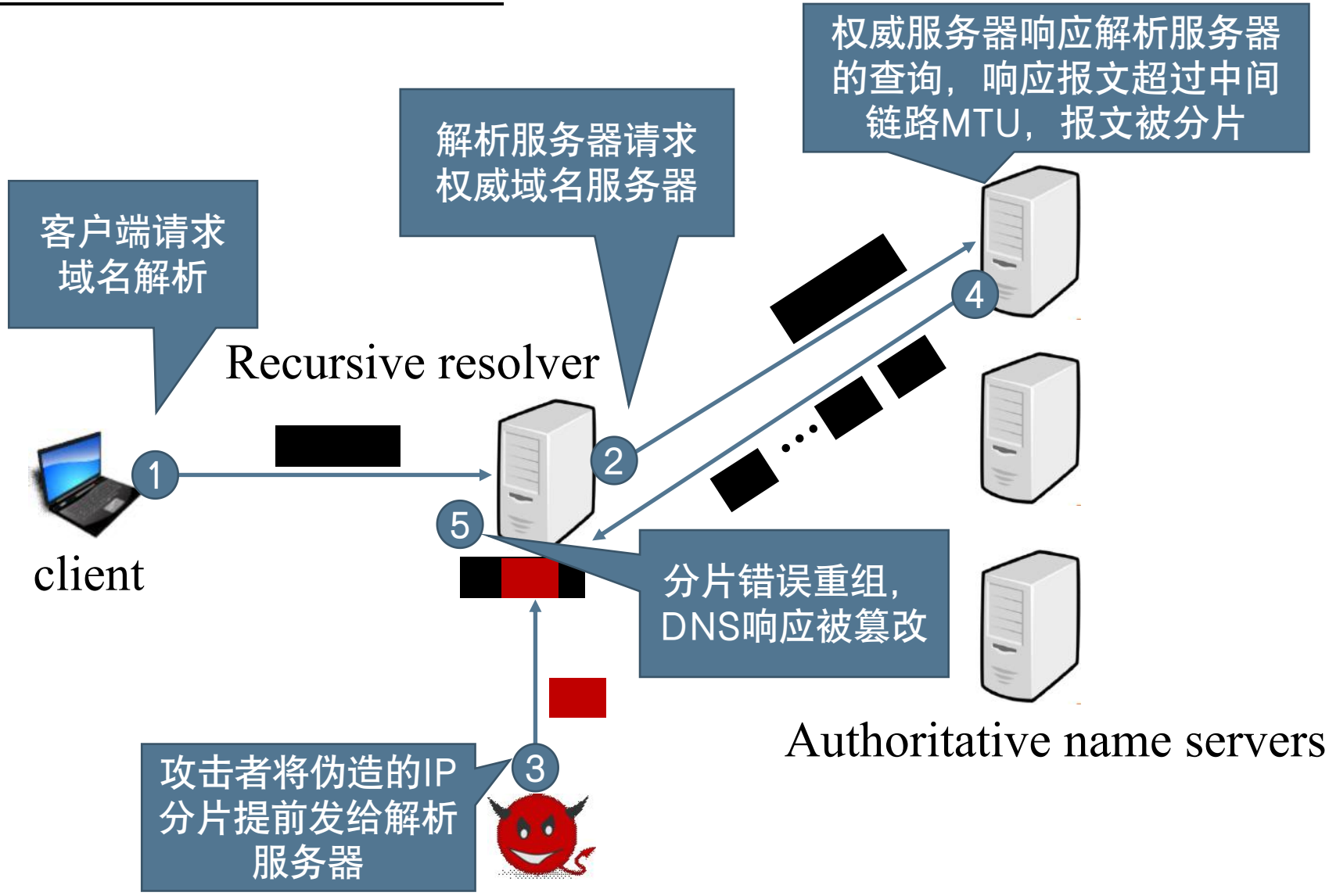
IP分片利用——DNS缓存污染攻击



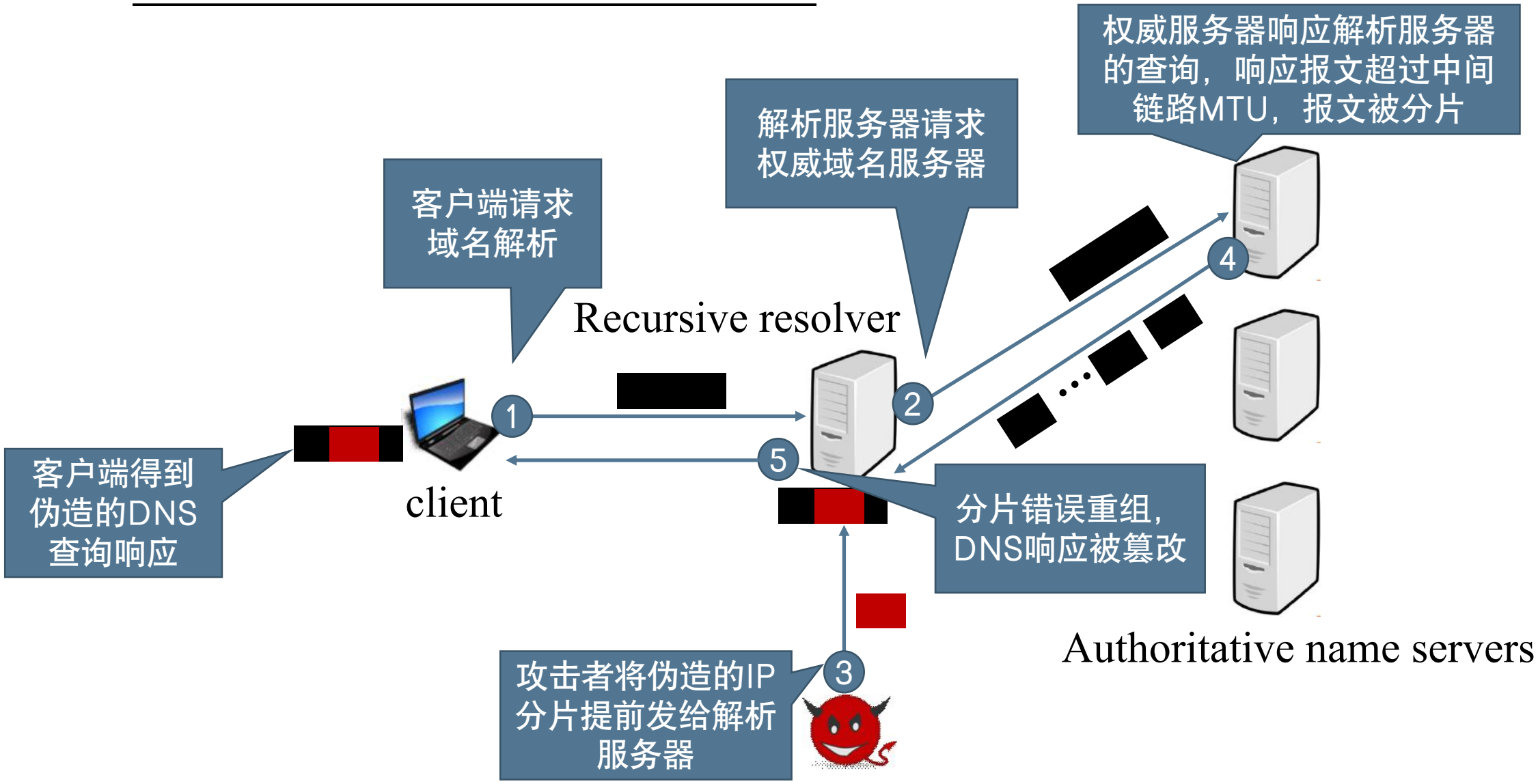
IP分片利用——DNS缓存污染攻击



IP分片利用——DNS缓存污染攻击



IP分片利用——DNS缓存污染攻击



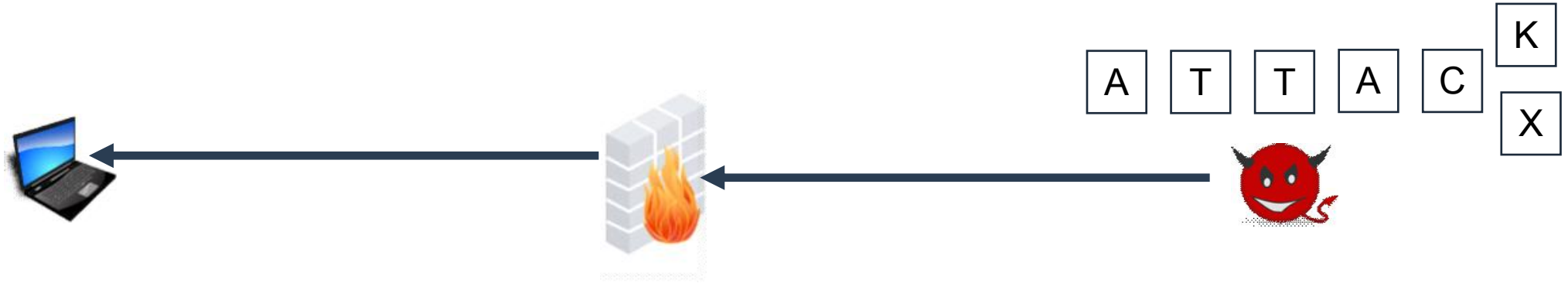
IP分片利用——DNS缓存污染攻击

Offsets	Octet	0								1								2								3							
Octet	Bit	0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25	26	27	28	29	30	31
0	0	v4				IHL = 20				TOS								Total Length = 85															
4	32	IPID = 23456																x	DF	MF	Frag Offset = 48											
8	64	TTL								Protocol = 17								IP Header Checksum															
12	96	Source IP = 2.2.2.2																															
16	128	Destination IP = 7.7.7.7																															
20	160	Data Length = 4																IPv4 Address															
24	192	6.6.6.6																Name = 0								Type							
28	224	= OPT								UDP Payload Size = 4096																EXTENDED-RCODE = 0							
32	256	Version = 0								DO	Z															Data Length							
36	288	= 0																															

利用IP分片，将域名的合法IP地址，篡改成攻击者控制的地址“6.6.6.6”，实现域名劫持

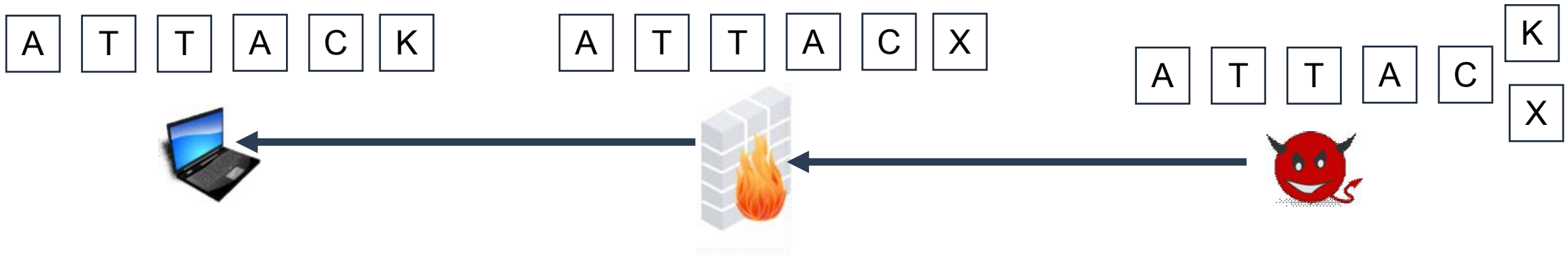
IP分片利用——安全策略逃逸

通常网络防火墙会对IP分片进行虚拟分片重组，审查其中的恶意载荷。但防火墙和接收端主机往往存在**重组策略不一致**现象，即当分片出现重叠时，二者可能会采用不同的覆盖策略



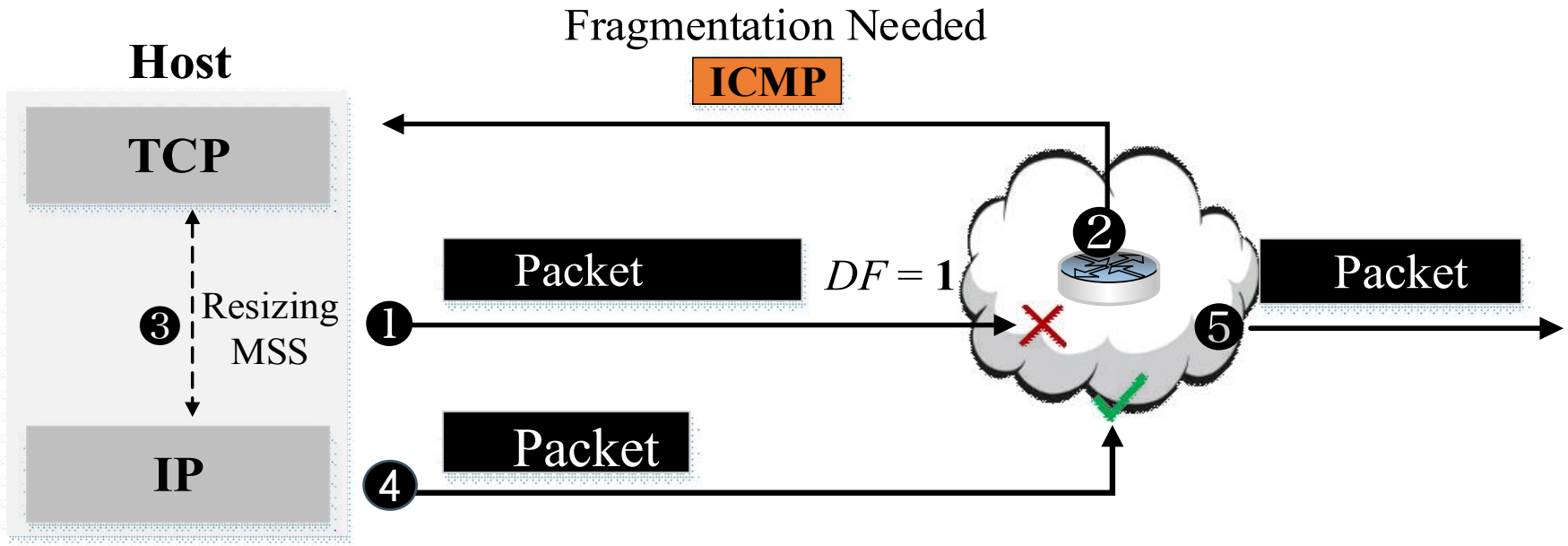
IP分片利用——安全策略逃逸

因此，攻击者可以通过设置合理的分片偏移，逃逸防火墙的审查，形成对接收端的破坏



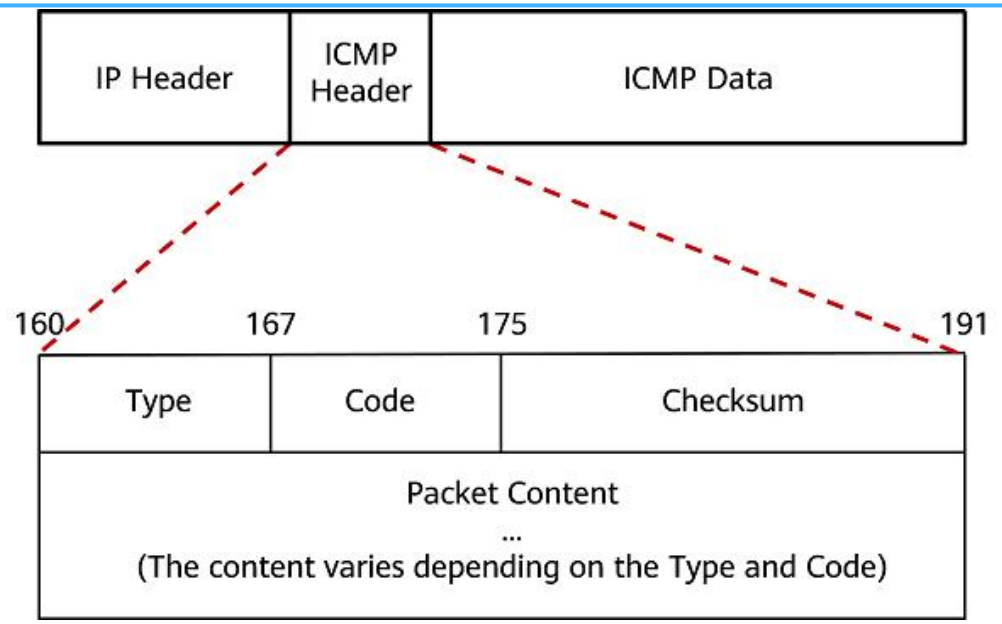
路径MTU发现机制

为了避免IP分片，一些相关技术标准也陆续被提出。例如，RFC1191定义了“**路径MTU发现（Path MTU Discovery，PMTUD）**”机制，该机制用于确定两台IP主机间的路径MTU



ICMP攻击原理

ICMP（Internet Control Message Protocol） 协议是在 RFC 792 中定义的互联网协议族之一， 也是互联网协议族的核心协议之一。ICMP 协议**用于发送控制消息**，提供可能发生在通信环境中的各种**问题反馈**，通过这些信息，网络管理员可以对所发生的问题做出诊断，然后采取适当的措施。



ICMP消息格式

- Type 0 – Echo reply
- Type 3 – Destination unreachable
- Type 5 – Redirect Message
- Type 8 – Echo Request
- Type 11 – Time Exceeded
- Type 12 – Parameter problem

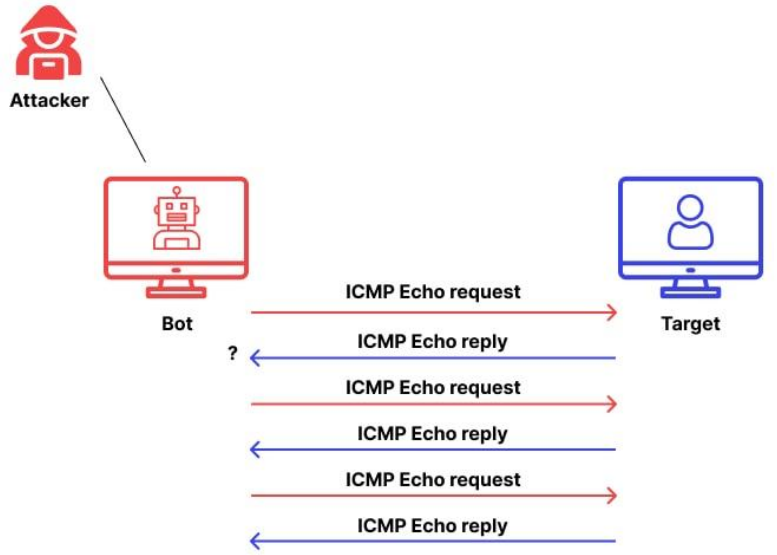
ICMP消息类型

ICMP攻击原理

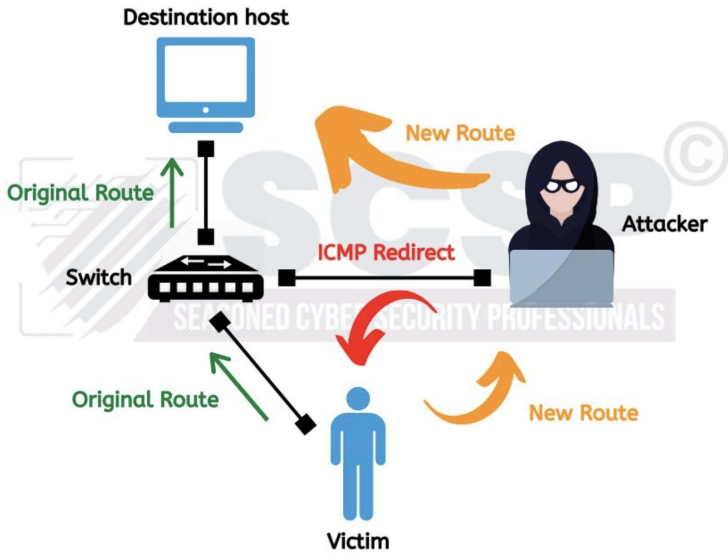
互联网缺乏对 ICMP 消息源和消息传输路径的安全验证，导致网络上的任何一个攻击者都可以冒充成中间路由器，发送伪造的 ICMP 控制消息给受害主机

ICMP攻击案例

ping flooding攻击：基于 ICMP 协议的 DDoS攻击，攻击者伪装成受害主机，**广播发送大量的 ping 请求**，然后短时间内受害主机就会收到大量的回复，**消耗主机资源**，主机资源耗尽后就会瘫痪或者无法提供其他服务



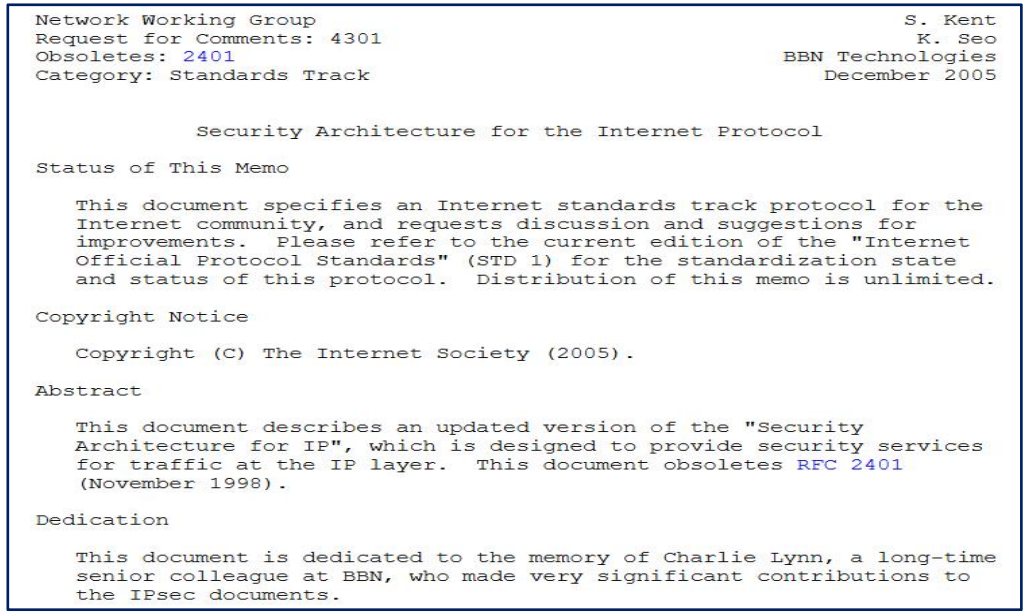
ICMP 重定向攻击：基于 ICMP 重定向消息缺乏合理性验证而产生，远程攻击者能够**伪造 ICMP 重定向消息**，诱导目标主机将流量重定向至无效地址，**造成拒绝服务**（DoS），此外，攻击者还能在 NAT 网络中利用此机制**执行中间人（MITM）攻击**，拦截并篡改网络流量



网络层防御

安全防御——IPSec协议

- IPSec (Internet Protocol Security，RFC4301)，即Internet协议安全性，是一种开放标准的框架结构，通过对IP协议的分组进行**加密和认证**，来保护基于IP协议的网络传输
- 在 IPv4 中， IPSec 的使用是一个可选项，在 IPv6 （RFC 6434 ）中，初始设为必选项，未来随着 IPv6 的进一步流行，IPSec 可以得到更为广泛的使用



Network Working Group — S. Kent
Request for Comments: 4301 — K. Seo
Obsoletes: 2401 — BBN Technologies
Category: Standards Track — December 2005

Security Architecture for the Internet Protocol

Status of This Memo

This document specifies an Internet standards track protocol for the Internet community, and requests discussion and suggestions for improvements. Please refer to the current edition of the "Internet Official Protocol Standards" (STD 1) for the standardization state and status of this protocol. Distribution of this memo is unlimited.

Copyright Notice

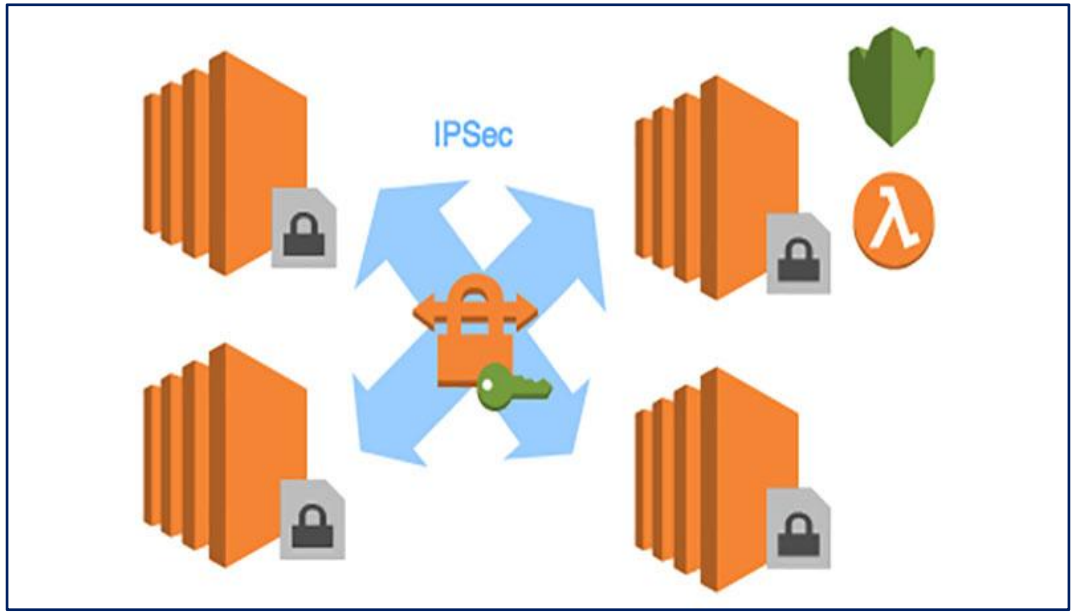
Copyright (C) The Internet Society (2005).

Abstract

This document describes an updated version of the "Security Architecture for IP", which is designed to provide security services for traffic at the IP layer. This document obsoletes RFC 2401 (November 1998).

Dedication

This document is dedicated to the memory of Charlie Lynn, a long-time senior colleague at BBN, who made very significant contributions to the IPsec documents.

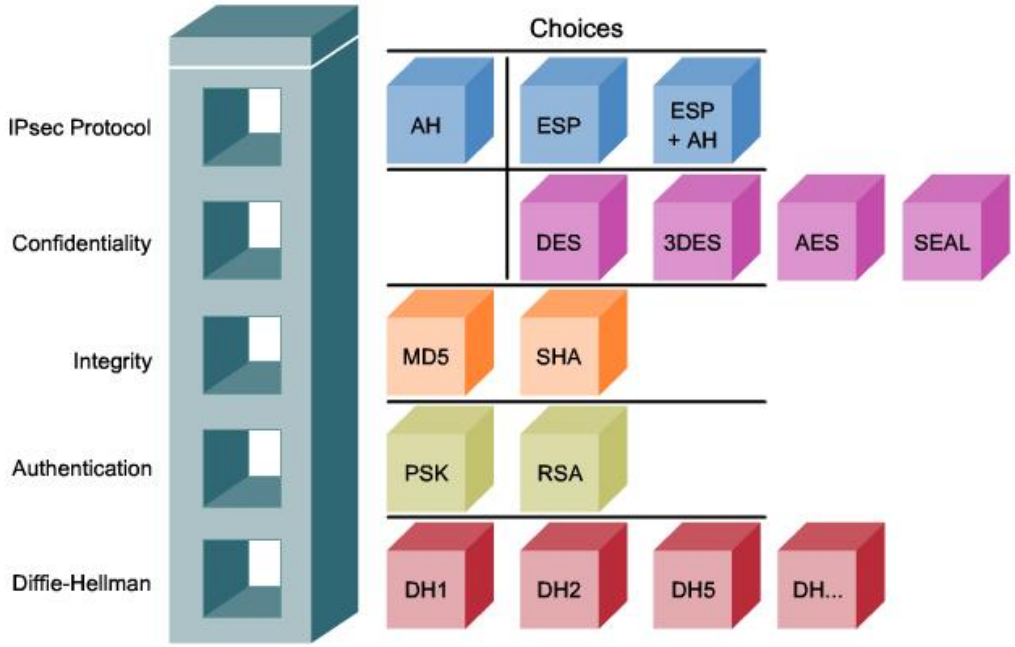


IPSec协议

IPSec协议工作在TCP/IP协议的第三层，使其在使用时可以保护基于IP协议的所有上层协议

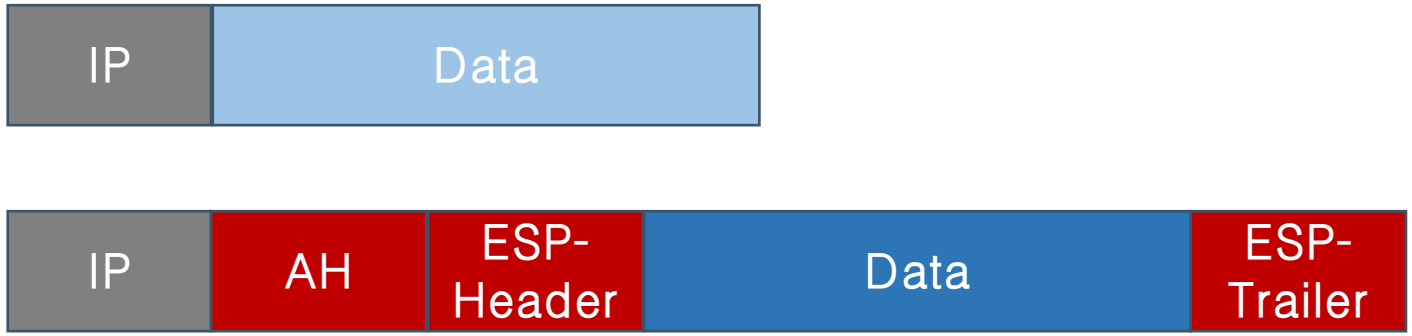
IPSec提供了两种安全机制：

- **认证**，采用IPSec的Authentication Headers，AH
- **加密**，采用IPSec的Encapsulating Security Payloads，ESP



IPSec协议

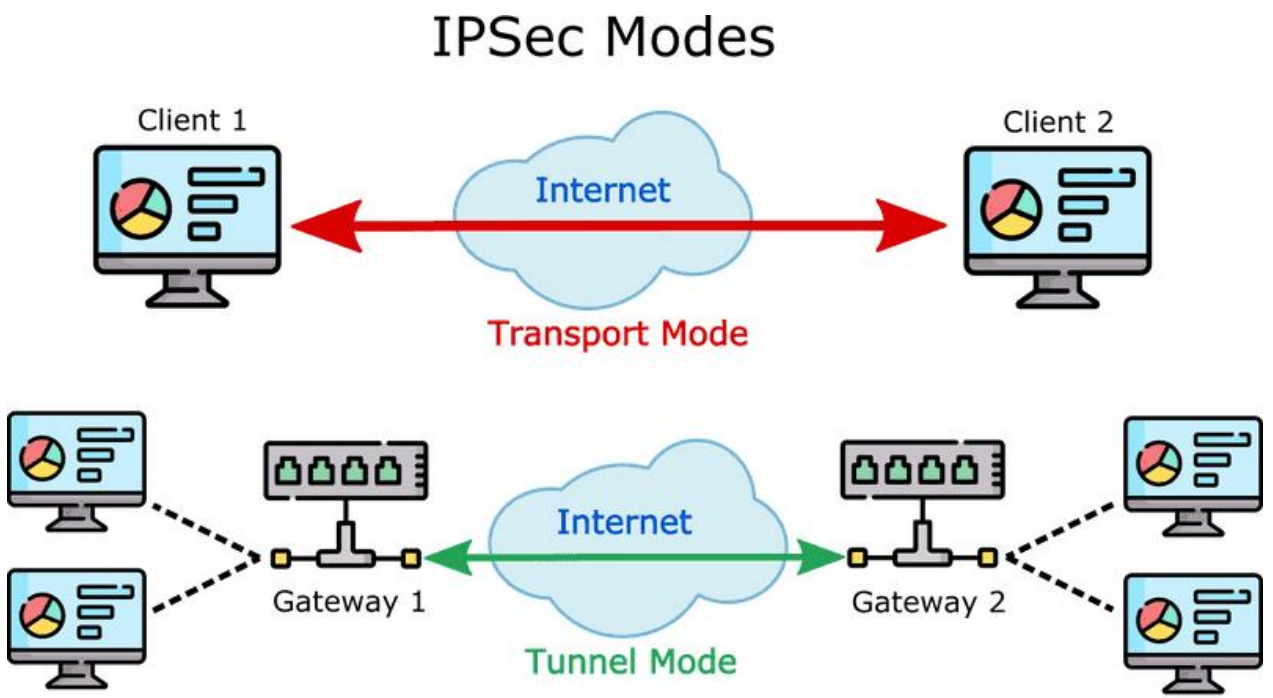
- 在实际进行IP通信时，可以根据实际安全需求同时使用这两种协议或选择使用其中的一种
- 同时使用AH和ESP时，设备支持的AH和ESP联合使用的方式为：先对报文进行ESP封装，再对报文进行AH封装
- 封装之后的报文从内到外依次是原始IP报文、ESP头、AH头和外部IP头



IPSec协议

IPSec的两种工作模式：

- **传输（transport）模式**：只是传输层数据被用来计算AH或ESP头，AH或ESP头以及ESP加密的用户数据被放置在原IP包头后面
- **隧道（tunnel）模式**：用户的整个IP数据包被用来计算AH或ESP头，AH或ESP头以及ESP加密的用户数据被封装在一个新的IP数据包中



IPSec协议

传输模式

- 主要用于主机和主机之间，端到端通信的数据保护
- 封装方式：不改变原有的IP包头，在原数据包头后面插入IPSec包头，只封装数据部分



隧道模式

- 主要用于私网与私网之间，通过公网进行通信，建立安全VPN通道
- 封装方式：增加新的IP（外网IP）头，其后是IPSec包头，之后再将原来的整个数据包封装



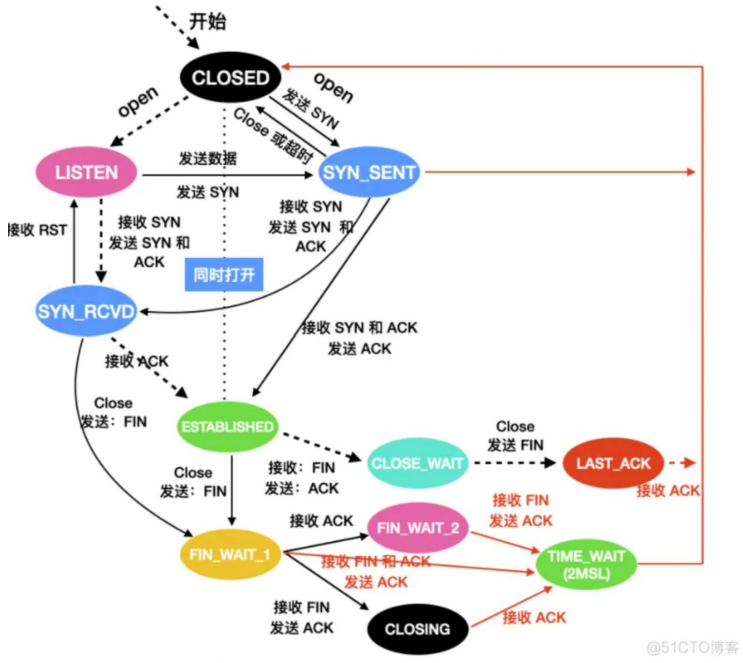
传输层安全

传输层功能

传输层主要负责提供不同主机应用程序进程之间的端到端的服务

传输层的基本功能如下：

- 可靠传输
- 按端口号寻址
- 连接管理
- 拥塞控制和流量控制



常见的传输层协议主要包括两类：

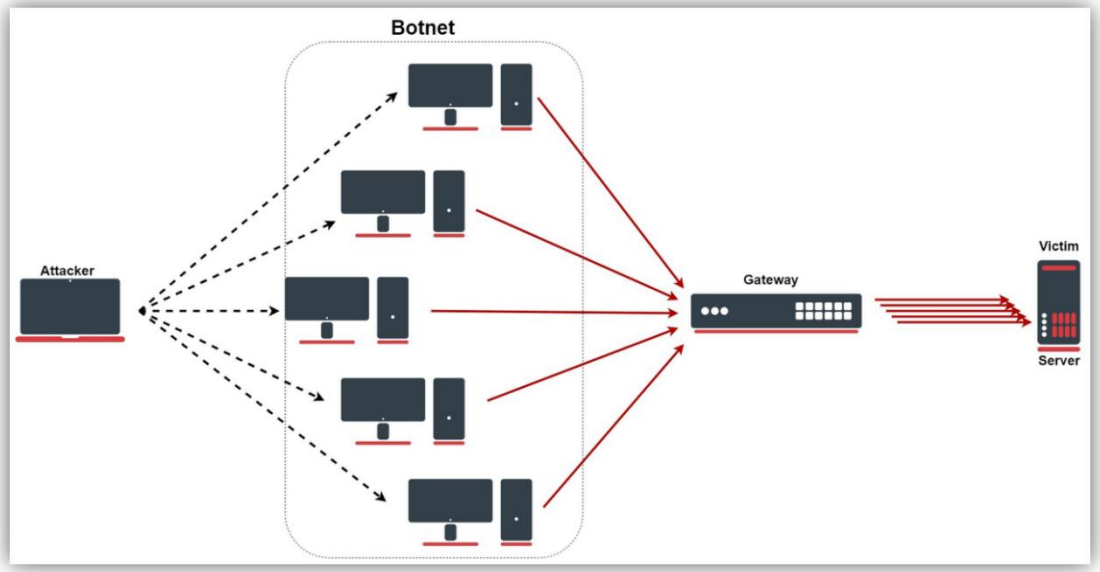
TCP（Transmission Control Protocol）：面向连接、提供可靠传输

UDP（User Datagram Protocol）：非面向连接、不提供可靠传输

拒绝服务攻击

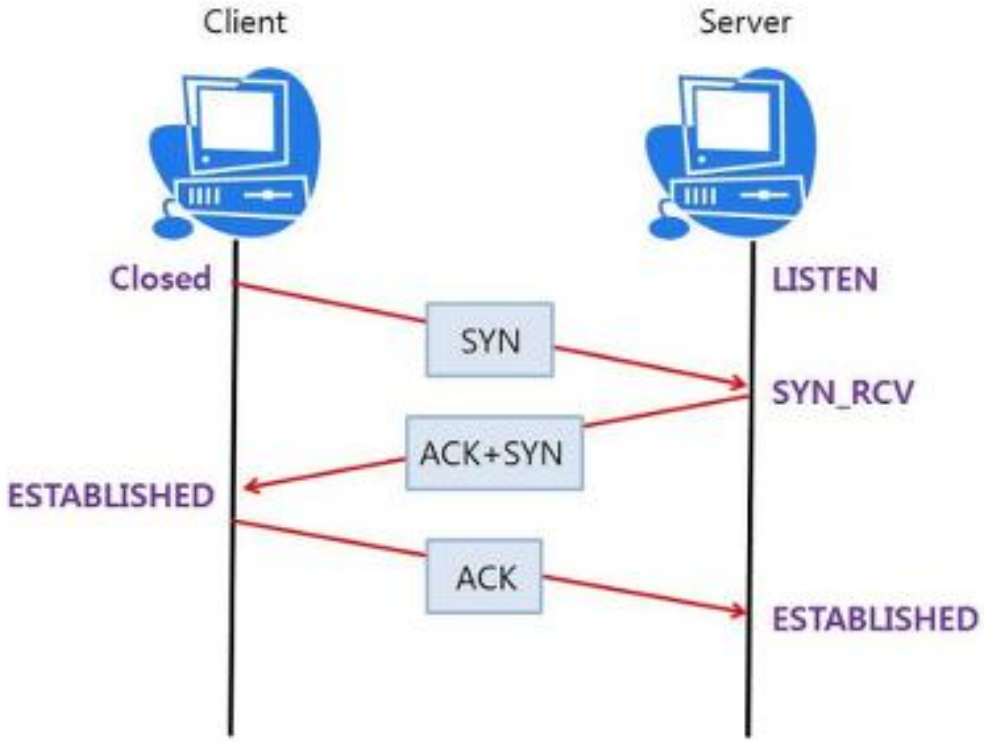
拒绝服务攻击（Denial of Service，DoS）是指通过大量无效请求使目标系统无法正常提供服务，使得其可用性降低或者失去可用性的攻击方式。例如一个计算机系统崩溃，或其带宽耗尽，或其硬盘被填满，导致其不能提供正常的服务，就构成拒绝服务攻击。





拒绝服务攻击——SYN Flooding

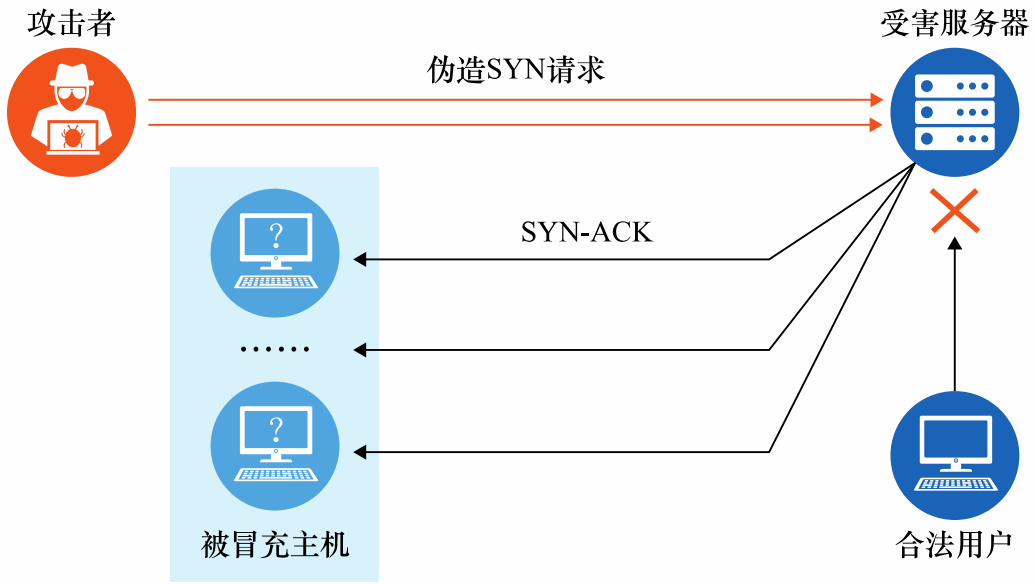
SYN Flooding是针对TCP协议主要的DoS攻击方式之一，通过发送大量伪造的TCP连接请求，使被攻击方资源耗尽，CPU满负荷或内存不足，一般发生在TCP协议中的三次握手（Three-way Handshake）阶段



拒绝服务攻击——SYN Flooding

攻击步骤：

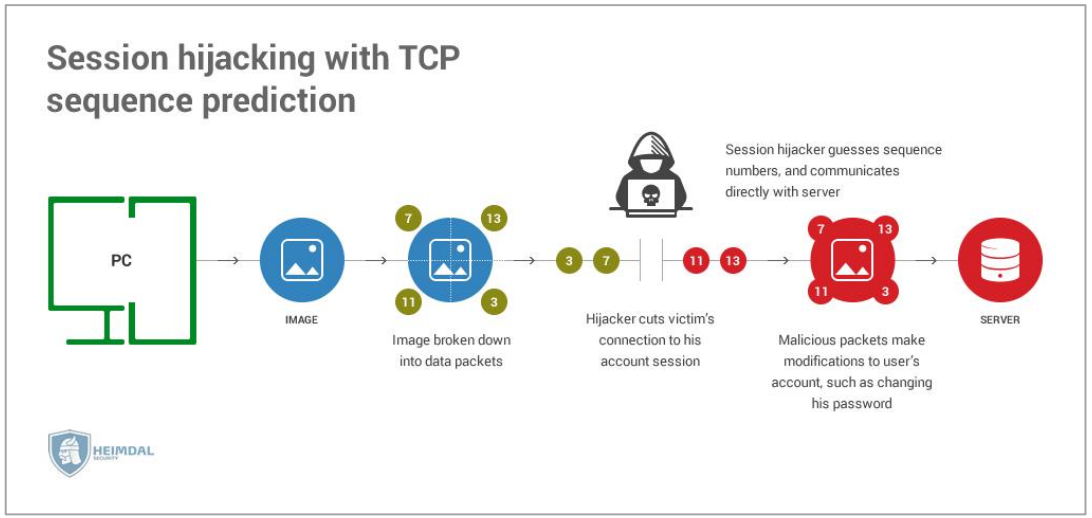
- 攻击者向目标服务器发送大量**伪造的SYN数据包**，通常会使用欺骗性的IP地址
- 服务器响应每个连接请求，并分配存储和计算资源（TCB），维护半连接状态
- 攻击者继续发送更多的SYN数据包，消耗服务器资源，最终服务器资源耗尽，无法正常工作



TCP Control Block

TCP劫持攻击

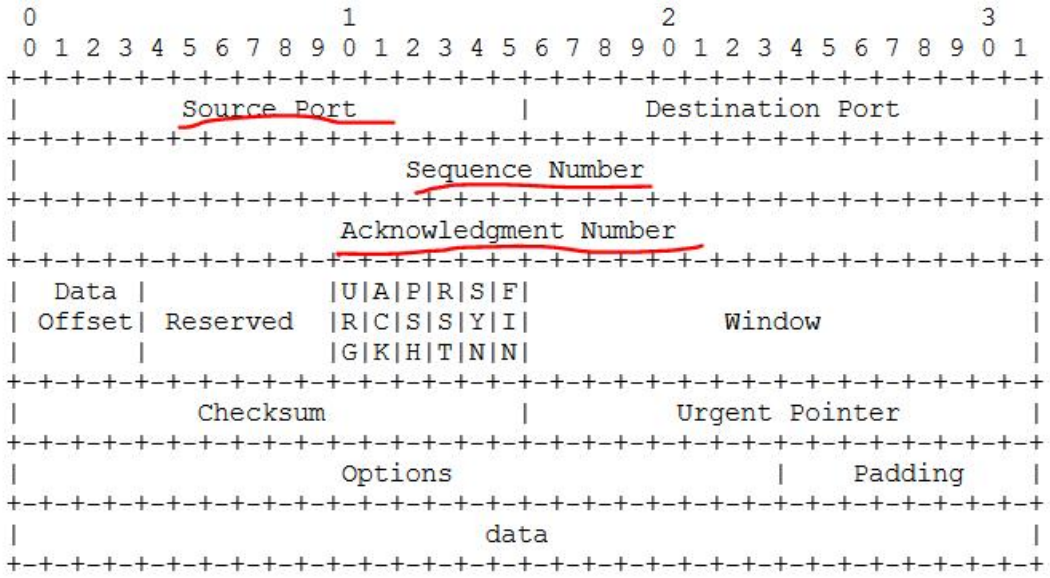
- 相比较针对TCP的DoS攻击，针对TCP的劫持攻击是一种更高级、更隐蔽、危害也更大的攻击方式
- TCP劫持攻击是指，一个TCP连接外的的非法攻击者（即Client和Server之外的一个Attacker），将自己伪造的TCP报文，注入到TCP连接双方的合法数据流中，进而对连接进行攻击破坏，包括：
  - 伪造控制报文（如RST报文等），恶意**阻断该连接**
  - 伪造数据报文，**污染数据流**



TCP劫持攻击

TCP协议的实现引入了32位随机的序列号和确认号，以及16位随机的源端口号

因此攻击者要成功地将恶意报文注入到目标TCP流中，**必须正确预测这些值**



如果采用**暴力猜测**的办法，要求攻击者的报文发送能力大约在**300M个/秒**，这在实际环境中，显然很难成功实施，也很容易触发IDS等安全检测设备

TLS协议及发展历史

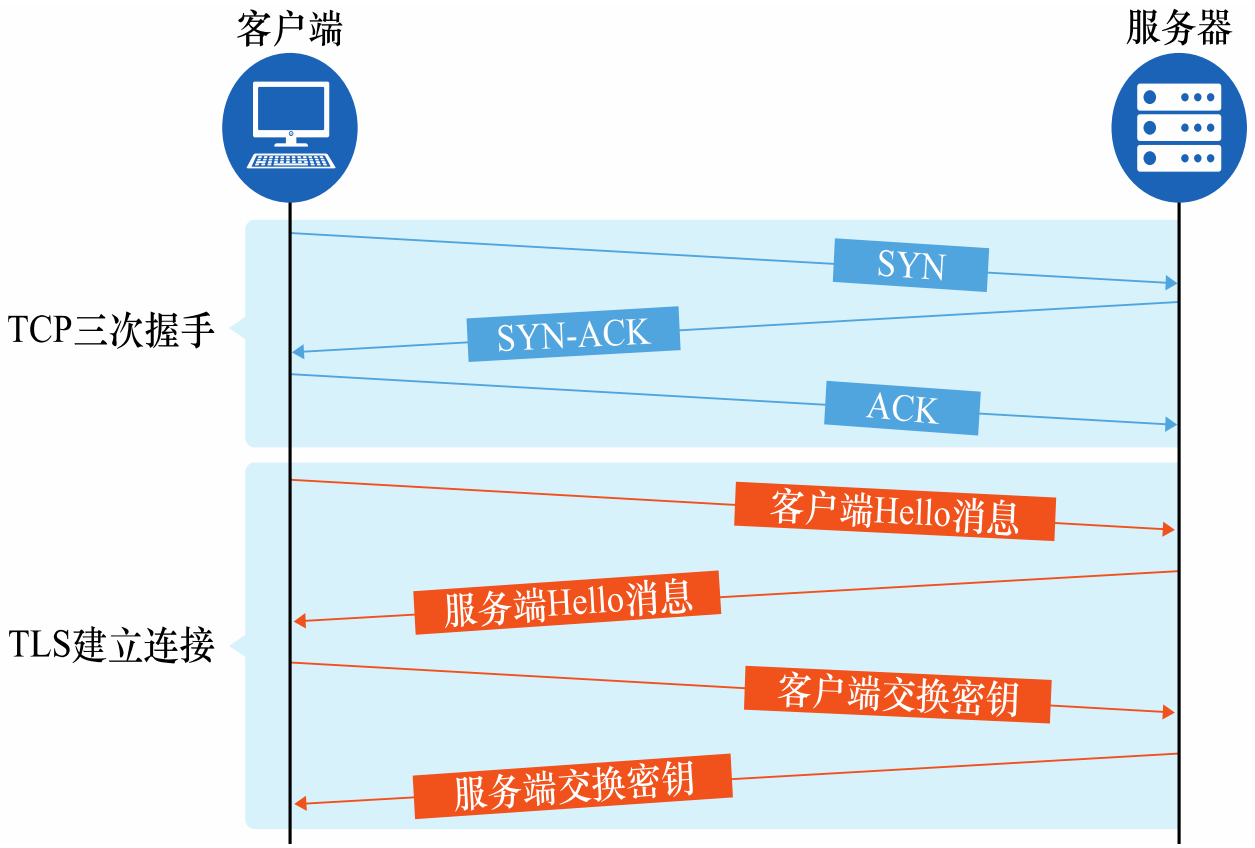
传输层安全性协议（Transport Layer Security, TLS）及其前身安全套接层协议（Secure Sockets Layer, SSL）是一种广泛采用的安全性协议，旨在促进 Internet 上通信的隐私和数据安全性

- 1994年，NetScape公司设计了SSL协议（Secure Sockets Layer）的1.0版，但是未发布
- 1995年，NetScape公司发布SSL 2.0版，很快发现有严重漏洞
- 1996年，SSL 3.0版问世，得到大规模应用
- 1999年，互联网标准化组织IETF接替NetScape公司，发布了SSL的升级版TLS1.0版
- 2006年和2008年，TLS进行了两次升级，分别为TLS 1.1版和TLS 1.2版
- 2011年，TLS 1.2修订版发布
- 2018年，TLS 1.3发布





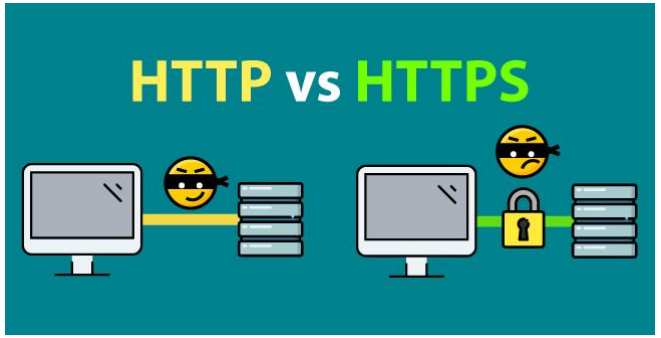
TLS协议工作过程

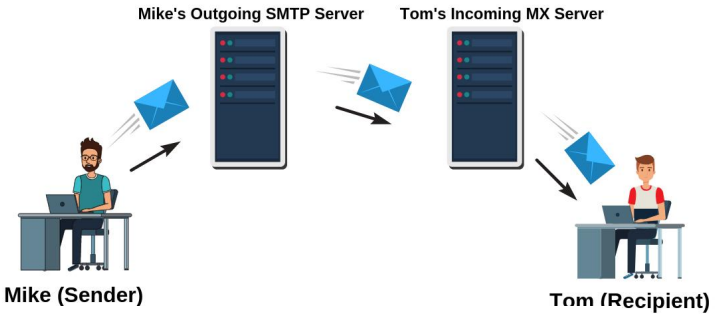

客户端
服务器
TCP三次握手
SYN
SYN-ACK
ACK
TLS建立连接
客户端Hello消息
服务端Hello消息
客户端交换密钥
服务端交换密钥

TLS协议功能及应用

TLS 协议通常在TCP等传输层协议之上运行，提供以下三个安全功能：

- **加密**：阻止第三方对传输数据的窃听
- **身份验证**：确保交换信息的各方是他们声称的身份
- **完整性**：验证数据是否伪造而来或未遭篡改过





广泛应用：

TLS是目前采用最广泛的一种安全性协议，应用于多个网络场景，如：对Web 应用程序和服务器之间的通信进行加密保护，还可用于电子邮件、消息传递和 IP 语音（VoIP）加密等



6.2 常见网络攻击类型

常见网络攻击

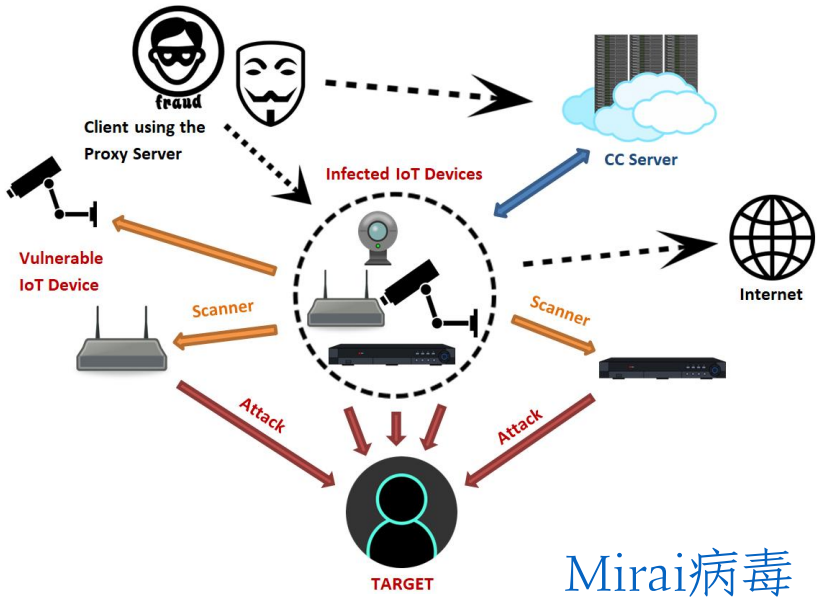
分类	攻击类型	原理 / 手段	目标 / 影响	示例
网络层攻击	DDoS / DoS	向服务器发送大量请求，耗尽资源	服务瘫痪、无法响应合法请求	SYN Flood, UDP Flood
	IP 欺骗 (IP Spoofing)	伪造源 IP 地址绕过过滤	冒充可信主机、配合 DDoS 使用	伪造源地址的 UDP flood
	嗅探 (Sniffing)	监听网络数据包	获取密码/敏感数据	Wireshark 中的 packet capture
	ARP 欺骗	伪造 ARP 响应劫持流量	中间人攻击、流量篡改	ARP Poisoning
	DNS 欺骗 / 污染	篡改 DNS 解析结果	重定向到恶意网站	DNS Cache Poisoning
	中间人攻击 (MITM)	截获并篡改通信	获取敏感信息、伪造身份	HTTPS 被降级攻击
应用层攻击	SQL 注入、XSS、CSRF、文件上传漏洞、远程代码执行（RCE）、目录遍历			
主机层攻击	暴力破解/字典攻击	大量尝试密码组合	登录突破、服务入侵	SSH 爆破
	缓冲区溢出攻击	覆盖内存、控制执行流程	提权、执行 Shellcode	stack overflow exploit
	恶意软件攻击	利用病毒/木马/蠕虫	系统破坏、窃取数据	WannaCry、木马后门
	键盘记录 (Keylogger)	记录用户输入	密码/隐私泄露	本地或浏览器键记录器
无线网络攻击	Wi-Fi 嗅探	捕获无线流量	获取密码、监听通信	WPA Handshake crack
	Evil Twin	伪造 WiFi 热点	钓鱼、窃取凭证	Fake AP
	蓝牙攻击	漏洞利用或暴力连接	数据窃取、设备控制	BlueBorne
社会工程学攻击	钓鱼攻击 (Phishing)	伪造可信网站/邮件	盗取账号密码	钓鱼邮件、伪造银行网站
	欺骗 (Impersonation)	冒充技术支持或管理员	获取敏感信息	假冒客服
	诱骗下载 (Malvertising)	恶意广告诱导下载恶意文件	植入木马或勒索软件	恶意广告安装器
	垃圾邮件攻击	大量恶意邮件轰炸	欺诈、传播恶意链接	Spam campaigns

网络层面攻击

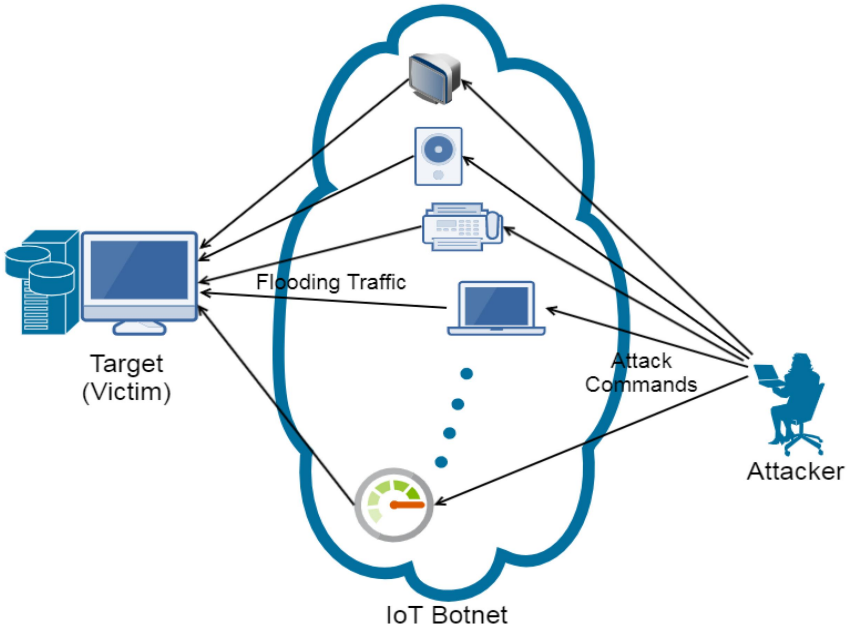
DDoS攻击

攻击者通过控制分布式的受害主机，建立僵尸网络（Botnet），通过僵尸网络节点对DDoS攻击的对象进行攻击，常见攻击方式分为两种：

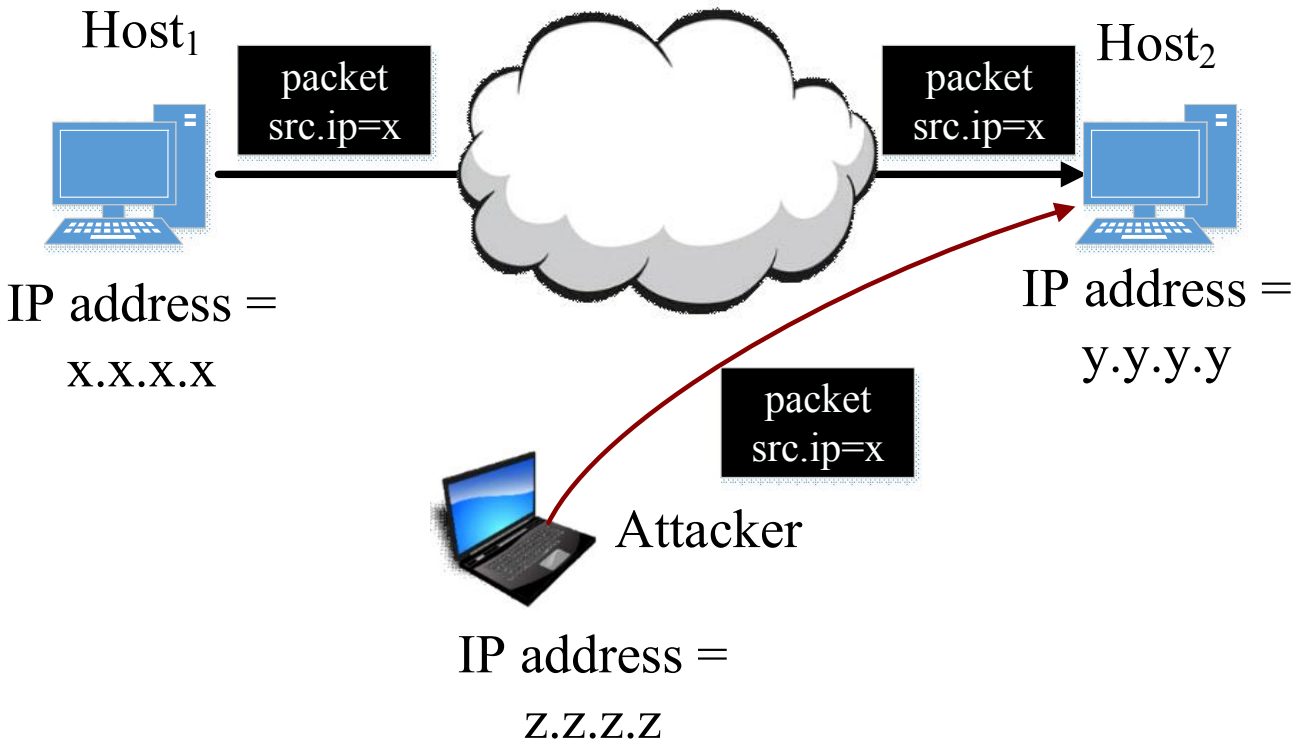
- 直接攻击：直接或反射式向目标发送大量数据包
- 间接攻击：链路泛洪攻击（Crossfire攻击和Coremelt攻击）



Mirai病毒



IP欺骗

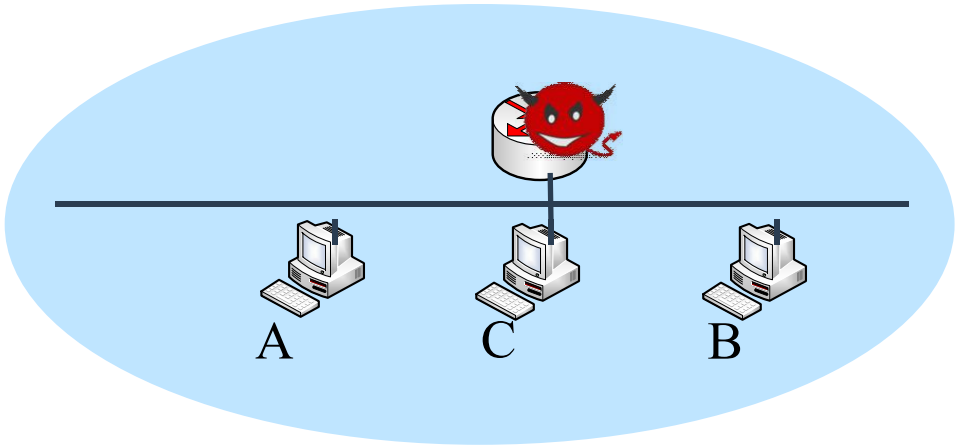

Host1
packet
src.ip=x
packet
src.ip=x
Host2
IP address =
x.x.x.x
IP address =
y.y.y.y
packet
src.ip=x
Attacker
IP address =
z.z.z.z

嗅探

恶意的网络嗅探，取决于攻击者的位置和攻击能力：

- 共享网络传输链路场景下，攻击者的恶意嗅探监听
- 攻击者控制了关键节点网络设备，对流经的流量进行拦截嗅探

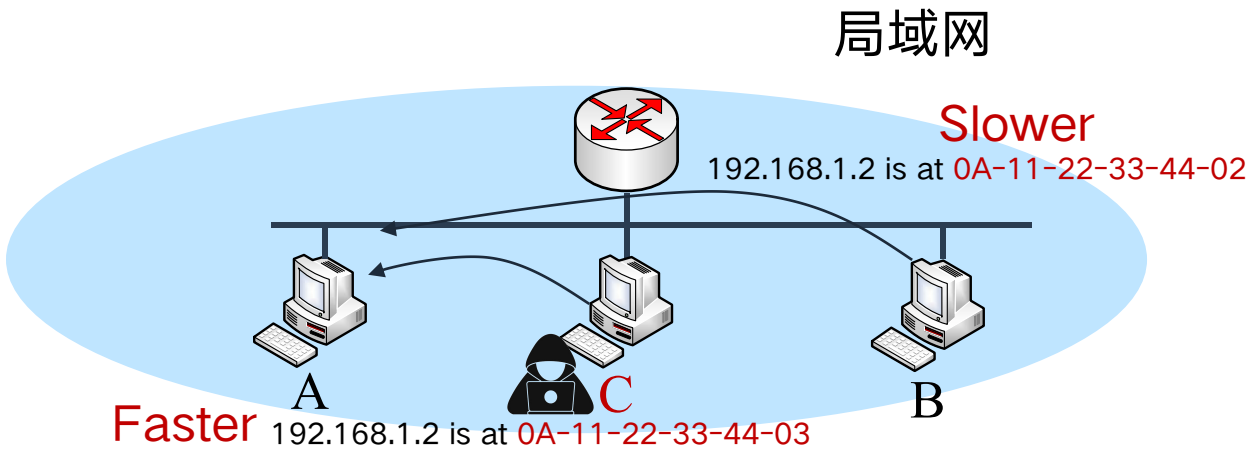




ARP欺骗

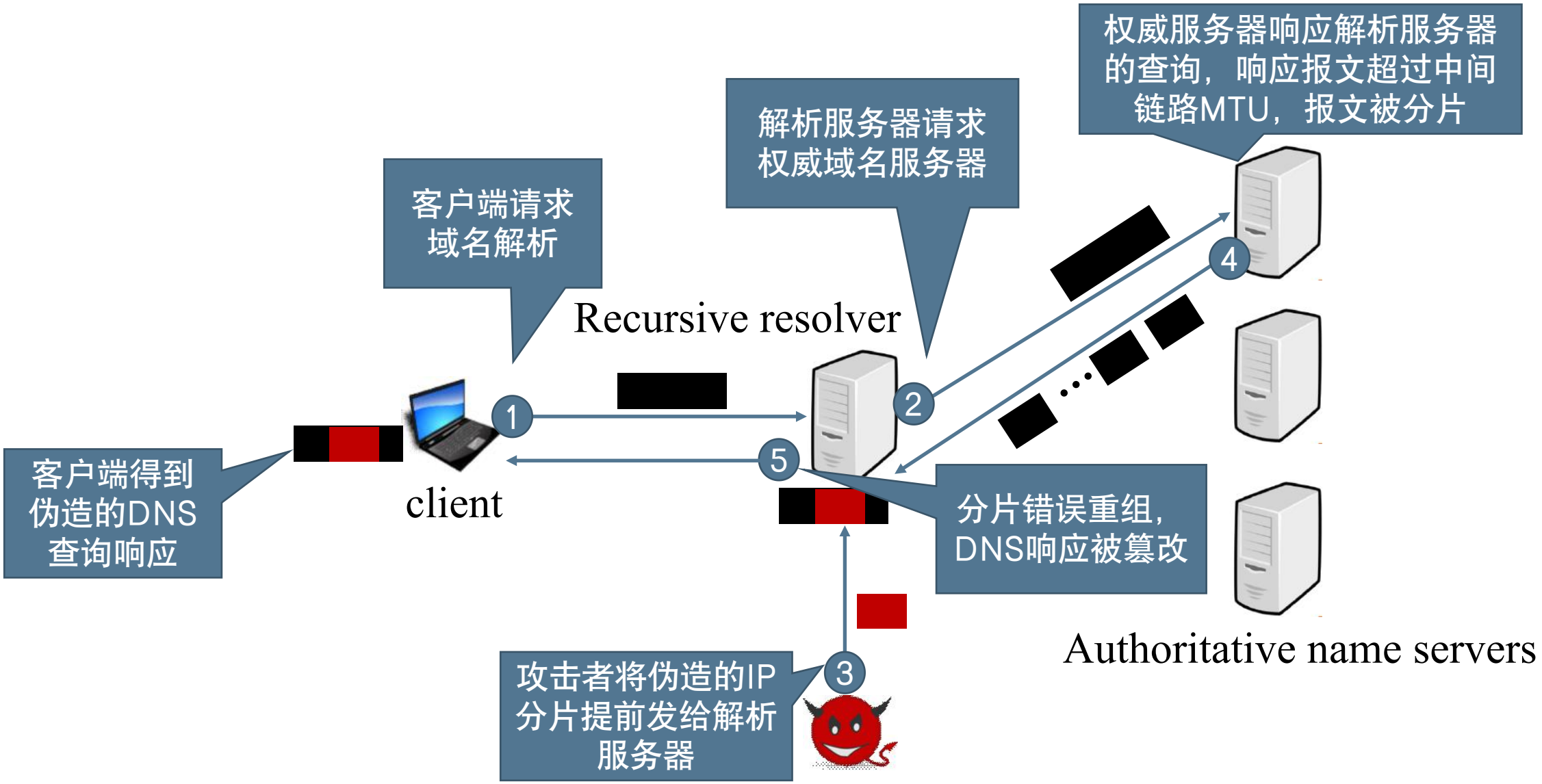
恶意节点C进行ARP欺骗，污染攻击A的ARP缓存：

ARP欺骗攻击的根本原因：缺乏对ARP响应消息的认证、完整性校验等安全机制



ARP表	主机	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
		192.168.1.2	0A-11-22-33-44-03
	B	192.168.1.2	0A-11-22-33-44-02
		192.168.1.1	0A-11-22-33-44-01
	C	192.168.1.3	0A-11-22-33-44-03

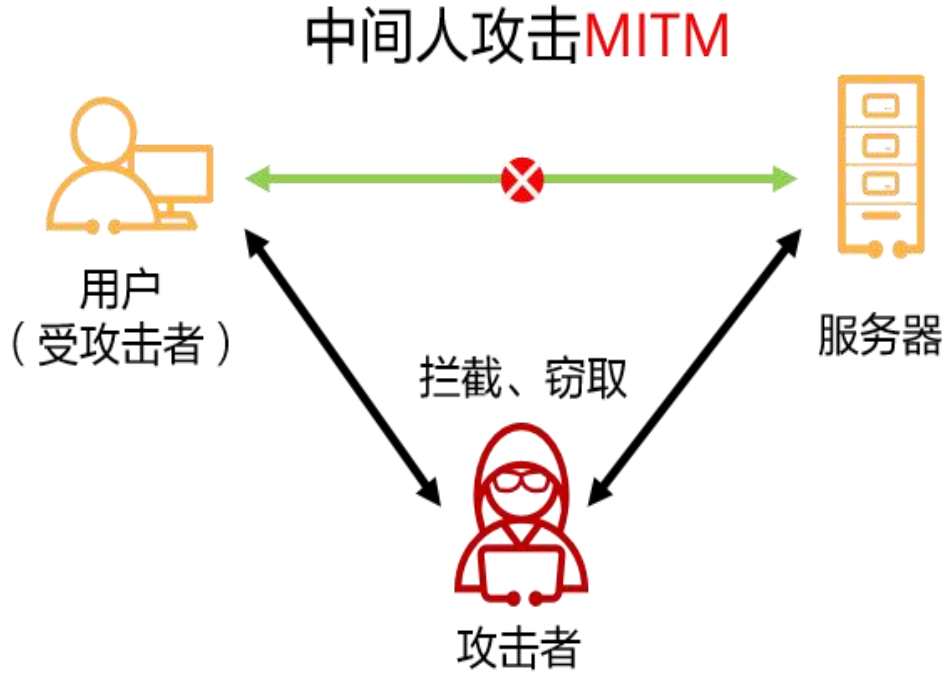
DNS欺骗


权威服务器响应解析服务器的查询，响应报文超过中间链路MTU，报文被分片
解析服务器请求权威域名服务器
客户端请求域名解析
Recursive resolver
1
2
3
4
5
客户端得到伪造的DNS查询响应
client
分片错误重组，DNS响应被篡改
攻击者将伪造的IP分片提前发给解析服务器
Authoritative name servers

中间人攻击

中间人攻击是指攻击者在通信双方之间插入自己，充当通信的中间人。攻击者可以读取、修改或转发数据，而通信双方却浑然不觉。可通过多种攻击方式实现：

- ARP欺骗攻击
- DNS欺骗攻击
- TCP劫持攻击
- HTTPs/TLS拦截攻击



主机层攻击

暴力破解/字典攻击

1、从数据库获取密码，解密
2、窃听通信数据数据，解密
3、直接从登录框猜测密码

[攻防演练中攻击方的思考]

不安全的密码：

- 默认密码
  - https://www.routerpasswords.com/
  - https://cirt.net/passwords/
  - https://www.toolmao.com/baiduapp/routerpwd/
  - https://datarecovery.com/rd/default-passwords/
- 弱口令
  - https://nordpass.com/most-common-passwords-list/
- “裤子”密码：
  - 已经泄露的数据库中包含的密码；撞库

CSDN-中文 IT 社区-600 万.rar 104MB

多玩网_800W.rar 216MB

人人网 500W_16610.rar 49.5MB

猫 1000W_8228.rar 91.9MB

嘟嘟牛_66277.rar 205MB

7k7k2000 万_2047.rar 194MB

178(1000w)_3087.rar 103MB

检测密码是否有撞库风险

暴力破解/字典攻击

暴力破解：

- 口令长度
- 口令内容　0-9a-zA-z!@#$%^&*

70^6　= 117649000000

70^10 = 282475249000000000

70^12 = 13841287201000000000000

实际上用户倾向于使用容易记忆的口令。

因此，破解时先从常用的口令来尝试

字典（wordlist，dict）：

- Kali自带（/usr/share/wordlists）
- 网络下载（百度、GitHub）
  - https://github.com/DictionaryHouse/Weak-password
  - https://github.com/TgeaUs/Weak-password
  - https://github.com/kkrypt0nn/wordlists
- 指定格式字典，比如生日、手机号、QQ
  - crunch -h
- 社工字典
  - cupp、ccupp
  - bugku.com/mima
- 文章内容字典
  - cewl sqlmap.org -w dict.txt

GPU加速密码破解：https://blog.darkthread.net/blog/hashcat-w-cuda/

恶意软件攻击

类别	是否自我复制	是否依附宿主	传播方式	主要危害	举例
病毒	是	是	文件传播、拷贝、U盘	文件损坏、系统异常	• CIH（“陈盈豪病毒”） • 宏病毒（感染 Word、Excel 文档的宏脚本）
木马	否	否	用户误装、钓鱼、恶意网站	窃密、远控、开后门	• 远控木马（Remote Access Trojan, RAT）、游戏外挂木马、 • 银行木马（窃取网银账号密码）
蠕虫	是	否	网络漏洞、自传播	网络瘫痪、系统崩溃	• “震网（Stuxnet）” • “冲击波（Blaster）” • “熊猫烧香”

缓冲区溢出攻击

程序向内存中写入超出预定范围的数据，导致程序执行异常或漏洞。

缓冲区溢出是指程序向固定长度缓冲区写入超出其容量的数据，导致相邻内存被覆盖的漏洞。

技术本质：

```
char str[4]; // 预定4字节空间
strcpy(str,"ABCDE"); // 写入5个字节 溢出!
```

攻击者可以构造各种恶意输入，覆盖返回地址，使程序跳转到攻击者注入的代码位置执行，从而**实现代码注入、堆栈溢出、堆溢出、格式化字符串攻击、返回导向编程、权限提升和拒绝服务攻击**。

键盘记录攻击

键盘记录攻击（keylogging, key stroke logging），是指在使用键盘的人不知情的情况下，通过隐蔽的方式记录下键盘的每一次敲击的行为。进行键盘监听可通过各种软硬件手段实现。目前最常见的方法为在客户电脑上植入木马程序实现键盘监听。

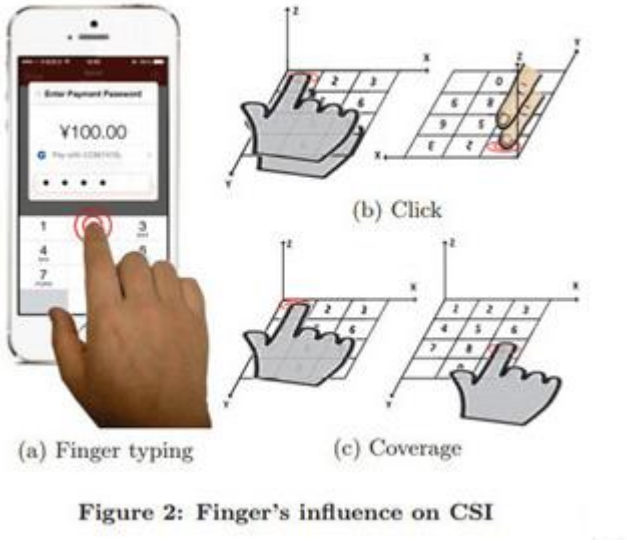
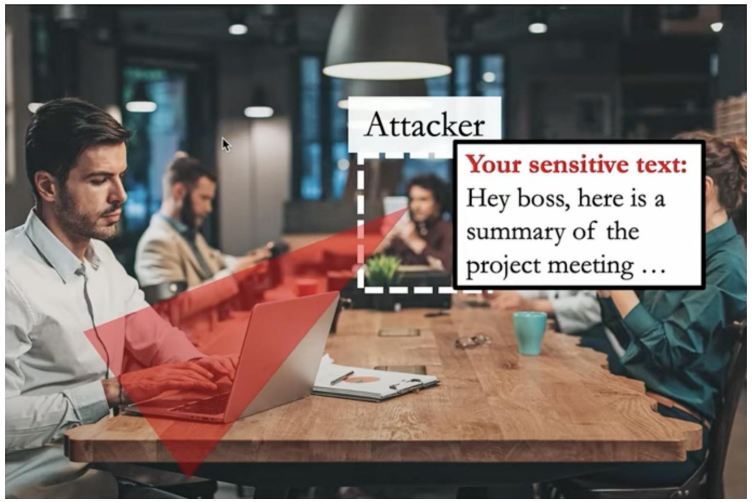
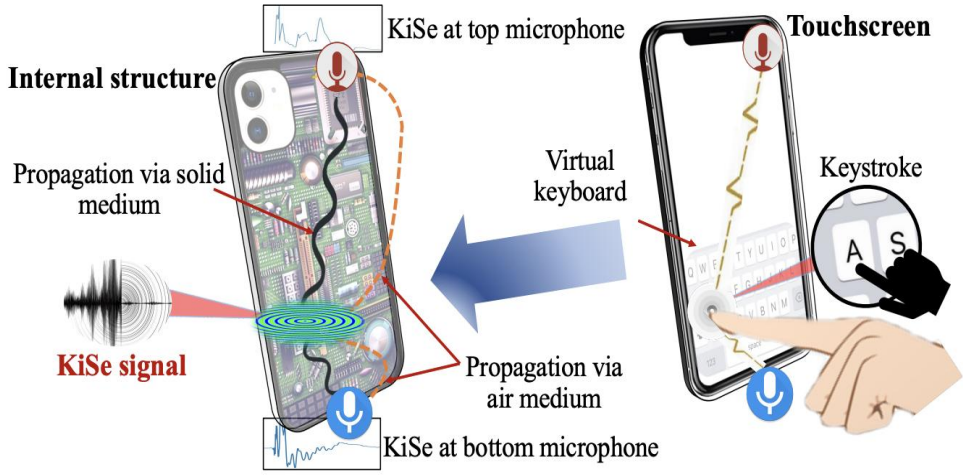


Figure 2: Finger's influence on CSI

监听WIFI变化嗅探手机输入



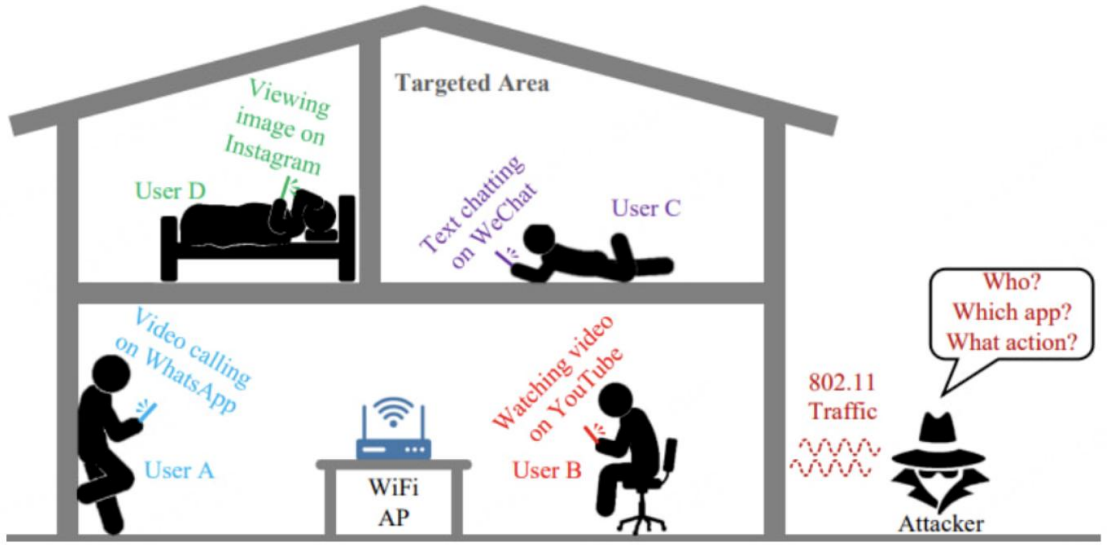
通过视频推测手机输入

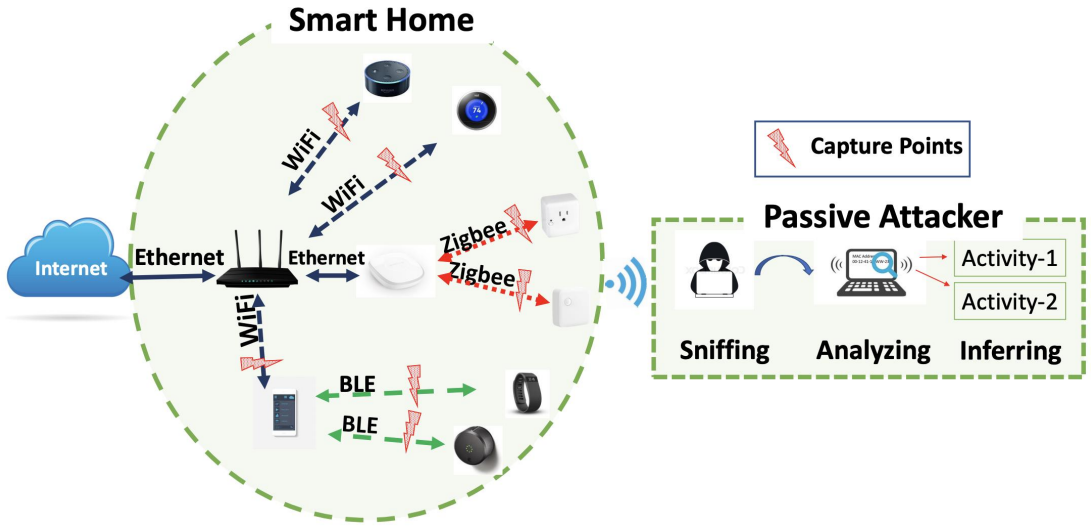


通过手机两个内置麦克风的信号推测手机输入

无线网络攻击

WiFi嗅探

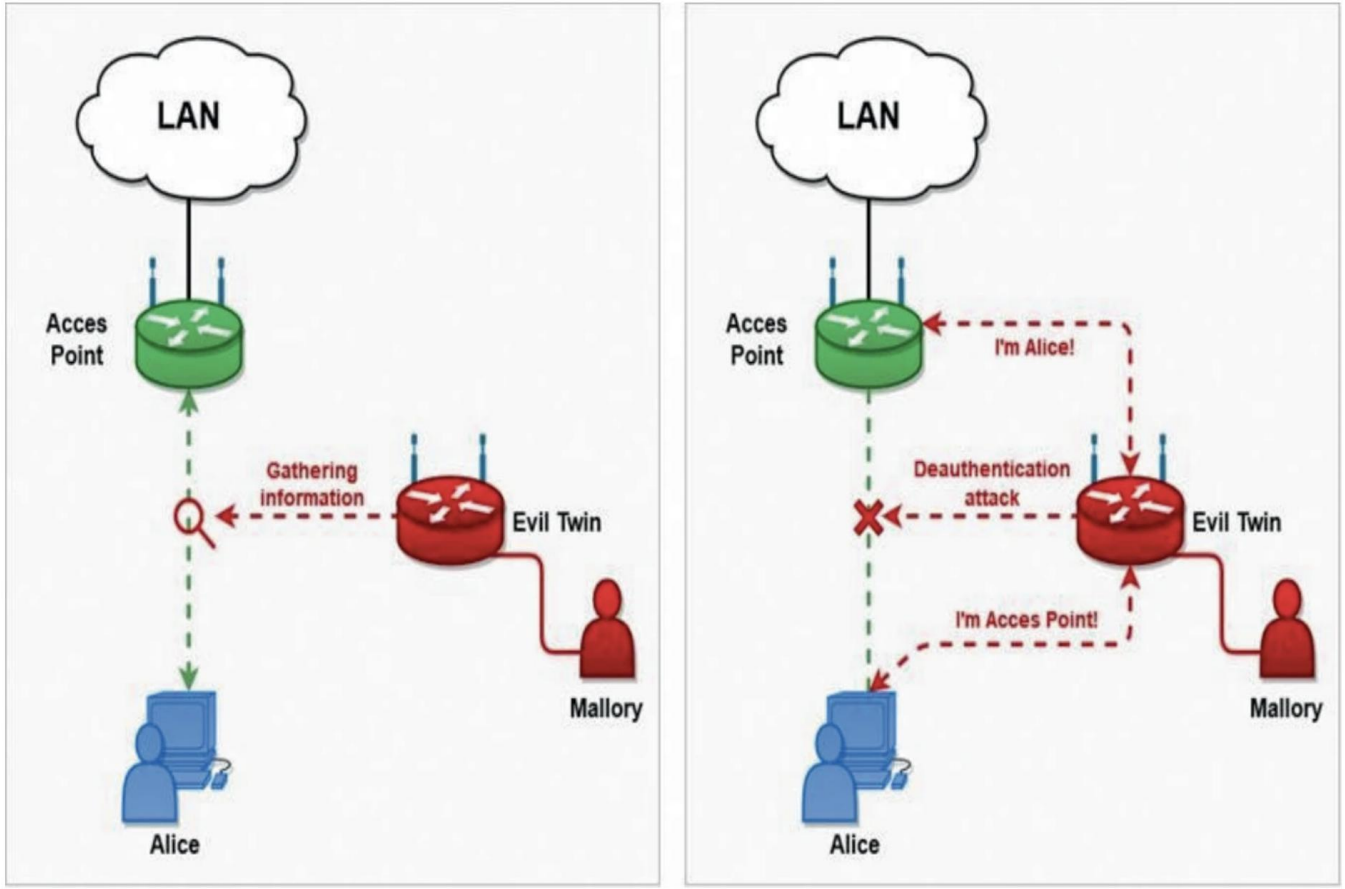




- 用于嗅探的WiFi无线网卡须处于监听（monitor）模式，才可以接收空气介质中的所有可见802.11帧,包括数据帧、管理帧、控制帧。
- 非监听模式下的网卡只能抓取与自身相关的帧，即自己必须是通信的一方。

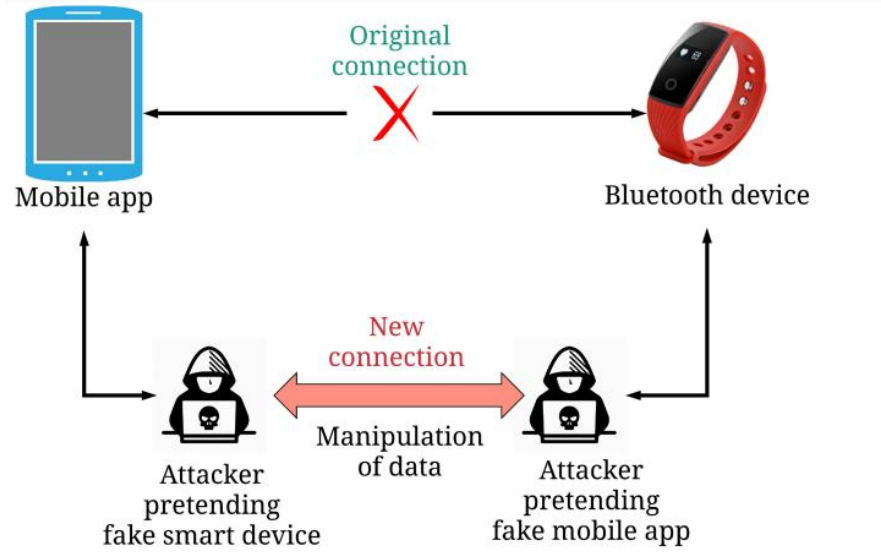
Evil Twin

- 攻击者伪造一个与合法 Wi-Fi 几乎一模一样的无线接入点，诱骗受害者连接，从而窃听、篡改或操纵其网络通信。
- 明文流量窃听、钓鱼式认证页面、Session hijacking、行为/设备指纹分析



蓝牙攻击

- 蓝牙攻击是指攻击者利用蓝牙协议、配对机制或实现缺陷，对设备进行窃听、欺骗或控制的安全威胁。
- 其攻击形式涵盖被动嗅探、中间人攻击、配对劫持以及低功耗蓝牙（BLE）中的隐私与侧信道攻击。



利用漏洞进行中间人攻击



多种蓝牙攻击的信道和手段

社会工程学攻击

社会工程学...

- 攻击目标：有权限的用户——信任
- 社会工程学（Social Engineering，SoE）
  - 社会工程学是通过对社会人的心理弱点、习惯弱点的分析，借助一定的手段达到某些目的
  - 的过程。
- 起源：Kevin David Mitnick：《The Art of Deception》
- 技术漏洞 vs 人的漏洞；渗透 vs 社工

社工的策略

类型	案例
利用好奇心	邮件标题、网页标题、包裹内容
利用紧迫感	打造紧急事件
利用信任	冒充上级、权威机构、亲人、同事、老乡等
利用疲劳	在深夜进行攻击
利用恐惧	爆发严重病毒，请立即修复
利用盲从	阅读数、下载量、购买人数
利用同情	谎称遇到麻烦
	好色、贪婪、自私、愤怒、懒惰、狭隘、自负……

欺骗

类型	案例
资金窃取	中奖短信、订单异常、社保、退税
身份冒充	冒充领导；冒充孩子报课、车祸、进局子
承接需求	升学、买房、求职、退费
交友诈骗	卖茶女、杀猪盘、酒托
果聊诈骗	诱导下载恶意软件，获取通讯录，录像
投资理财诈骗	高回报虚假App、贷款、庞氏骗局
兼职类诈骗	刷单诈骗、打字诈骗
冒充公检法诈骗	账户有洗钱嫌疑

社会工程学的一般攻击流程

1、收集目标信息（人事、保安、运维……）

社交网站、冒充身份获取、社工库、远控

2、伪造身份与目标接触（求职者、维修工、同事）

3、编造谎言迷惑目标（发送邮件、连接网络、进入机房）

4、展开攻击（接入网络、控制机器、窃取信息）

6.3 防御技术及产品

常见防御技术

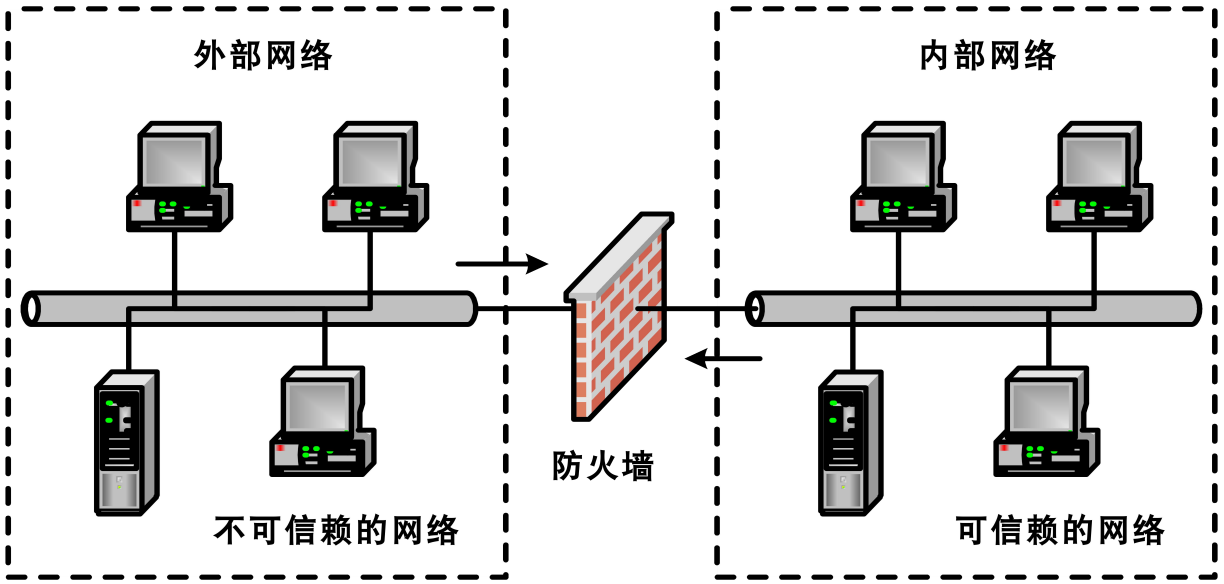
分类	防御技术	作用 / 原理	优点	局限性
网络边界防护	防火墙 (Firewall)	基于规则过滤网络流量，阻止未授权访问	简单高效、部署成熟	无法防御内部攻击、对未知攻击无效
	NAT (网络地址转换)	隐藏内部网络结构，减少外部暴露面	增强隐私、节省 IPv4 地址	非安全机制，不能抵御攻击
	VPN (虚拟专用网络)	通过加密建立安全通道	防窃听、保护远程访问	无法阻止恶意用户进入网络
入侵检测与防御	IDS (入侵检测系统)	监测网络或主机行为，识别异常/攻击	可检测广泛威胁	被动响应，常有误报
	IPS (入侵防御系统)	自动阻断检测到的攻击	实时防御能力强	配置复杂，误拦截风险
访问控制与身份管理	ACL (访问控制列表)	基于用户/设备/资源制定权限规则	精确权限管理	配置复杂，维护成本高
	MFA (多因素认证)	除密码外加入额外认证	安全性显著提升	用户体验可能受影响
	最小权限原则 (Least Privilege)	减少用户权限	降低被攻破后的损害	管理成本较高
恶意软件防御	杀毒软件 / EDR	检测恶意代码与异常行为	能阻止大多数已知恶意软件	对未知攻击效果有限
	沙箱 (Sandbox)	隔离并监控可疑文件执行行为	安全性高，可检测未知恶意样本	资源开销大
网络监测与审计	SIEM (安全信息与事件管理)	集成日志、检测事件、风险分析	全局可视化、自动化分析	成本很高，需要专家运维
	流量分析	持续监测网络数据包	可发现攻击趋势	难处理大规模加密流量
加密与数据保护	TLS/SSL 加密	加密网络通信	防窃听、保密性强	中间人攻击仍需注意
	数据脱敏	防止敏感数据泄露	合规性强、安全性高	部分方案易误拦截
系统/网络强化	补丁管理	修复漏洞	简单有效	对零日漏洞无能为力
欺骗性防御技术	蜜罐 (Honeypot)	诱骗攻击者暴露行为	可分析攻击方式	无法直接阻断攻击
	蜜网 (Honeynet)	更大规模的欺骗网络	高级威胁情报来源	架构复杂

网络边界防护

防火墙

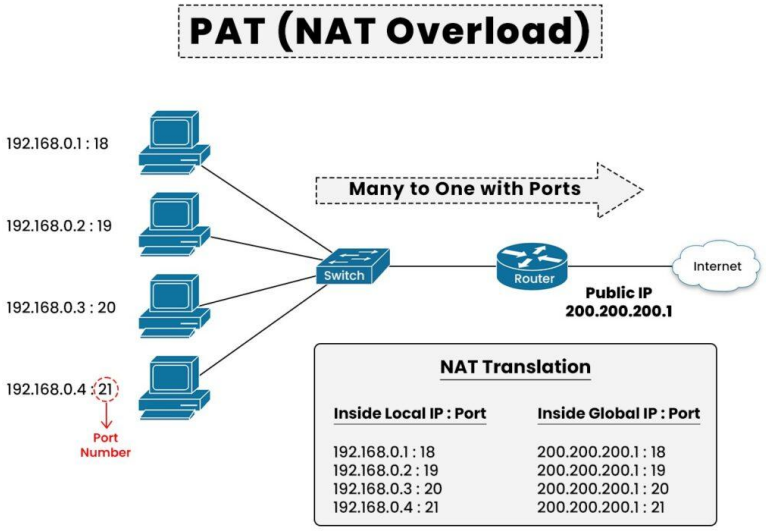
防火墙根据安全策略对进出网络的数据流量进行过滤和控制，以防止未授权访问并保护内部网络安全。

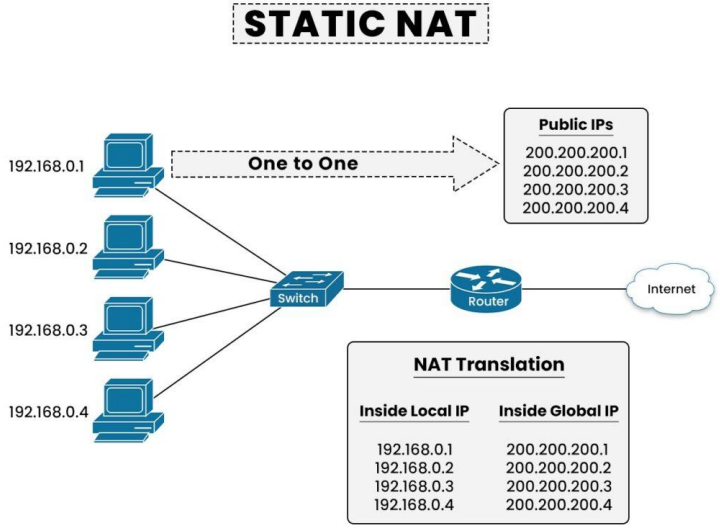
- 所有来自互联网的信息或从内部网络发出的信息都必须穿过防火墙。
- 从逻辑上讲，防火墙是分离器、限制器和分析器。
- 从物理角度看，各站点防火墙的实现方式有所不同。

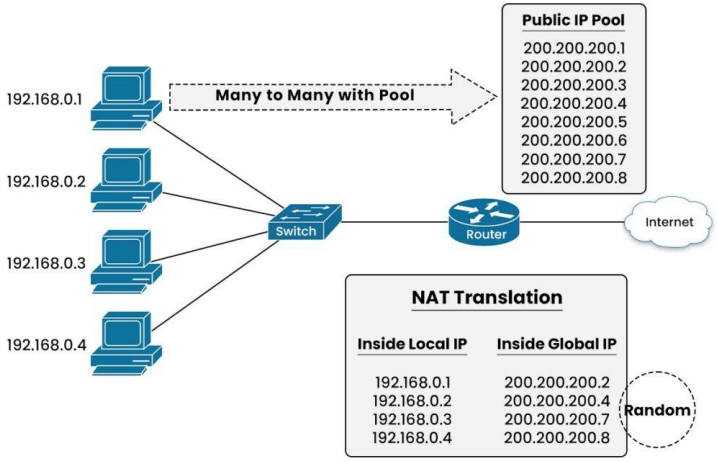


NAT

网络地址转换（Network Address Translation），是一种用于转换网络中IP地址的过程。典型NAT允许私有网络中的多个设备在与外部世界通信时共享一个公网IP地址。这是通过在数据包通过路由器或防火墙时修改其源或目的IP地址来实现的。







不同类型的NAT

IP匮乏

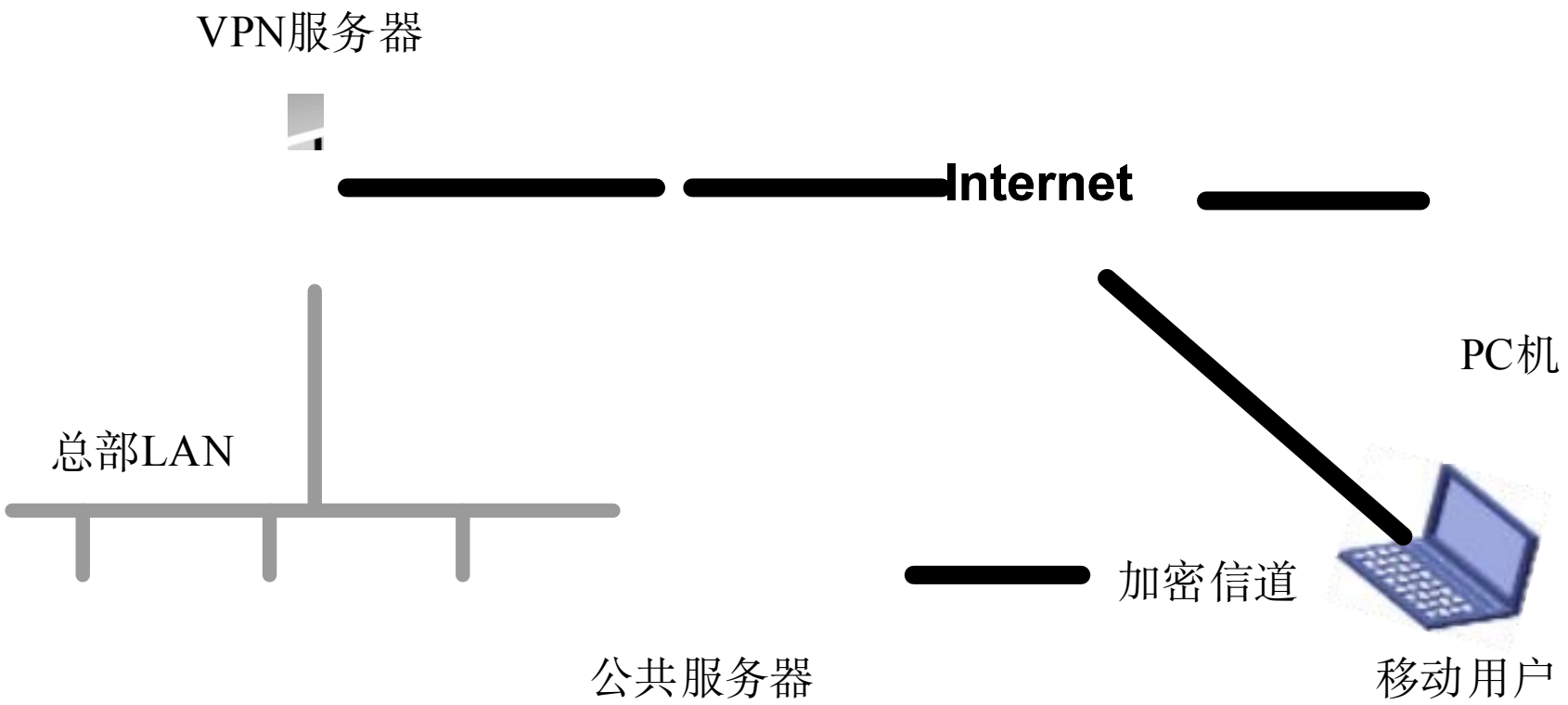
192.168.120.11

每个字节的取值范围是0 ~ 2^8
IP地址的取值空间是2^{32}，远小于网络上的主机数

分层：内网IP和公网IP　　两层：$(2^{32})^2$

虚拟专用网（VPN）

VPN指的是**在公用网络上建立安全加密通道，从而实现专用网络的技术**。之所以称为虚拟网，是因为整个VPN网络的节点之间的连接并没有传统专网所需的端到端的物理链路，而是架构在公用网络上。



虚拟专用网的类型

虚拟专用网分为3种类型：企业内部虚拟网（Intranet VPN）、企业扩展虚拟网（Extranet VPN）和远程访问虚拟网（Access VPN）。

1．企业内部虚拟网：主要任务是保护公司的互联网不被外部入侵，同时保证公司的重要数据流经因特传输时的安全性。

2．企业外部虚拟专用网：利用VPN将企业网延伸至合作伙伴与客户。企业外部虚拟专用网的主要目标是保证数据在传输过程中不被修改，保护网络资源不受外部威胁。

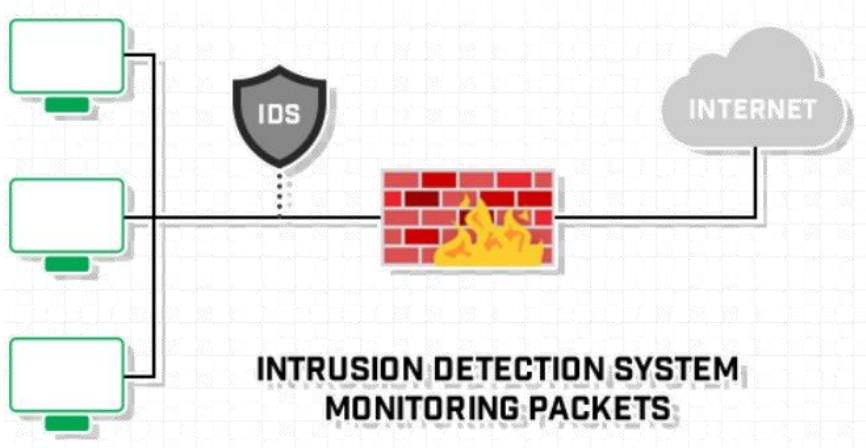
3．远程访问虚拟专用网：通过公用网络与企业的 Intranet 建立私有的网络连接。利用了二层网络隧道技术在公用网络上建立VPN隧道连接来传输私有网络数据。

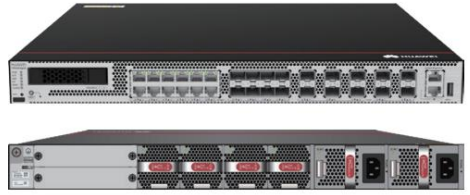
入侵检测与防御

IDS/IPS

➢入侵检测系统（IDS）是一种网络安全设备或应用软件，可以监控网络数据传输（NIDS），或者主机系统行为（HIDS），发现并告警潜在的入侵行为或异常活动，但通常不主动阻断流量。

➢入侵防御系统（IPS）在IDS的基础上，可自动阻断检测到的攻击，实时防御能力强。





华为HiSecEngine IPS6625F

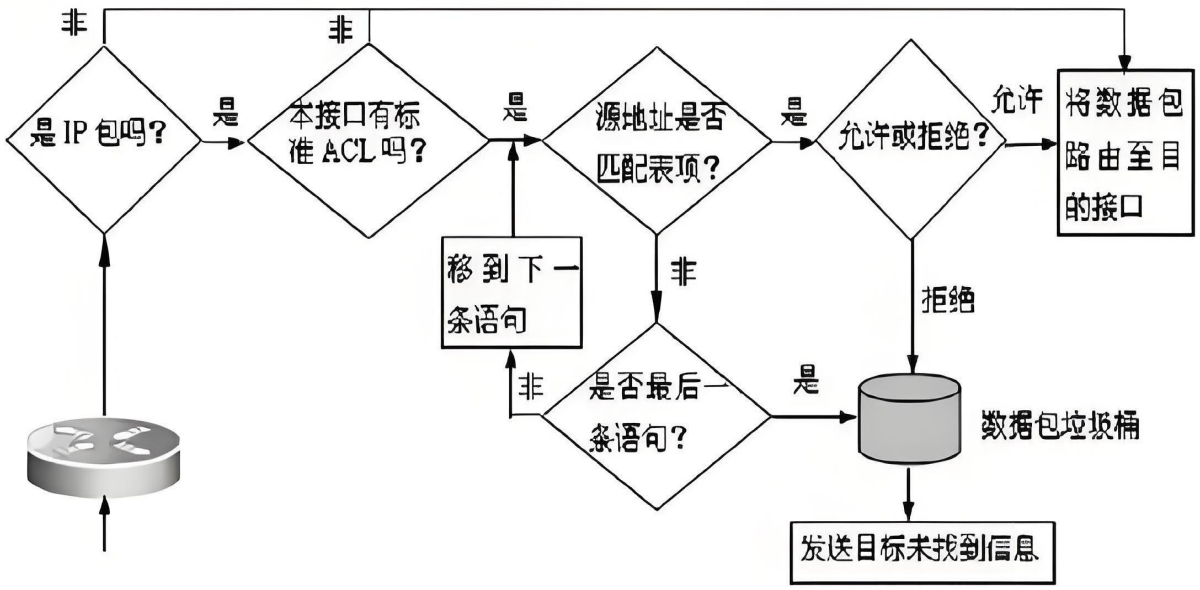


华为HiSecEngine IPS6655F

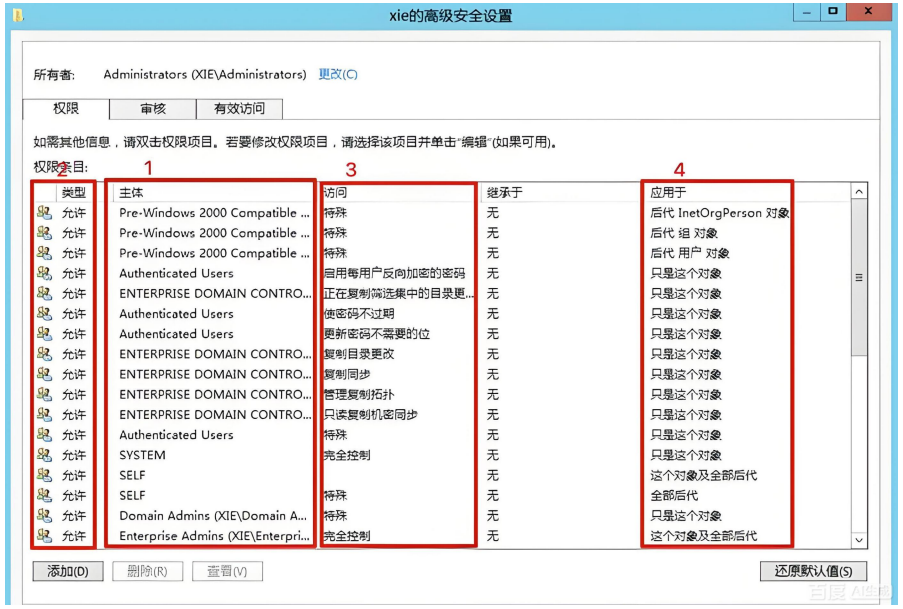
访问控制与身份管理

访问控制列表ACL

- 访问控制列表（ACL）是一种按照预先定义规则，允许或拒绝特定主体对资源进行访问的机制。回忆：访问控制三要素，ACL用于描述控制策略。
- 它通过对访问请求进行逐条匹配，来实现对网络流量或系统资源的精细化控制。



标准ACL工作过程



域内ACL

多因素认证MFA

MFA（Multi-Factor Authentication）是指在身份验证过程中，使用两种或两种以上不同类型的认证因素来确认用户身份的安全机制。MFA的好处是显著降低单一凭据泄露所带来的安全风险。

- 所知信息（如口令密码）
- 所持物品（如验证码设备，电子钥匙等）
- 生物特征（如指纹、人脸、虹膜等）

最小权限原则

最小权限原则是指系统应仅向用户或进程授予完成其任务所必需的最少权限。

好处是减少误操作和安全漏洞被利用时造成的影响范围，从而提高系统整体安全性。

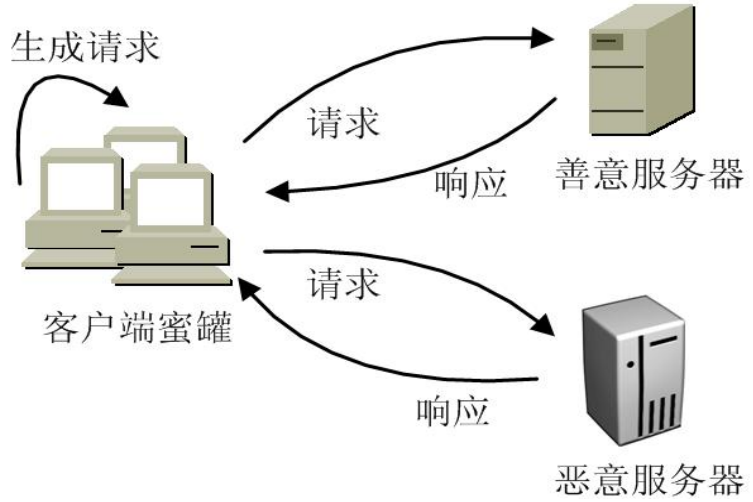
欺骗性防御技术

蜜罐（Honeypot）

蜜罐技术是一种欺骗性的IDS。

蜜罐技术的主要任务是：

- **转移**入侵者对关键系统的访问
- **收集**入侵者的活动信息
- 引诱入侵者在系统中**停留**足够长的时间，以便于管理员对入侵行为做出反应。



蜜罐系统包含了很多看起来有价值的虚假信息。蜜罐系统装备了灵敏的监视器和事件记录器，用于检测对蜜罐系统的访问和收集攻击者的活动信息。